



ΔΙΕΘΝΕΣ  
ΠΑΝΕΠΙΣΤΗΜΙΟ  
ΕΛΛΑΔΟΣ

Δ Ι Ε Θ Ν Ε Σ Π Α Ν Ε Π Ι Σ Τ Η Μ Ι Ο Τ Η Σ Ε Λ Λ Α Δ Ο Σ  
Π Ο Λ Υ Τ Ε Χ Ν Ι Κ Η Σ Χ Ο Λ Η  
Τ Μ Η Μ Α Μ Η Χ Α Ν Ι Κ Ω Ν Π Λ Η Ρ Ο Φ Ο Ρ Ι Κ Η Σ ,  
Υ Π Ο Λ Ο Γ Ι Σ Τ Ω Ν Κ Α Ι Τ Η Λ Ε Π Ι Κ Ο Ι Ν Ω Ν Ι Ω Ν

**Ανίχνευση και Αντιμετώπιση Επιθέσεων σε Δίκτυα  
Οριζόμενα από Λογισμικό (SDN)**

*Detection and Handling of Attacks in Software Defined Networks*

**Διπλωματική Εργασία της**

**Ζαφείρω Μπάρδα**

(ΑΕΜ : 21015)

**Επιβλέπων Καθηγητής:**

Κωνσταντίνος Χειλάς, Καθηγητής

**ΣΕΡΡΕΣ, Ιούλιος 2026**

## Περίληψη

Η υιοθέτηση των Δικτύων Οριζόμενων από Λογισμικό (Software-Defined Networking, SDN) στα σύγχρονα κέντρα δεδομένων και στις υποδομές παρόχων έχει μεταβάλει θεμελιωδώς τη διαχείριση των δικτύων, εισάγοντας ταυτόχρονα μια νέα, κρίσιμη επιφάνεια επίθεσης. Ο διαχωρισμός του επιπέδου ελέγχου (control plane) από το επίπεδο δεδομένων (data plane) και η λογική κεντριοποίηση της ευφυΐας του δικτύου μετατρέπουν τον ελεγκτή σε μοναδικό σημείο αποτυχίας και σε προνομιακό στόχο επιθέσεων άρνησης εξυπηρέτησης.

Η παρούσα διπλωματική σχεδιάζει, υλοποιεί και αξιολογεί ένα ολοκληρωμένο σύστημα ανίχνευσης και αυτόματης αντιμετώπισης επιθέσεων σε περιβάλλον SDN, βασισμένο σε Μηχανική Μάθηση, σε δύο συμπληρωματικά επίπεδα. Η Μέθοδος Α αφορά τη ζωντανή ανίχνευση και αντιμετώπιση σε προσομοιωμένο δίκτυο Mininet/Open vSwitch, όπου ο ελεγκτής υπολογίζει συγκεντρωτικά χαρακτηριστικά (aggregate features) ανά πηγή, εντοπίζει τον επιτιθέμενο με Isolation Forest και επιβάλλει αυτόματα κανόνα απόρριψης (drop) στον μεταγωγέα. Η Μέθοδος Β αφορά την offline ανάλυση ροών σε δεδομένα δομής InSDN/CICFlowMeter, όπου συγκρίνονται οκτώ αλγόριθμοι, έξι κλασικοί και δύο βαθιάς μάθησης, επιβλεπόμενοι και μη.

Στο offline σκέλος, το Random Forest επιτυγχάνει F1-score άνω του 0,999 στο συνθετικό σύνολο και 0,945 (μακρο-F1) στο InSDN. Η τελευταία τιμή ερμηνεύεται ως ένδειξη συμβατότητας του pipeline με πραγματικά δεδομένα και όχι ως απόδειξη γενίκευσης, λόγω της υψηλής παρουσίας διπλότυπων ροών στο σύνολο. Το ζωντανό σκέλος διακρίνεται σε ένα πείραμα σε επίπεδο πακέτου (πλημμύρα SYN σε Mininet/Open vSwitch, με τηλεμετρία από τον μεταγωγέα και αυτόματη εγκατάσταση κανόνα απόρριψης) και σε πειράματα συνθετικής τηλεμετρίας σε επίπεδο API. Το σύστημα αποκρίνεται αξιόπιστα σε επιθέσεις με έντονο στατιστικό αποτύπωμα, όπως η πλημμύρα SYN, η σάρωση θυρών και η εξάντληση του πίνακα ροών, ενώ σε πιο σύνθετα σενάρια, όπως η εξαγωγή δεδομένων, η πλευρική κίνηση και το ARP spoofing, αναδεικνύει περιορισμούς που σχετίζονται με τα ψευδώς θετικά (false positives) και με την απουσία ανάλυσης σε επίπεδο πρωτοκόλλου. Η μελέτη εμβαθύνει με ερμηνευσιμότητα (SHAP), ανάλυση καθυστέρησης, προσομοίωση της επίθεσης κορεσμού του control plane και ανθεκτικότητα σε αντίπαλες επιθέσεις. Η τελευταία ανέδειξε απότομη κατάρρευση του Random Forest σε διαταραχή  $\varepsilon \approx 0,20$ . Ως αντίμετρο προτείνεται και αξιολογείται adversarial training, το οποίο μειώνει τον ρυθμό

αποφυγής από 98,9% σε 0,0% με στατιστικά μη σημαντική απώλεια καθαρής απόδοσης (μακρο-F1 από 0,9998 σε 0,9992). Συνολικά τεκμηριώνεται η λειτουργική εφικτότητα ενός ερευνητικού prototype σε ελεγχόμενο περιβάλλον, με ρητή οριοθέτηση των σημείων που απαιτούν πλήρη ενσωμάτωση OpenFlow και ανάλυση πρωτοκόλλου.

# Abstract

The rapid adoption of Software-Defined Networking (SDN) in modern data centres and provider infrastructures has fundamentally changed the way networks are managed, while simultaneously introducing a new and highly critical attack surface. The separation of the control plane from the data plane and the logical centralisation of network intelligence in the controller turn the latter into a single point of failure and a prime target for denial-of-service attacks.

This diploma thesis designs, implements and evaluates a complete system for the detection and automated mitigation of cyber-attacks in an SDN environment, based on Machine Learning techniques. The approach is developed on two complementary levels. The first (Method B) concerns the offline analysis of flows using supervised and unsupervised models on InSDN/CICFlowMeter-structured data, comparing eight algorithms, six classical and two deep-learning ones. The second (Method A) concerns live detection and mitigation inside a simulated Mininet/Open vSwitch network, where a controller computes aggregate per-source features, identifies the attacker with an Isolation Forest model and automatically installs a drop rule on the switch.

In the offline part, Random Forest achieves an F1-score above 0.999 on the synthetic dataset and 0.945 (macro-F1) on InSDN. The latter is interpreted as an indication of the pipeline's compatibility with real flow data rather than as proof of generalisation, due to the high proportion of duplicate flows in that dataset. The live part comprises one packet-level experiment (SYN flood in Mininet/Open vSwitch, with telemetry collected from the switch and automatic installation of a drop rule) and a set of API-level synthetic-telemetry experiments. The system responds reliably to attacks with a strong statistical footprint, namely SYN flooding, port scanning and flow-table exhaustion, whereas in more complex scenarios, namely data exfiltration, lateral movement and ARP spoofing, it reveals limitations related to false positives and to the absence of protocol-level analysis. The study is further deepened through interpretability analysis (SHAP), detection-latency analysis, a simulation of the control-plane saturation attack, and an investigation of adversarial robustness. The latter revealed an abrupt collapse of Random Forest at a perturbation of  $\epsilon \approx 0.20$ . As a countermeasure, adversarial training is proposed and evaluated, reducing the evasion rate from 98.9% to 0.0% with a statistically non-significant loss of clean performance (macro-F1 from 0.9998 to 0.9992). Overall, the work

demonstrates the functional feasibility of a research prototype in a controlled environment and explicitly delineates the points that require full OpenFlow integration and protocol-level analysis.

**Υπεύθυνη Δήλωση:** Βεβαιώνω ότι είμαι συγγραφέας αυτής της διπλωματικής και ότι κάθε βοήθεια την οποία είχα για την προετοιμασία της, είναι πλήρως αναγνωρισμένη και αναφέρεται στην διπλωματική. Επίσης έχω αναφέρει τις όποιες πηγές από τις οποίες έκανα χρήση δεδομένων, ιδεών ή λέξεων, είτε αυτές αναφέρονται ακριβώς είτε παραφρασμένες. Επίσης, βεβαιώνω ότι αυτή η διπλωματική προετοιμάστηκε από εμένα προσωπικά ειδικά για τις απαιτήσεις του προγράμματος σπουδών του Τμήματος Μηχανικών Πληροφορικής, Υπολογιστών και Τηλεπικοινωνιών του Διεθνούς Πανεπιστημίου της Ελλάδας.

Z. Μπάρδα

# Πίνακας Περιεχομένων

|                                                                                         |    |
|-----------------------------------------------------------------------------------------|----|
| Περίληψη .....                                                                          | 2  |
| Abstract.....                                                                           | 4  |
| Πίνακας Περιεχομένων .....                                                              | 7  |
| Πίνακας Πινάκων .....                                                                   | 12 |
| Πίνακας Σχημάτων .....                                                                  | 13 |
| Πίνακας Συντομογραφιών .....                                                            | 14 |
| 1. Εισαγωγή .....                                                                       | 17 |
| 1.1 Πλαίσιο και κίνητρο .....                                                           | 17 |
| 1.2 Ορισμός του προβλήματος .....                                                       | 18 |
| 1.3 Στόχοι της διπλωματικής .....                                                       | 18 |
| 1.4 Συνεισφορά της διπλωματικής .....                                                   | 19 |
| 1.5 Δομή της διπλωματικής .....                                                         | 19 |
| 1.6 Ιστορικό πλαίσιο.....                                                               | 20 |
| 1.7 Το μέγεθος του προβλήματος.....                                                     | 20 |
| 1.8 Μεθοδολογική προσέγγιση .....                                                       | 21 |
| 2. Αρχιτεκτονική των Δικτύων SDN.....                                                   | 22 |
| 2.1 Τα τρία επίπεδα της αρχιτεκτονικής.....                                             | 22 |
| 2.1.1 Επίπεδο Δεδομένων (Data Plane).....                                               | 22 |
| 2.1.2 Επίπεδο Ελέγχου (Control Plane).....                                              | 22 |
| 2.1.3 Επίπεδο Εφαρμογών (Application Plane) .....                                       | 22 |
| 2.2 Διεπαφές επικοινωνίας και πρωτόκολλα νότιας διεπαφής.....                           | 23 |
| 2.3 Το πρωτόκολλο OpenFlow: μηνύματα, διοχέτευση και στατιστικά .....                   | 23 |
| 2.4 Ελεγκτές SDN: εσωτερική δομή, διαθεσιμότητα και ασφάλεια του καναλιού ελέγχου ..... | 26 |
| 2.5 Εργαλεία προσομοίωσης: Mininet και Open vSwitch .....                               | 27 |

|                                                                                           |    |
|-------------------------------------------------------------------------------------------|----|
| 2.6 Σύγκριση με τα παραδοσιακά δίκτυα: πλεονεκτήματα και προκλήσεις .....                 | 28 |
| 2.7 Σχέση με το NFV, τυποποίηση και οικοσύστημα .....                                     | 29 |
| 2.8 Περιπτώσεις χρήσης και υπηρεσίες του επιπέδου εφαρμογών .....                         | 30 |
| 3. Απειλές και Επιθέσεις σε Δίκτυα SDN .....                                              | 32 |
| 3.1 Επιφάνεια επίθεσης ανά επίπεδο .....                                                  | 32 |
| 3.2 Επιθέσεις άρνησης εξυπηρέτησης: μορφές, κύκλος ζωής και ταξινόμηση.....               | 32 |
| 3.3 Κορεσμός του πίνακα ροών και του καναλιού ελέγχου .....                               | 34 |
| 3.4 Πλαστογράφηση, δηλητηρίαση τηλεμετρίας και επιθέσεις ενδιάμεσου.....                  | 34 |
| 3.5 Σάρωση, πλευρική κίνηση και υποκλοπή.....                                             | 35 |
| 3.6 Ο ελεγκτής ως μοναδικό σημείο αποτυχίας και οι εσωτερικές απειλές.....                | 36 |
| 3.7 Ταξινόμηση των απειλών, υποδομή και αντίκτυπος των επιθέσεων .....                    | 36 |
| 3.8 Μηχανισμοί άμυνας και ο ρόλος του IDS .....                                           | 39 |
| 4. Μέθοδοι Ανίχνευσης και Μηχανική Μάθηση.....                                            | 40 |
| 4.1 Παραδοσιακές μέθοδοι και οι αδυναμίες τους .....                                      | 40 |
| 4.2 Ανίχνευση βασισμένη σε Μηχανική Μάθηση: επισκόπηση και μηχανισμοί των αλγορίθμων..... | 40 |
| 4.3 Ο αλγόριθμος Isolation Forest και η μαθηματική του θεμελίωση .....                    | 42 |
| 4.4 Δημόσια σύνολα δεδομένων και κατηγορίες κίνησης.....                                  | 43 |
| 4.5 Χαρακτηριστικά ροής: εξαγωγή, περιγραφή και επιλογή .....                             | 44 |
| 4.6 Μετρικές αξιολόγησης και καμπύλες ROC .....                                           | 46 |
| 4.7 Σχετική βιβλιογραφία και αρχιτεκτονικές συστημάτων ανίχνευσης.....                    | 47 |
| 4.8 Προεπεξεργασία, ρύθμιση υπερπαραμέτρων και γενίκευση.....                             | 48 |
| 4.9 Ζητήματα ιδιωτικότητας και δεοντολογίας .....                                         | 51 |
| 4.10 Εκδόσεις και εξέλιξη του OpenFlow.....                                               | 52 |
| 5. Μεθοδολογία και Υλοποίηση.....                                                         | 53 |
| 5.1 Συνολική αρχιτεκτονική του συστήματος .....                                           | 53 |
| 5.2 Αρχιτεκτονική ελέγχου: υβριδικό μοντέλο SDN .....                                     | 53 |

|                                                                             |    |
|-----------------------------------------------------------------------------|----|
| 5.2.1 Αιτιολόγηση της σχεδιαστικής επιλογής.....                            | 54 |
| 5.3 Μέθοδος A: Ζωντανό σύστημα και αντιμετώπιση.....                        | 55 |
| 5.3.1 Αποφυγή ψευδώς θετικών .....                                          | 56 |
| 5.4 Μέθοδος B: offline ανάλυση και παραγωγή του συνθετικού συνόλου.....     | 57 |
| 5.5 Ασφάλεια της υλοποίησης και προστασία του ελεγκτή .....                 | 59 |
| 5.6 REST διεπαφή του ελεγκτή .....                                          | 60 |
| 5.7 Ο βρόχος τηλεμετρίας: μορφή μηνυμάτων και αλγόριθμος απόφασης .....     | 60 |
| 5.8 Περιβάλλον εκτέλεσης: Docker, δικτύωση και WSL2 .....                   | 62 |
| 5.9 Οπτικοποίηση σε πραγματικό χρόνο .....                                  | 63 |
| 5.10 Διαχείριση κατάστασης, ταυτοχρονισμού και σφαλμάτων .....              | 63 |
| 5.11 Σχηματική αναπαράσταση της αρχιτεκτονικής και του βρόχου ελέγχου ..... | 64 |
| 5.12 Στρατηγική ελέγχου και συνεχής ενσωμάτωση .....                        | 66 |
| 5.13 Κύκλος ζωής πειράματος: μοντέλα και παραγωγή κίνησης.....              | 66 |
| 6. Πειράματα και Αποτελέσματα .....                                         | 68 |
| 6.1 Πειραματική διάταξη.....                                                | 68 |
| 6.2 Σύγκριση κλασικών μοντέλων Μηχανικής Μάθησης.....                       | 69 |
| 6.3 Σημαντικότητα χαρακτηριστικών και ερμηνευσιμότητα (SHAP) .....          | 71 |
| 6.4 Καμπύλες ROC και διασταυρούμενη επικύρωση .....                         | 75 |
| 6.5 Σύγκριση με μοντέλα Βαθιάς Μάθησης.....                                 | 77 |
| 6.6 Αξιολόγηση στο πραγματικό σύνολο InSDN.....                             | 79 |
| 6.7 Αξιολόγηση και ρύθμιση του Isolation Forest .....                       | 80 |
| 6.8 Ζωντανά σενάρια επίθεσης και αντιμετώπισης.....                         | 83 |
| 6.8.1 DDoS / SYN Flood.....                                                 | 85 |
| 6.8.2 Σάρωση θυρών (Port Scan) .....                                        | 85 |
| 6.8.3 Εξαγωγή δεδομένων (Data Exfiltration) .....                           | 86 |
| 6.8.4 Εξάντληση πίνακα ροών.....                                            | 86 |
| 6.8.5 Πλευρική κίνηση (Lateral Movement).....                               | 86 |

|                                                                                             |     |
|---------------------------------------------------------------------------------------------|-----|
| 6.8.6 ARP Spoofing / MITM.....                                                              | 87  |
| 6.9 Καθυστέρηση ανίχνευσης και αποτελεσματικότητα αντιμετώπισης .....                       | 88  |
| 6.10 Επικύρωση της per-flow τηλεμετρίας σε πραγματική εκτέλεση.....                         | 90  |
| 6.11 Επιθέσεις ειδικές του SDN: κορεσμός του control plane και δηλητηρίαση τηλεμετρίας..... | 93  |
| 6.12 Ανθεκτικότητα σε αντίπαλες επιθέσεις .....                                             | 97  |
| 6.12.1 Το φαινόμενο του γκρεμού (cliff effect) .....                                        | 97  |
| 6.12.2 Ανθεκτικότητα του ζωντανού μοντέλου .....                                            | 98  |
| 6.12.3 Μετριασμός της αντίπαλης ευπάθειας μέσω adversarial training .....                   | 100 |
| 6.13 Πρόσθετα αποτελέσματα, οπτικοποιήσεις και υπολογιστικό κόστος .....                    | 101 |
| 6.14 Σύγκριση με signature-based IDS και με τη βιβλιογραφία .....                           | 105 |
| 6.15 Απειλές εγκυρότητας και στατιστική αξιοπιστία .....                                    | 107 |
| 6.16 Συζήτηση, ζητήματα κλιμάκωσης και πρακτικές συστάσεις .....                            | 108 |
| 7. Συμπεράσματα και Μελλοντική Εργασία .....                                                | 111 |
| 7.1 Σύνοψη ευρημάτων .....                                                                  | 111 |
| 7.2 Περιορισμοί της διπλωματικής.....                                                       | 113 |
| 7.3 Μελλοντικές επεκτάσεις.....                                                             | 115 |
| 7.4 Τελικό συμπέρασμα.....                                                                  | 115 |
| 8. Βιβλιογραφία .....                                                                       | 116 |
| Παράρτημα Α: Οδηγίες αναπαραγωγής των πειραμάτων .....                                      | 119 |
| Α.1 Απαιτήσεις συστήματος.....                                                              | 119 |
| Α.2 Εκκίνηση της στοίβας.....                                                               | 119 |
| Α.3 Εκτέλεση του offline pipeline (Μέθοδος Β).....                                          | 119 |
| Α.4 Εκτέλεση των ζωντανών σεναρίων (Μέθοδος Α) .....                                        | 119 |
| Α.5 Θέση των αποτελεσμάτων .....                                                            | 120 |
| Α.6 Λίστα ελέγχου αναπαραγωγιμότητας .....                                                  | 120 |
| Παράρτημα Β: Πλήρης πίνακας υπερπαραμέτρων του Isolation Forest.....                        | 122 |



## Πίνακας Πινάκων

Δεν βρέθηκαν καταχωρήσεις πίνακα εικόνων.

## Πίνακας Σχημάτων

Δεν βρέθηκαν καταχωρήσεις πίνακα εικόνων.

## Πίνακας Συντομογραφιών

| Συντομογραφία | Επεξήγηση                                                                |
|---------------|--------------------------------------------------------------------------|
| ACK           | Acknowledgement, σημαία TCP επιβεβαίωσης                                 |
| API           | Application Programming Interface                                        |
| ARP           | Address Resolution Protocol                                              |
| BFA           | Brute Force Attack, Επίθεση Ωμής Βίας                                    |
| CI            | Continuous Integration, Συνεχής Ενσωμάτωση                               |
| CICDDoS2019   | σύνολο δεδομένων επιθέσεων DDoS του Canadian Institute for Cybersecurity |
| CICFlowMeter  | εργαλείο εξαγωγής στατιστικών χαρακτηριστικών ανά ροή                    |
| CNN           | Convolutional Neural Network                                             |
| CSV           | Comma-Separated Values, μορφή αρχείου με τιμές χωρισμένες με κόμμα       |
| DL            | Deep Learning, Βαθιά Μάθηση                                              |
| DoS / DDoS    | (Distributed) Denial of Service                                          |
| F1            | F1-score, αρμονικός μέσος ορθότητας (precision) και ανάκλησης (recall)   |
| FIN           | Finish, σημαία TCP ομαλού τερματισμού σύνδεσης                           |
| FN            | False Negative, Ψευδώς Αρνητικό                                          |
| FP / TP       | False Positive / True Positive                                           |
| GRU           | Gated Recurrent Unit, αναδρομική μονάδα με πύλες                         |
| HIDS          | Host-based Intrusion Detection System, IDS σε επίπεδο υπολογιστή         |
| IAT           | Inter-Arrival Time, Χρόνος μεταξύ αφίξεων                                |
| IDS           | Intrusion Detection System, Σύστημα Ανίχνευσης Εισβολών                  |
| IF            | Isolation Forest                                                         |
| InSDN         | δημόσιο σύνολο δεδομένων εισβολών ειδικά για περιβάλλοντα SDN            |
| IP            | Internet Protocol, Πρωτόκολλο Διαδικτύου                                 |
| JSON          | JavaScript Object Notation, μορφή ανταλλαγής δεδομένων                   |
| KNN           | K-Nearest Neighbors                                                      |
| LSTM          | Long Short-Term Memory, αναδρομικό νευρωνικό δίκτυο μακράς βραχείας      |

|           | μνήμης                                                                                        |
|-----------|-----------------------------------------------------------------------------------------------|
| MAC       | Media Access Control, φυσική διεύθυνση δικτυακής διεπαφής                                     |
| MITM      | Man-in-the-Middle                                                                             |
| ML        | Machine Learning, Μηχανική Μάθηση                                                             |
| MLP       | Multi-Layer Perceptron                                                                        |
| NETCONF   | Network Configuration Protocol, πρωτόκολλο διαμόρφωσης συσκευών                               |
| NFV       | Network Functions Virtualization                                                              |
| NIDS      | Network-based Intrusion Detection System, IDS σε επίπεδο δικτύου                              |
| NOX       | ο πρώτος ελεγκτής OpenFlow                                                                    |
| NSL-KDD   | σύνολο δεδομένων ανίχνευσης εισβολών, βελτιωμένη εκδοχή του KDD Cup 99                        |
| ONOS      | Open Network Operating System, ελεγκτής SDN για περιβάλλοντα παρόχων                          |
| OVS       | Open vSwitch                                                                                  |
| OVSDB     | Open vSwitch Database Management Protocol                                                     |
| P4        | Programming Protocol-independent Packet Processors, γλώσσα προγραμματισμού επιπέδου δεδομένων |
| POX       | ελεγκτής SDN υλοποιημένος σε Python, διάδοχος του NOX                                         |
| RBF       | Radial Basis Function, πυρήνας ακτινικής βάσης του SVM                                        |
| REST      | Representational State Transfer                                                               |
| RF        | Random Forest                                                                                 |
| ROC / AUC | Receiver Operating Characteristic / Area Under Curve                                          |
| RST       | Reset, σημαία TCP απότομου τερματισμού σύνδεσης                                               |
| RTT       | Round-Trip Time, Χρόνος Μετάβασης και Επιστροφής                                              |
| SD-WAN    | Software-Defined Wide Area Network, Δίκτυο Ευρείας Περιοχής Οριζόμενο από Λογισμικό           |
| SDN       | Software-Defined Networking, Δίκτυα Οριζόμενα από Λογισμικό                                   |
| SHAP      | SHapley Additive exPlanations                                                                 |
| SLA       | Service Level Agreement, Συμφωνία Επιπέδου Υπηρεσίας                                          |
| SOM       | Self-Organizing Map, Αυτο-Οργανούμενος Χάρτης                                                 |

|      |                                                                                      |
|------|--------------------------------------------------------------------------------------|
| SVM  | Support Vector Machine                                                               |
| SYN  | Synchronize, σημαία TCP για την έναρξη σύνδεσης. Αξιοποιείται στην επίθεση SYN flood |
| TCAM | Ternary Content-Addressable Memory                                                   |
| TCP  | Transmission Control Protocol, Πρωτόκολλο Ελέγχου Μετάδοσης                          |
| TLS  | Transport Layer Security, Ασφάλεια Επιπέδου Μεταφοράς                                |
| TN   | True Negative, Αληθώς Αρνητικό                                                       |
| TTD  | Time-to-Detect, Χρόνος έως την ανίχνευση                                             |
| UDP  | User Datagram Protocol, Πρωτόκολλο Αυτοδύναμων Πακέτων Χρήστη                        |
| WSL2 | Windows Subsystem for Linux 2, υποσύστημα Linux για Windows                          |
| YANG | Yet Another Next Generation, γλώσσα μοντελοποίησης δεδομένων δικτύου                 |

# 1. Εισαγωγή

## 1.1 Πλαίσιο και κίνητρο

Η ραγδαία αύξηση των απαιτήσεων των σύγχρονων δικτυακών εφαρμογών, από το υπολογιστικό νέφος (cloud computing) και το Διαδίκτυο των Πραγμάτων (Internet of Things, IoT) μέχρι τη ροή δεδομένων υψηλής ευκρίνειας και τις εφαρμογές πραγματικού χρόνου, έχει αναδείξει με έντονο τρόπο τους διαρθρωτικούς περιορισμούς της παραδοσιακής δικτυακής αρχιτεκτονικής. Στα συμβατικά δίκτυα, η λογική ελέγχου (control logic) και η προώθηση των δεδομένων (data forwarding) είναι στενά συνυφασμένες μέσα σε κάθε δικτυακή συσκευή. Κάθε δρομολογητής ή μεταγωγέας (switch) λαμβάνει τοπικές, αυτόνομες αποφάσεις, με αποτέλεσμα η διαχείριση του δικτύου να καθίσταται δύσκαμπτη, η κλιμάκωση δαπανηρή και η εισαγωγή νέων λειτουργιών ιδιαίτερα αργή, καθώς εξαρτάται από κλειστό, ιδιόκτητο υλικολογισμικό των κατασκευαστών.

Τα Δίκτυα Οριζόμενα από Λογισμικό (Software-Defined Networking, SDN) προτείνουν μια ριζική αναδιάρθρωση αυτού του μοντέλου: τον σαφή διαχωρισμό του επιπέδου ελέγχου από το επίπεδο δεδομένων. Η λογική του δικτύου αφαιρείται από τις μεμονωμένες συσκευές και συγκεντρώνεται σε έναν λογικά κεντρικό ελεγκτή (controller), ο οποίος διαθέτει σφαιρική εικόνα της τοπολογίας και προγραμματίζει τη συμπεριφορά των μεταγωγέων μέσω ανοιχτών, τυποποιημένων πρωτοκόλλων, κατεξοχήν του OpenFlow. Το αποτέλεσμα είναι ένα δίκτυο που καθίσταται προγραμματιζόμενο, ευέλικτο και δυναμικά αναδιατάξιμο μέσω λογισμικού, με προφανή οφέλη για την αυτοματοποίηση, τη διαχείριση πολιτικών και την ταχύτητα καινοτομίας.

Η ίδια, ωστόσο, αρχιτεκτονική επιλογή που προσδίδει την ευελιξία, δημιουργεί και μια νέα, κρίσιμη επιφάνεια επίθεσης. Η λογική κεντρικοποίηση του ελέγχου μπορεί να καταστήσει έναν μη πλεονασματικό ελεγκτή μοναδικό σημείο αποτυχίας (single point of failure): αν τεθεί εκτός λειτουργίας ή κορεστεί, η λειτουργία του δικτύου διακυβεύεται. Στην πράξη οι κατανεμημένες ή replicated αναπτύξεις ελεγκτή μετριάζουν τον κίνδυνο αυτόν, όμως η επιφάνεια επίθεσης προς το επίπεδο ελέγχου παραμένει. Επιπλέον, το κανάλι ελέγχου (control channel) μεταξύ ελεγκτή και μεταγωγέων, καθώς και ο μηχανισμός με τον οποίο τα «άγνωστα» πακέτα προωθούνται στον ελεγκτή για απόφαση, ανοίγουν νέους δρόμους για επιθέσεις άρνησης εξυπηρέτησης που δεν υφίστανται καν στα

παραδοσιακά δίκτυα. Η προστασία του ελεγκτή SDN αναδεικνύεται, επομένως, σε ζήτημα υψίστης σημασίας για την αξιοπιστία ολόκληρης της υποδομής.

## 1.2 Ορισμός του προβλήματος

Το πρόβλημα που πραγματεύεται η παρούσα διπλωματική είναι η έγκαιρη και ακριβής ανίχνευση κακόβουλης δικτυακής κίνησης σε περιβάλλον SDN, καθώς και η αυτόματη αντιμετώπισή της πριν προκληθεί ουσιαστική ζημιά στην υποδομή. Οι παραδοσιακές μέθοδοι άμυνας, όπως τα συστήματα ανίχνευσης εισβολών βάσει υπογραφών (signature-based IDS), παρουσιάζουν δύο βασικούς περιορισμούς: αφενός τυπικά δυσκολεύονται να ανιχνεύσουν άγνωστες (zero-day) επιθέσεις για τις οποίες δεν υπάρχει ακόμη υπογραφή, και αφετέρου συχνά εισάγουν καθυστέρηση, καθώς βασίζονται σε επιθεώρηση κάθε πακέτου. Η προσέγγιση βάσει ανωμαλίας δεν αναιρεί αυτούς τους περιορισμούς, αλλά τους αντισταθμίζει μερικώς, με το δικό της κόστος σε ψευδώς θετικά. Σε ένα περιβάλλον όπου ο ελεγκτής μπορεί να κορεστεί μέσα σε δευτερόλεπτα, η καθυστέρηση αυτή είναι κρίσιμη.

Η Μηχανική Μάθηση προσφέρει μια εναλλακτική προσέγγιση: αντί για στατικές υπογραφές, τα μοντέλα μαθαίνουν τα στατιστικά χαρακτηριστικά της νόμιμης και της κακόβουλης κίνησης και γενικεύουν σε νέες, άγνωστες παραλλαγές επιθέσεων. Το ερώτημα που τίθεται είναι κατά πόσον μια τέτοια προσέγγιση μπορεί να ενσωματωθεί αποτελεσματικά στην αρχιτεκτονική SDN, αξιοποιώντας τα ίδια τα στατιστικά ροών που ο μεταγωγέας ήδη συλλέγει, ώστε να επιτυγχάνεται ανίχνευση σε πραγματικό χρόνο και αυτόματη αντιμετώπιση μέσω δυναμικής εγκατάστασης κανόνων ροής.

## 1.3 Στόχοι της διπλωματικής

Οι στόχοι της παρούσας διπλωματικής περιλαμβάνουν τη μελέτη της αρχιτεκτονικής SDN και του πρωτοκόλλου OpenFlow, με έμφαση στις επιπτώσεις τους στην ασφάλεια του δικτύου, τη συστηματική ανάλυση των βασικών κατηγοριών επιθέσεων ανά επίπεδο της αρχιτεκτονικής, καθώς και τον σχεδιασμό και την υλοποίηση συστήματος ανίχνευσης βασισμένου σε τεχνικές Μηχανικής Μάθησης. Επιπλέον, η μελέτη στοχεύει στην ενσωμάτωση του μηχανισμού ανίχνευσης σε ζωντανό περιβάλλον προσομοίωσης Mininet/Open vSwitch, στην αυτόματη αντιμετώπιση επιθέσεων μέσω κανόνων απόρριψης και στην πειραματική αξιολόγηση της απόδοσης ως προς τις μετρικές ταξινόμησης, την καθυστέρηση ανίχνευσης, την αποτελεσματικότητα αντιμετώπισης και

την εμφάνιση ψευδώς θετικών. Τέλος, εξετάζονται ζητήματα ερμηνευσιμότητας, κορεσμού του control plane και ανθεκτικότητας έναντι αντίπαλων στρατηγικών αποφυγής.

Οι στόχοι αυτοί συγκεκριμενοποιούνται στα ακόλουθα πέντε ερευνητικά ερωτήματα, τα οποία καθοδηγούν τον σχεδιασμό των πειραμάτων και απαντώνται στο Κεφάλαιο 6:

RQ1: Ποια είναι η απόδοση ταξινόμησης των κλασικών μοντέλων Μηχανικής Μάθησης σε δεδομένα ροών SDN, υπό διαχωρισμό ανθεκτικό στη διαρροή ακριβών διπλότυπων;

RQ2: Πώς συμπεριφέρεται το μη επιβλεπόμενο Isolation Forest στο συνθετικό σύνολο έναντι του πραγματικού InSDN, και τι αποκαλύπτει η διαφορά για τη γενίκευση;

RQ3: Σε επίπεδο πακέτου (Mininet/Open vSwitch), ανιχνεύεται και αντιμετωπίζεται μια επίθεση πλημμύρας εντός του πρώτου παραθύρου παρατήρησης;

RQ4: Ποια είναι η επίπτωση των ψευδώς θετικών στη νόμιμη κίνηση, και μπορεί να περιοριστεί ώστε το σύστημα να μην πλήττει νόμιμους χρήστες;

RQ5: Ποια είναι η επίδραση του μηχανισμού αντιμετώπισης στην απόδοση του δικτύου και ποιοι περιορισμοί απομένουν για μια πλήρη reactive SDN υλοποίηση;

## **1.4 Συνεισφορά της διπλωματικής**

Η συνεισφορά της παρούσας διπλωματικής εντοπίζεται σε τρία επίπεδα. Πρώτον, πραγματοποιείται συγκριτική αξιολόγηση οκτώ μοντέλων Μηχανικής Μάθησης σε δεδομένα δομής SDN/InSDN, με στόχο την ανάδειξη του καταλληλότερου αλγορίθμου για ταξινόμηση ροών. Δεύτερον, υλοποιείται ζωντανό σύστημα ανίχνευσης και αντιμετώπισης σε προσομοιωμένο περιβάλλον Mininet/Open vSwitch, το οποίο συνδέει την απόφαση του μοντέλου με την αυτόματη εγκατάσταση κανόνων απόρριψης. Τρίτον, η αξιολόγηση επεκτείνεται πέρα από τις κλασικές μετρικές ταξινόμησης, εξετάζοντας την καθυστέρηση ανίχνευσης, την αποτελεσματικότητα της αντιμετώπισης, την ερμηνευσιμότητα μέσω SHAP και την ανθεκτικότητα έναντι αντίπαλων στρατηγικών αποφυγής, όπου αναδεικνύεται και το φαινόμενο του γκρεμού (cliff effect) στα δέντρα απόφασης.

## **1.5 Δομή της διπλωματικής**

Το υπόλοιπο της διπλωματικής οργανώνεται ως εξής. Το Κεφάλαιο 2 παρουσιάζει το θεωρητικό υπόβαθρο των δικτύων SDN και του πρωτοκόλλου OpenFlow. Το Κεφάλαιο 3 αναλύει τις απειλές και τις κατηγορίες επιθέσεων σε περιβάλλον SDN. Το Κεφάλαιο 4 επισκοπεί τις μεθόδους ανίχνευσης εισβολών και τα θεμέλια της Μηχανικής Μάθησης που

αξιοποιούνται. Το Κεφάλαιο 5 περιγράφει αναλυτικά τη μεθοδολογία και την υλοποίηση, τόσο του offline pipeline όσο και του ζωντανού συστήματος. Το Κεφάλαιο 6 παρουσιάζει και σχολιάζει τα πειραματικά αποτελέσματα. Τέλος, το Κεφάλαιο 7 συνοψίζει τα συμπεράσματα, τους περιορισμούς και τις κατευθύνσεις μελλοντικής εργασίας.

## **1.6 Ιστορικό πλαίσιο**

Η ιδέα του διαχωρισμού ελέγχου και προώθησης δεν είναι εντελώς νέα, προϋπήρξε σε ερευνητικές προσπάθειες όπως τα active networks και τα προγραμματιζόμενα δίκτυα της δεκαετίας του 1990. Ωστόσο, η πρακτική καθιέρωση των SDN συνδέεται με την εισαγωγή του OpenFlow το 2008 από την ερευνητική ομάδα του Stanford, το οποίο για πρώτη φορά προσέφερε μια τυποποιημένη, ανοιχτή διεπαφή για τον προγραμματισμό εμπορικών μεταγωγέων. Η επακόλουθη υιοθέτηση από μεγάλους παρόχους νεφοϋπολογιστικής (cloud computing) και η ίδρυση οργανισμών τυποποίησης εδραίωσαν τα SDN ως κυρίαρχο παράδειγμα για τα σύγχρονα κέντρα δεδομένων.

Παράλληλα με τη λειτουργική ωρίμανση, αναδείχθηκε και η ανάγκη για εξειδικευμένη έρευνα ασφάλειας. Η πρωτοποριακή εργασία των Braga κ.ά. [1] έδειξε ότι τα ίδια τα στατιστικά ροών του OpenFlow μπορούν να τροφοδοτήσουν ελαφρείς ανιχνευτές DDoS, θέτοντας τα θεμέλια της προσέγγισης που ακολουθείται και εδώ. Έκτοτε, η βιβλιογραφία έχει εμπλουτιστεί με πλήθος μεθόδων Μηχανικής Μάθησης, τις οποίες αναλύουμε στο Κεφάλαιο 4.

## **1.7 Το μέγεθος του προβλήματος**

Η σημασία της προστασίας των δικτύων από επιθέσεις άρνησης εξυπηρέτησης δεν είναι θεωρητική. Οι επιθέσεις DDoS έχουν αυξηθεί σημαντικά σε συχνότητα, όγκο και πολυπλοκότητα κατά την τελευταία δεκαετία, με σύγχρονες επιθέσεις να ξεπερνούν τα εκατοντάδες gigabits ανά δευτερόλεπτο. Η διάδοση ανασφαλών συσκευών του Διαδικτύου των Πραγμάτων (IoT) έχει προσφέρει στους επιτιθέμενους τεράστια δίκτυα παραβιασμένων συσκευών, ικανά να εξαπολύσουν επιθέσεις πρωτοφανούς κλίμακας. Παράλληλα, η μετάβαση κρίσιμων υπηρεσιών στο νέφος (cloud) έχει αυξήσει το κόστος της διακοπής λειτουργίας, καθιστώντας την ασφάλεια του δικτύου ζήτημα άμεσης επιχειρησιακής προτεραιότητας.

Σε αυτό το πλαίσιο, η κεντροποίηση των SDN λειτουργεί ως δίκοπο μαχαίρι. Από τη μία, προσφέρει κατάλληλη θέση για την εγκατάσταση κεντρικού μηχανισμού άμυνας με καθολική εποπτεία του δικτύου. Από την άλλη, συγκεντρώνει το ρίσκο, καθιστώντας τον

ελεγκτή ελκυστικό στόχο. Η παρούσα μελέτη τοποθετείται σε αυτό το σημείο τομής, αξιοποιώντας το πλεονέκτημα της κεντρικής εποπτείας για την προστασία του ίδιου του σημείου που τη συγκεντρώνει.

## **1.8 Μεθοδολογική προσέγγιση**

Η μεθοδολογία που ακολουθήθηκε συνδυάζει τη θεωρητική μελέτη με την πειραματική επαλήθευση, σε μια επαναληπτική διαδικασία. Αρχικά μελετήθηκε το θεωρητικό υπόβαθρο των SDN και των απειλών τους, ώστε να προσδιοριστούν οι απαιτήσεις του συστήματος. Στη συνέχεια σχεδιάστηκε και υλοποιήθηκε το offline pipeline, το οποίο επέτρεψε την επιλογή των καταλληλότερων αλγορίθμων. Ακολούθησε η ανάπτυξη του ζωντανού συστήματος, με διαρκή αξιολόγηση και βελτίωση μέσω των πειραματικών σεναρίων. Τέλος, πραγματοποιήθηκαν οι εμβαθύνσεις σε ζητήματα ερμηνευσιμότητας και ασφάλειας. Η προσέγγιση αυτή, με τη σταδιακή οικοδόμηση από τη θεωρία στην πράξη και την πειραματική επικύρωση κάθε σταδίου, διασφάλισε ότι οι σχεδιαστικές αποφάσεις τεκμηριώνονται από δεδομένα και όχι από υποθέσεις.

Καθ' όλη τη διάρκεια δόθηκε έμφαση στην αναπαραγωγικότητα και στην τεκμηρίωση. Κάθε πείραμα σχεδιάστηκε ώστε να είναι επαναλήψιμο, κάθε αποτέλεσμα καταγράφηκε σε μορφή που επιτρέπει την ανεξάρτητη επαλήθευση, και κάθε σχεδιαστική επιλογή αιτιολογήθηκε ρητά. Η προσέγγιση αυτή αντικατοπτρίζει την πεποίθηση ότι η επιστημονική αξία μιας εργασίας έγκειται εξίσου στα αποτελέσματα και στη δυνατότητα ελέγχου τους.

## **2. Αρχιτεκτονική των Δικτύων SDN**

Η θεμελιώδης ιδέα των Δικτύων Οριζόμενων από Λογισμικό είναι ο διαχωρισμός των αρμοδιοτήτων που στα παραδοσιακά δίκτυα συνυπάρχουν στην ίδια συσκευή. Αντί κάθε δρομολογητή να ενσωματώνει τόσο τη λογική απόφασης όσο και τον μηχανισμό προώθησης, τα SDN αποσυνδέουν αυτά τα δύο και εισάγουν μια σαφή, ιεραρχική οργάνωση σε τρία λογικά επίπεδα, τα οποία επικοινωνούν μέσω καλά ορισμένων διεπαφών προγραμματισμού.

### **2.1 Τα τρία επίπεδα της αρχιτεκτονικής**

#### **2.1.1 Επίπεδο Δεδομένων (Data Plane)**

Το επίπεδο δεδομένων αποτελείται από τους δικτυακούς μεταγωγείς (switches), οι οποίοι στα SDN είναι απλές, «ανόητες» συσκευές προώθησης, χωρίς ενσωματωμένη λογική ελέγχου. Κάθε μεταγωγέας διατηρεί έναν ή περισσότερους πίνακες ροών (flow tables), οι οποίοι περιέχουν κανόνες που υπαγορεύουν πώς θα χειριστεί τα εισερχόμενα πακέτα. Όταν ένα πακέτο ταιριάζει σε έναν κανόνα, εκτελείται η αντίστοιχη ενέργεια (προώθηση σε θύρα, απόρριψη, τροποποίηση κεφαλίδων). Όταν όμως δεν ταιριάζει σε κανέναν υπάρχοντα κανόνα, γεγονός που ονομάζεται table-miss, το πακέτο (ή μια περίληψή του) προωθείται στον ελεγκτή μέσω μηνύματος Packet-In, ώστε ο τελευταίος να αποφασίσει.

#### **2.1.2 Επίπεδο Ελέγχου (Control Plane)**

Το επίπεδο ελέγχου περιέχει τον ελεγκτή, ο οποίος αποτελεί τον λογικό «εγκέφαλο» του δικτύου. Ο ελεγκτής διατηρεί μια σφαιρική εικόνα της τοπολογίας (global network view), λαμβάνει αποφάσεις δρομολόγησης και προγραμματίζει τους πίνακες ροών των μεταγωγέων μέσω μηνυμάτων Flow-Mod. Η λογική συγκέντρωση της ευφυΐας απλοποιεί σημαντικά τη διαχείριση: μια πολιτική ασφαλείας ή δρομολόγησης ορίζεται μία φορά, κεντρικά, και εφαρμόζεται συνεπώς σε ολόκληρο το δίκτυο. Ταυτόχρονα, όμως, η ίδια συγκέντρωση δημιουργεί ένα κρίσιμο σημείο ευπάθειας, στο οποίο εστιάζει και η παρούσα μελέτη.

#### **2.1.3 Επίπεδο Εφαρμογών (Application Plane)**

Στο ανώτερο επίπεδο βρίσκονται οι δικτυακές εφαρμογές, μηχανισμοί εξισορρόπησης φορτίου, τείχη προστασίας, συστήματα ανίχνευσης εισβολών, εφαρμογές traffic engineering, που υλοποιούν την επιχειρησιακή πολιτική του οργανισμού. Οι εφαρμογές

αυτές δεν επικοινωνούν απευθείας με το υλικό. Αντ' αυτού αλληλεπιδρούν με τον ελεγκτή μέσω της βόρειας διεπαφής (northbound API), συνήθως μιας RESTful διεπαφής. Το σύστημα ανίχνευσης που αναπτύσσεται εδώ εντάσσεται εννοιολογικά ακριβώς σε αυτό το επίπεδο: αποτελεί μια εφαρμογή ασφαλείας που εποπτεύει το δίκτυο και επιβάλλει πολιτικές μέσω του ελεγκτή.

## **2.2 Διεπαφές επικοινωνίας και πρωτόκολλα νότιας διεπαφής**

Η νότια διεπαφή (southbound API) συνδέει τον ελεγκτή με τους μεταγωγείς. Το επικρατέστερο πρωτόκολλο είναι το OpenFlow, ενώ υποστηρίζονται και άλλα, όπως τα NETCONF και OVSDB για τη διαμόρφωση των συσκευών. Η βόρεια διεπαφή (northbound API), αντίθετα, εκθέτει τις λειτουργίες του ελεγκτή προς τις εφαρμογές του ανώτερου επιπέδου. Ενώ η νότια διεπαφή είναι σε μεγάλο βαθμό τυποποιημένη, η βόρεια παραμένει λιγότερο πρότυπη και συχνά εξαρτάται από τον εκάστοτε ελεγκτή.

### **Άλλα πρωτόκολλα νότιας διεπαφής**

Παρότι το OpenFlow είναι το επικρατέστερο πρωτόκολλο νότιας διεπαφής, το οικοσύστημα SDN περιλαμβάνει και άλλα. Το NETCONF, σε συνδυασμό με το μοντέλο δεδομένων YANG, χρησιμοποιείται για τη διαμόρφωση συσκευών. Το OVSDB είναι το πρωτόκολλο διαχείρισης του Open vSwitch, το οποίο λειτουργεί συμπληρωματικά προς το OpenFlow: το πρώτο διαμορφώνει τη δομή του μεταγωγέα (γέφυρες, θύρες), ενώ το δεύτερο προγραμματίζει τη συμπεριφορά προώθησης. Πιο πρόσφατα, η γλώσσα P4 επιτρέπει τον προγραμματισμό της ίδιας της διοχέτευσης επεξεργασίας του μεταγωγέα, προσφέροντας ακόμη μεγαλύτερη ευελιξία. Η επίγνωση αυτού του ευρύτερου τοπίου βοηθά στην τοποθέτηση της υλοποίησης που περιγράφεται, η οποία αξιοποιεί τη σημασιολογία OpenFlow μέσω του Open vSwitch.

## **2.3 Το πρωτόκολλο OpenFlow: μηνύματα, διοχέτευση και στατιστικά**

Το OpenFlow, που εισήχθη από τους McKeown κ.ά. [2], είναι το πρότυπο πρωτόκολλο επικοινωνίας ελεγκτή-μεταγωγέα και αποτελεί τον ακρογωνιαίο λίθο των SDN. Ορίζει τη δομή των πινάκων ροών, όπου κάθε καταχώρηση αποτελείται από τρία βασικά μέρη: τα πεδία ταιριάσματος (match fields, π.χ. διευθύνσεις MAC/IP, θύρες, πρωτόκολλο), τους μετρητές (counters, που καταγράφουν πλήθος πακέτων και bytes ανά ροή) και τις ενέργειες (actions). Η αρχή λειτουργίας match-action είναι απλή αλλά ιδιαίτερα

εκφραστική: για κάθε εισερχόμενο πακέτο, ο μεταγωγέας βρίσκει την καταχώρηση με την υψηλότερη προτεραιότητα που ταιριάζει και εκτελεί την αντίστοιχη ενέργεια.

Ιδιαίτερη σημασία για την παρούσα μελέτη έχουν οι μετρητές ανά ροή. Καθώς ο μεταγωγέας καταγράφει αυτόματα το πλήθος πακέτων, το πλήθος bytes και τη διάρκεια κάθε ροής, τα στατιστικά αυτά (OpenFlow Flow-Stats / Port-Stats) μπορούν να ανακτηθούν περιοδικά από τον ελεγκτή και να τροφοδοτήσουν απευθείας το μοντέλο Μηχανικής Μάθησης, χωρίς ανάγκη για βαθιά επιθεώρηση πακέτων (deep packet inspection). Αυτό καθιστά την ανίχνευση βάσει ροών εγγενώς αποδοτική και κλιμακώσιμη.

### Τύποι μηνυμάτων OpenFlow

Το πρωτόκολλο OpenFlow ορίζει μια σειρά μηνυμάτων για την επικοινωνία ελεγκτή-μεταγωγέα. Τα σημαντικότερα για την κατανόηση των επιθέσεων και της άμυνας που υλοποιείται συνοψίζονται στον ακόλουθο πίνακα.

| Μήνυμα                   | Κατεύθυνση          | Σκοπός                                                                                        |
|--------------------------|---------------------|-----------------------------------------------------------------------------------------------|
| Packet-In                | Switch → Controller | Προώθηση πακέτου που δεν ταίριαζε σε κανόνα (table-miss).                                     |
| Packet-Out               | Controller → Switch | Εντολή αποστολής πακέτου από τον ελεγκτή.                                                     |
| Flow-Mod                 | Controller → Switch | Εγκατάσταση, τροποποίηση ή διαγραφή κανόνα ροής.                                              |
| Flow-Stats Request/Reply | Αμφίδρομο           | Αίτηση και επιστροφή στατιστικών ανά ροή.                                                     |
| Port-Stats Request/Reply | Αμφίδρομο           | Αίτηση και επιστροφή στατιστικών ανά θύρα (χρησιμοποιείται στην τηλεμετρία της διπλωματικής). |

*Πίνακας 2-1: Βασικοί τύποι μηνυμάτων OpenFlow.*

Στην παρούσα υλοποίηση, η περιοδική ανάκτηση στατιστικών θυρών αντιστοιχεί εννοιολογικά σε μια ακολουθία Port-Stats Request/Reply, ενώ η εγκατάσταση κανόνα απόρριψης αντιστοιχεί σε ένα μήνυμα Flow-Mod. Έτσι, παρά τη χρήση του `ons-ofctl` ως μηχανισμού μεταφοράς, η σημασιολογία παραμένει πλήρως OpenFlow-συμβατή.

### Η διοχέτευση επεξεργασίας του OpenFlow

Στις νεότερες εκδόσεις του OpenFlow, η επεξεργασία ενός πακέτου δεν περιορίζεται σε έναν μόνο πίνακα ροών αλλά διέρχεται από μια διοχέτευση (pipeline) πολλαπλών πινάκων. Κάθε πακέτο εισέρχεται στον πρώτο πίνακα, όπου αναζητείται η καταχώρηση με

την υψηλότερη προτεραιότητα που ταιριάζει. Η αντίστοιχη ενέργεια μπορεί είτε να ολοκληρώσει την επεξεργασία είτε να προωθήσει το πακέτο σε επόμενο πίνακα μέσω της εντολής Goto-Table. Κατά τη διαδρομή αυτή, το πακέτο συνοδεύεται από ένα σύνολο ενεργειών (action set) που συσσωρεύεται και εκτελείται στο τέλος. Η αρχιτεκτονική πολλαπλών πινάκων επιτρέπει τον διαχωρισμό της λογικής (π.χ. ένας πίνακας για ασφάλεια, ένας για δρομολόγηση) και τη συμπαγέστερη έκφραση σύνθετων πολιτικών.

Πέραν των απλών πινάκων ροών, το OpenFlow ορίζει και πίνακες ομάδων (group tables), οι οποίοι υποστηρίζουν προηγμένες λειτουργίες όπως πολλαπλή προώθηση (multicast), εξισορρόπηση φορτίου και ταχεία εναλλαγή διαδρομής σε περίπτωση αστοχίας (fast failover). Παρότι η υλοποίηση που περιγράφεται εστιάζει στη σημασιολογία match-action ενός πίνακα, η κατανόηση της πλήρους διοχέτευσης είναι σημαντική για την εκτίμηση των δυνατοτήτων και των περιορισμών ενός προγραμματιζόμενου επιπέδου δεδομένων.

Το Open vSwitch υλοποιεί πλήρως αυτή τη διοχέτευση, διατηρώντας παράλληλα μια δομή γρήγορης διαδρομής (fast path) στον πυρήνα για την αποδοτική προώθηση των ήδη εγκατεστημένων ροών, και μια αργή διαδρομή (slow path) στον χώρο χρήστη για τις νέες αποφάσεις. Αυτή η αρχιτεκτονική δύο επιπέδων εξηγεί γιατί οι επιθέσεις που παράγουν συνεχώς νέες ροές, και επομένως αναγκάζουν συνεχή χρήση της αργής διαδρομής, είναι ιδιαίτερα επιζήμιες.

### **Πεδία ταιριάσματος και δομή καταχώρησης ροής**

Η εκφραστικότητα του OpenFlow απορρέει από το πλούσιο σύνολο πεδίων ταιριάσματος που μπορεί να χρησιμοποιήσει μια καταχώρηση ροής. Τα πεδία αυτά καλύπτουν πολλαπλά επίπεδα της στοίβας πρωτοκόλλων: τη θύρα εισόδου του μεταγωγέα, τις διευθύνσεις MAC προέλευσης και προορισμού, τον τύπο Ethernet, τις διευθύνσεις IP, το πρωτόκολλο μεταφοράς και τις θύρες TCP ή UDP. Ο συνδυασμός αυτών των πεδίων επιτρέπει τον καθορισμό κανόνων με διαφορετική διαβάθμιση (granularity): από γενικούς κανόνες που ταιριάζουν σε ολόκληρα υποδίκτυα, μέχρι εξειδικευμένους κανόνες για μια συγκεκριμένη ροή. Στο προτεινόμενο σύστημα, ο κανόνας απόρριψης του επιτιθέμενου χρησιμοποιεί ταίριασμα στη διεύθυνση IP προέλευσης, επιτυγχάνοντας στοχευμένο αποκλεισμό χωρίς επίπτωση στη νόμιμη κίνηση.

Κάθε καταχώρηση ροής συνοδεύεται από προτεραιότητα, χρονόμετρα λήξης (idle και hard timeout) και μετρητές. Η προτεραιότητα καθορίζει ποιος κανόνας υπερισχύει όταν πολλοί ταιριάζουν. Γι' αυτό ο κανόνας απόρριψης εγκαθίσταται με υψηλή προτεραιότητα, ώστε να

υπερισχύει των κανόνων προώθησης. Τα χρονόμετρα λήξης επιτρέπουν την αυτόματη αφαίρεση κανόνων που δεν χρησιμοποιούνται, αποτρέποντας τη συσσώρευση άχρηστων καταχωρήσεων, μηχανισμός ιδιαίτερα σημαντικός στο πλαίσιο των επιθέσεων εξάντλησης του πίνακα ροών.

### Μηχανισμός συλλογής στατιστικών

Η δυνατότητα ανίχνευσης βάσει ροών στηρίζεται στους μετρητές που διατηρεί αυτόματα ο μεταγωγέας για κάθε καταχώρηση και για κάθε θύρα. Κάθε φορά που ένα πακέτο ταιριάζει σε έναν κανόνα, οι αντίστοιχοι μετρητές πακέτων και bytes αυξάνονται. Ο ελεγκτής μπορεί να ανακτήσει αυτά τα στατιστικά ανά πάσα στιγμή, χωρίς πρόσθετο κόστος στο επίπεδο δεδομένων. Στην υλοποίηση που παρουσιάζεται, η περιοδική ανάκτηση των στατιστικών θυρών κάθε πέντε δευτερόλεπτα παρέχει μια χρονοσειρά μετρήσεων, από την οποία, με απλή διαφόριση, προκύπτει η δραστηριότητα κάθε παραθύρου. Η προσέγγιση αυτή είναι ελαφριά, μη παρεμβατική και κλιμακώσιμη, καθιστώντας την ιδανική βάση για ανίχνευση σε πραγματικό χρόνο.

## 2.4 Ελεγκτές SDN: εσωτερική δομή, διαθεσιμότητα και ασφάλεια του καναλιού ελέγχου

Στη βιβλιογραφία και στην πράξη έχουν αναπτυχθεί πολλοί ελεγκτές SDN, με διαφορετικά χαρακτηριστικά ως προς τη γλώσσα υλοποίησης, την παραγωγικότητα και το πεδίο χρήσης. Οι πιο διαδεδομένοι είναι:

| Ελεγκτής     | Γλώσσα       | Χαρακτηριστικά / Χρήση                             |
|--------------|--------------|----------------------------------------------------|
| POX / NOX    | Python / C++ | Εκπαιδευτικοί, απλοί, ιδανικοί για prototyping.    |
| Ryu          | Python       | Ευρέως χρησιμοποιούμενος στην ακαδημαϊκή έρευνα.   |
| ONOS         | Java         | Παραγωγικός, καταναμημένος, υψηλής διαθεσιμότητας. |
| OpenDaylight | Java         | Modular, βιομηχανικό πρότυπο, μεγάλη κοινότητα.    |

*Πίνακας 2-2: Σύγκριση των κυριότερων ελεγκτών SDN.*

Στο πλαίσιο αυτό, η αρχική επιλογή ήταν ο Ryu, λόγω της ευρείας του χρήσης στην ακαδημαϊκή βιβλιογραφία και της υλοποίησής του σε Python. Ωστόσο, όπως αναλύεται στο Κεφάλαιο 5, τεχνικές ασυμβατότητες του Ryu με σύγχρονες εκδόσεις της Python οδήγησαν σε μια υβριδική αρχιτεκτονική ελέγχου, η οποία διατηρεί πλήρως τη

σημασιολογία του OpenFlow μέσω του Open vSwitch, χωρίς εξάρτηση από εξωτερικό framework.

### **Εσωτερική δομή και υψηλή διαθεσιμότητα του ελεγκτή**

Ένας σύγχρονος ελεγκτής SDN δεν είναι μονολιθικός. Αποτελείται από πολλαπλά υποσυστήματα, όπως η διαχείριση της τοπολογίας, η υπηρεσία δρομολόγησης, η διαχείριση συμβάντων και η διεπαφή προς τις εφαρμογές. Σε παραγωγικά περιβάλλοντα, όπου η διαθεσιμότητα είναι κρίσιμη, οι ελεγκτές αναπτύσσονται σε συστάδες (clusters) πολλαπλών κόμβων, με συγχρονισμό της κατάστασης μεταξύ τους. Έτσι, η αστοχία ενός κόμβου δεν συνεπάγεται κατάρρευση του δικτύου, καθώς ένας άλλος αναλαμβάνει αυτόματα. Η προσέγγιση αυτή αντιμετωπίζει εν μέρει τον περιορισμό του μοναδικού σημείου αποτυχίας, αλλά εισάγει με τη σειρά της προκλήσεις συνέπειας και συντονισμού.

Η κατανόηση αυτής της δομής είναι σημαντική για την τοποθέτηση της παρούσας μελέτης: το σύστημα ανίχνευσης λειτουργεί ως ένα υποσύστημα ασφαλείας στο επίπεδο εφαρμογών, το οποίο, σε μια κατανεμημένη ανάπτυξη, θα έπρεπε και το ίδιο να συντονίζει την κατάστασή του (τους ενεργούς κανόνες απόρριψης) μεταξύ των κόμβων της συστάδας. Η αρθρωτή σχεδίαση του συστήματος διευκολύνει μια τέτοια επέκταση, καθώς η κατάσταση ασφαλείας είναι σαφώς διαχωρισμένη από τη λογική της ανίχνευσης.

### **Ασφάλεια του καναλιού ελέγχου**

Το κανάλι ελέγχου μεταξύ ελεγκτή και μεταγωγέων αποτελεί το ίδιο έναν κρίσιμο στόχο. Το OpenFlow προβλέπει την προστασία του με TLS, ώστε να διασφαλίζεται η εμπιστευτικότητα και η ακεραιότητα των μηνυμάτων και να αποτρέπεται η πλαστοπροσωπία μεταγωγέα ή ελεγκτή. Στην πράξη, ωστόσο, η κρυπτογράφηση του καναλιού συχνά παραλείπεται σε πειραματικά περιβάλλοντα, αφήνοντας ανοιχτό ένα σημαντικό διάνυσμα επίθεσης. Η αυθεντικοποίηση με token που υιοθετεί η παρούσα υλοποίηση για την τηλεμετρία και τα διαχειριστικά endpoints κινείται στο ίδιο πνεύμα προστασίας του καναλιού επικοινωνίας, σε επίπεδο εφαρμογής.

## **2.5 Εργαλεία προσομοίωσης: Mininet και Open vSwitch**

Η πειραματική διάταξη στηρίζεται σε δύο θεμελιώδη εργαλεία του οικοσυστήματος SDN. Το Mininet, που παρουσιάστηκε από τους Lantz κ.ά. [3], επιτρέπει τη δημιουργία ρεαλιστικών εικονικών δικτύων, με hosts, μεταγωγείς και συνδέσεις, σε έναν μόνο υπολογιστή, αξιοποιώντας τους μηχανισμούς απομόνωσης του πυρήνα Linux. Έτσι, ένα

ολόκληρο δικτυακό σενάριο μπορεί να στηθεί, να εκτελεστεί και να καταστραφεί μέσα σε δευτερόλεπτα, γεγονός που το καθιστά ιδανικό για επαναλήψιμα πειράματα.

Το Open vSwitch (OVS), που περιγράφηκε από τους Pfaff κ.ά. [4], είναι ένας πλήρης εικονικός μεταγωγέας ανοιχτού κώδικα με πλήρη υποστήριξη OpenFlow. Το OVS χρησιμοποιείται τόσο σε πειραματικά όσο και σε παραγωγικά περιβάλλοντα νεφοϋπολογιστικής και αποτελεί το πρότυπο για την υλοποίηση προγραμματιζόμενων μεταγωγέων. Εδώ, η διεπαφή διαχείρισης `ovs-ofctl` χρησιμοποιείται για την ανάκτηση στατιστικών θυρών και την εγκατάσταση κανόνων ροής, λειτουργίες σημασιολογικά ταυτόσημες με τα αντίστοιχα μηνύματα OpenFlow.

## **2.6 Σύγκριση με τα παραδοσιακά δίκτυα: πλεονεκτήματα και προκλήσεις**

Ο διαχωρισμός του επιπέδου ελέγχου από το επίπεδο δεδομένων επιφέρει μια σειρά από ουσιαστικά λειτουργικά πλεονεκτήματα, τα οποία εξηγούν την ταχεία υιοθέτηση των SDN σε κέντρα δεδομένων και δίκτυα παρόχων. Πρώτον, η κεντρική διαχείριση επιτρέπει τον ενιαίο ορισμό πολιτικών: ο διαχειριστής περιγράφει την επιθυμητή συμπεριφορά μία φορά, και ο ελεγκτής την υλοποιεί συνεπώς σε όλες τις συσκευές, εξαλείφοντας τις αποκλίσεις διαμόρφωσης (*configuration drift*) που ταλανίζουν τα παραδοσιακά δίκτυα. Δεύτερον, η προγραμματισιμότητα μέσω της βόρειας διεπαφής επιτρέπει την αυτοματοποίηση και την ταχεία ανάπτυξη νέων υπηρεσιών χωρίς αναβάθμιση υλικού. Τρίτον, η καθολική εικόνα του δικτύου καθιστά δυνατή τη βελτιστοποίηση σε επίπεδο συστήματος, π.χ. καθολικό *traffic engineering*, αντί για τοπικές, μυωπικές αποφάσεις.

Οι ίδιες, όμως, ιδιότητες γεννούν και νέες προκλήσεις. Η κλιμακωσιμότητα του ελεγκτή αποτελεί ανοιχτό ζήτημα: ένας κεντρικός ελεγκτής πρέπει να εξυπηρετεί τα αιτήματα ολόκληρου του δικτύου, και ο ρυθμός με τον οποίο μπορεί να επεξεργάζεται μηνύματα *Packet-In* θέτει άνω όριο στη χωρητικότητα. Η αξιοπιστία (*dependability*) είναι εξίσου κρίσιμη, καθώς ένας μη πλεονασματικός ελεγκτής μπορεί να αποτελέσει μοναδικό σημείο αποτυχίας. Τέλος, η ασφάλεια, το αντικείμενο της παρούσας μελέτης, απαιτεί ιδιαίτερη προσοχή, ακριβώς επειδή η συγκέντρωση της λογικής συγκεντρώνει και το ρίσκο. Οι Benzekki κ.ά. [5] εντοπίζουν αυτές τις τρεις προκλήσεις ως τις κυριότερες που πρέπει να αντιμετωπίσει η ώριμη υιοθέτηση των SDN.

Είναι σημαντικό να διακρίνεται η λογική από τη φυσική κεντρικοποίηση. Η αρχιτεκτονική SDN κεντριοποιεί λογικά τη λήψη αποφάσεων, δηλαδή προσφέρει μια ενιαία, καθολική

όψη του δικτύου, χωρίς αυτό να συνεπάγεται αναγκαστικά έναν μοναδικό φυσικό ελεγκτή. Πλατφόρμες όπως το ONOS και το OpenDaylight υλοποιούν κατακεντρωμένα συμπλέγματα (clusters) ελεγκτών που μοιράζονται συγχρονισμένη κατάσταση, παρέχοντας πλεονασμό και οριζόντια κλιμάκωση διατηρώντας παράλληλα τη λογική ενοποίηση. Η παρούσα εργασία υλοποιεί, για λόγους εστίασης, έναν μοναδικό λογικό ελεγκτή, αλλά η ίδια λογική ανίχνευσης και αντιμετώπισης μεταφέρεται σε κατακεντρωμένη ανάπτυξη χωρίς αλλαγή αρχής.

## Σύγκριση παραδοσιακών δικτύων και SDN

| Πτυχή            | Παραδοσιακό δίκτυο           | SDN                         |
|------------------|------------------------------|-----------------------------|
| Έλεγχος          | Κατακεντρωμένος, ανά συσκευή | Λογικά κεντρικός            |
| Διαμόρφωση       | Χειροκίνητη, ανά συσκευή     | Προγραμματιζόμενη, κεντρική |
| Καινοτομία       | Αργή (κλειστό υλικό)         | Ταχεία (λογισμικό)          |
| Καθολική εικόνα  | Απουσία                      | Παρούσα στον ελεγκτή        |
| Σημείο αποτυχίας | Κατακεντρωμένο               | Ο ελεγκτής                  |

*Πίνακας 2-3: Συγκριτική επισκόπηση παραδοσιακών δικτύων και SDN.*

## 2.7 Σχέση με το NFV, τυποποίηση και οικοσύστημα

Στενά συνδεδεμένη με τα SDN είναι η έννοια της Δικτυακής Εικονικοποίησης Λειτουργιών (Network Functions Virtualization, NFV). Ενώ τα SDN αφορούν τον διαχωρισμό και την κεντροποίηση του ελέγχου, η NFV αφορά την υλοποίηση δικτυακών λειτουργιών, όπως τείχη προστασίας, εξισορροπητές φορτίου και συστήματα ανίχνευσης εισβολών, ως λογισμικού που εκτελείται σε τυποποιημένους διακομιστές, αντί για εξειδικευμένες συσκευές. Οι δύο τεχνολογίες είναι συμπληρωματικές: τα SDN παρέχουν την προγραμματιζόμενη διασύνδεση, ενώ η NFV παρέχει τις εικονικοποιημένες λειτουργίες που δρομολογούνται μέσω αυτής. Το προτεινόμενο σύστημα ανίχνευσης μπορεί να ιδωθεί ως μια τέτοια εικονικοποιημένη λειτουργία ασφαλείας, η οποία συνεργάζεται με το προγραμματιζόμενο επίπεδο δεδομένων για την επιβολή πολιτικών.

## Τυποποίηση και οικοσύστημα των SDN

Η ωρίμανση των SDN συνοδεύτηκε από την ανάπτυξη ενός ευρύτερου οικοσυστήματος προτύπων και φορέων. Η Open Networking Foundation ανέλαβε την τυποποίηση του OpenFlow, ενώ πλήθος έργων ανοιχτού κώδικα, από ελεγκτές όπως ο OpenDaylight και ο ONOS μέχρι πλατφόρμες εικονικοποίησης, συνέβαλαν στη διάδοση της τεχνολογίας. Η ύπαρξη ανοιχτών προτύπων είναι θεμελιώδης για την αποφυγή του εγκλωβισμού σε συγκεκριμένο προμηθευτή (vendor lock-in) και για την προώθηση της καινοτομίας. Η παρούσα υλοποίηση, στηριζόμενη εξ ολοκλήρου σε λογισμικό ανοιχτού κώδικα, Open vSwitch, Mininet, Python και το οικοσύστημα επιστημονικού υπολογισμού, εντάσσεται σε αυτή τη φιλοσοφία, διασφαλίζοντας την προσβασιμότητα και την αναπαραγωγικότητά της.

Παράλληλα με το OpenFlow, αναπτύχθηκαν και συμπληρωματικά πρότυπα, όπως τα διεπαφών βόρειας κατεύθυνσης και τα μοντέλα δεδομένων για τη διαμόρφωση. Η σύγκλιση των SDN με τη Δικτυακή Εικονικοποίηση Λειτουργιών οδήγησε σε ολοκληρωμένες αρχιτεκτονικές, όπου το προγραμματιζόμενο δίκτυο και οι εικονικοποιημένες λειτουργίες συνεργάζονται. Σε αυτό το τοπίο, η ασφάλεια αναδεικνύεται ως οριζόντια απαίτηση που διατρέχει όλα τα επίπεδα, από το προγραμματιζόμενο επίπεδο δεδομένων μέχρι τις εφαρμογές ασφαλείας του ανώτερου επιπέδου, όπου εντάσσεται και το προτεινόμενο σύστημα.

## **2.8 Περιπτώσεις χρήσης και υπηρεσίες του επιπέδου εφαρμογών**

Η ευελιξία των SDN έχει οδηγήσει σε ευρύ φάσμα πρακτικών εφαρμογών. Στα κέντρα δεδομένων, τα SDN επιτρέπουν την αυτόματη παροχή δικτυακών πόρων και τη δυναμική απομόνωση πολλαπλών ενοίκων (multi-tenancy). Στα δίκτυα ευρείας περιοχής των παρόχων (SD-WAN), επιτρέπουν την έξυπνη δρομολόγηση με βάση την ποιότητα των συνδέσμων και το κόστος. Στα δίκτυα κορμού, διευκολύνουν το traffic engineering σε κλίμακα. Σε όλες αυτές τις περιπτώσεις, ωστόσο, η κεντρικοποίηση του ελέγχου συνοδεύεται από την ανάγκη προστασίας του ελεγκτή, γεγονός που καθιστά την παρούσα μελέτη συναφή με ένα ευρύ φάσμα πραγματικών αναπτύξεων.

### **Το επίπεδο εφαρμογών και οι υπηρεσίες ασφαλείας**

Το επίπεδο εφαρμογών των SDN φιλοξενεί ένα ευρύ φάσμα υπηρεσιών που αξιοποιούν την κεντρική εικόνα και την προγραμματισιμότητα του δικτύου. Στον τομέα της ασφάλειας, τέτοιες υπηρεσίες περιλαμβάνουν δυναμικά τείχη προστασίας, συστήματα ανίχνευσης και πρόληψης εισβολών, μηχανισμούς απομόνωσης παραβιασμένων κόμβων και εφαρμογές επιβολής πολιτικών. Το βασικό πλεονέκτημα της υλοποίησης τέτοιων

λειτουργιών ως εφαρμογών SDN, αντί ως αυτόνομων συσκευών, είναι η στενή ολοκλήρωση με τον έλεγχο του δικτύου: μια εφαρμογή ασφαλείας δεν χρειάζεται απλώς να ανιχνεύει, αλλά μπορεί άμεσα να επιβάλλει την απόκρισή της, επαναπρογραμματίζοντας το δίκτυο. Το προτεινόμενο σύστημα αποτελεί ακριβώς μια τέτοια εφαρμογή, ενσωματώνοντας ανίχνευση και επιβολή σε έναν ενιαίο βρόχο.

### **3. Απειλές και Επιθέσεις σε Δίκτυα SDN**

Η αρχιτεκτονική SDN, παρά τα λειτουργικά της πλεονεκτήματα, εισάγει μια διευρυμένη και ποιοτικά διαφορετική επιφάνεια επίθεσης σε σύγκριση με τα παραδοσιακά δίκτυα. Στο κεφάλαιο αυτό αναλύονται συστηματικά οι απειλές ανά επίπεδο της αρχιτεκτονικής, με έμφαση στις επιθέσεις που στοχεύουν τον κεντρικό ελεγκτή, οι οποίες αποτελούν και το κύριο αντικείμενο του συστήματος άμυνας που αναπτύσσεται.

#### **3.1 Επιφάνεια επίθεσης ανά επίπεδο**

Η επισκόπηση ασφάλειας των Scott-Hayward κ.ά. [6] κατηγοριοποιεί τις απειλές SDN σύμφωνα με το επίπεδο που πλήττουν. Στο επίπεδο εφαρμογών, οι απειλές αφορούν κακόβουλες ή ευάλωτες εφαρμογές που, μέσω της βόρειας διεπαφής, μπορούν να επιβάλουν επικίνδυνες πολιτικές. Στο επίπεδο ελέγχου, ο ελεγκτής και το κανάλι ελέγχου αποτελούν στόχους επιθέσεων άρνησης εξυπηρέτησης, πλαστοπροσωπίας και μη εξουσιοδοτημένης πρόσβασης. Στο επίπεδο δεδομένων, οι μεταγωγείς είναι ευάλωτοι σε επιθέσεις πλαστογράφηση (spoofing) ροών, δηλητηρίασης τοπολογίας και εξάντλησης πόρων.

#### **3.2 Επιθέσεις άρνησης εξυπηρέτησης: μορφές, κύκλος ζωής και ταξινόμηση**

Η πιο κρίσιμη κατηγορία επιθέσεων σε SDN είναι οι επιθέσεις άρνησης εξυπηρέτησης (Denial of Service, DoS) και οι κατανεμημένες εκδοχές τους (Distributed DoS, DDoS) που στοχεύουν τον ελεγκτή. Επειδή ο ελεγκτής είναι υπεύθυνος για τη λήψη αποφάσεων σχετικά με κάθε νέα ροή, ένας επιτιθέμενος που κατακλύζει το δίκτυο με μεγάλο όγκο κίνησης, π.χ. μέσω SYN flood, μπορεί να εξαντλήσει τους υπολογιστικούς του πόρους. Καθώς καθεμία νέα, «άγνωστη» ροή προκαλεί μήνυμα Packet-In προς τον ελεγκτή, ο τελευταίος κατακλύζεται από αιτήματα και δεν προλαβαίνει να εξυπηρετήσει τη νόμιμη κίνηση.

##### **Κύκλος ζωής μιας επίθεσης DDoS σε SDN**

Για να γίνει κατανοητή η δυναμική μιας επίθεσης άρνησης εξυπηρέτησης σε περιβάλλον SDN, είναι χρήσιμο να αναλυθεί ο κύκλος ζωής της. Στην αρχική φάση, ο επιτιθέμενος, συχνά ελέγχοντας ένα δίκτυο παραβιασμένων συσκευών (botnet), αρχίζει να παράγει μεγάλο όγκο πακέτων προς το θύμα, τυπικά με πλαστές ή τυχαίες διευθύνσεις προέλευσης.

Στα SDN, καθεμία από αυτές τις φαινομενικά νέες ροές δεν ταιριάζει σε υπάρχοντα κανόνα, προκαλώντας μήνυμα Packet-In προς τον ελεγκτή.

Στη δεύτερη φάση, ο ρυθμός των Packet-In αυξάνεται εκθετικά. Ο ελεγκτής, με πεπερασμένη χωρητικότητα επεξεργασίας, αρχίζει να συσσωρεύει αιτήματα σε ουρά. Ο χρόνος απόκρισης για τη νόμιμη κίνηση αυξάνεται σημαντικά, καθώς τα νόμιμα αιτήματα περιμένουν πίσω από τα κακόβουλα. Ταυτόχρονα, ο πίνακας ροών (flow table) του μεταγωγέα αρχίζει να γεμίζει με εφήμερους κανόνες. Στην τρίτη, κρίσιμη φάση, ο ελεγκτής φτάνει σε πλήρη κορεσμό: δεν μπορεί πλέον να εξυπηρετήσει νόμιμα αιτήματα, και το δίκτυο, από τη σκοπιά του χρήστη, παύει ουσιαστικά να λειτουργεί, παρότι ο ίδιος ο σύνδεσμος δεδομένων μπορεί να μην είναι κορεσμένος.

Σε αυτόν τον κύκλο παρεμβαίνει το προτεινόμενο σύστημα. Ανιχνεύοντας την επίθεση ήδη από το πρώτο παράθυρο δειγματοληψίας, πριν δηλαδή ο ελεγκτής φτάσει στη φάση κορεσμού, και εγκαθιστώντας κανόνα απόρριψης στην πηγή, το σύστημα διακόπτει τον φαύλο κύκλο των Packet-In στην αφετηρία του. Η ταχύτητα της αντίδρασης, που τεκμηριώνεται στην ανάλυση καθυστέρησης, είναι επομένως όχι απλώς επιθυμητή αλλά καθοριστική για την αποτροπή της τρίτης φάσης.

### **Ταξινόμηση των επιθέσεων DDoS**

Οι επιθέσεις άρνησης εξυπηρέτησης δεν είναι ομοιογενείς. Διακρίνονται σε τρεις βασικές κατηγορίες ανάλογα με το επίπεδο που στοχεύουν [7]. Οι ογκομετρικές επιθέσεις (volumetric) επιδιώκουν να κορέσουν το εύρος ζώνης του συνδέσμου με τεράστιο όγκο κίνησης. Οι επιθέσεις πρωτοκόλλου (protocol attacks), όπως το SYN flood, εκμεταλλεύονται αδυναμίες στη λειτουργία των πρωτοκόλλων για να εξαντλήσουν πόρους κατάστασης, όπως τους πίνακες συνδέσεων. Οι επιθέσεις επιπέδου εφαρμογής (application layer) στοχεύουν συγκεκριμένες υπηρεσίες με φαινομενικά νόμιμα αιτήματα που όμως εξαντλούν τους πόρους του διακομιστή. Στα SDN, όλες αυτές οι κατηγορίες αποκτούν μια πρόσθετη διάσταση: πέραν του θύματος, πλήττουν και τον ίδιο τον ελεγκτή μέσω της καταιγίδας μηνυμάτων που προκαλούν.

Ιδιαίτερη αναφορά αξίζουν οι επιθέσεις ενίσχυσης (amplification), όπου ο επιτιθέμενος εκμεταλλεύεται υπηρεσίες που απαντούν με δυσανάλογα μεγάλο όγκο σε μικρά αιτήματα, πολλαπλασιάζοντας την ισχύ της επίθεσης ενώ ταυτόχρονα αποκρύπτει την ταυτότητά του μέσω πλαστογράφησης της διεύθυνσης προέλευσης. Η πλαστογράφηση αυτή είναι που καθιστά τις τυχαίες διευθύνσεις προέλευσης, και επομένως την επίθεση κορεσμού του

control plane, τόσο αποτελεσματικές, καθώς κάθε πλαστό πακέτο εμφανίζεται ως νέα, άγνωστη ροή.

### **Επιθέσεις χαμηλής έντασης και μακράς διάρκειας**

Πέρα από τις θορυβώδεις επιθέσεις όγκου, υπάρχει μια κατηγορία επιθέσεων που είναι εξ ορισμού δυσκολότερο να ανιχνευθούν: οι επιθέσεις χαμηλής έντασης και μακράς διάρκειας (low-and-slow). Αντί να κατακλύζουν το θύμα με τεράστιο όγκο, οι επιθέσεις αυτές διατηρούν έναν χαμηλό, διακριτικό ρυθμό, ώστε να παραμένουν κάτω από τα κατώφλι (threshold)α των παραδοσιακών ανιχνευτών, ενώ σταδιακά εξαντλούν τους πόρους κατάστασης του θύματος. Η ανάλυση αντίπαλης ανθεκτικότητας που παρουσιάζεται εξέτασε ακριβώς τέτοιες στρατηγικές (slow-rate, pulse), διαπιστώνοντας ότι το ζωντανό μοντέλο διατηρεί την ανθεκτικότητά του ακόμη και σε πολύ χαμηλές εντάσεις, χάρη στην εστίασή του σε συμπεριφορικά χαρακτηριστικά που δεν εξαρτώνται αποκλειστικά από τον όγκο. Το εύρημα αυτό είναι σημαντικό, καθώς οι επιθέσεις χαμηλής έντασης αποτελούν από τις δυσκολότερες προκλήσεις για κάθε σύστημα ανίχνευσης.

### **3.3 Κορεσμός του πίνακα ροών και του καναλιού ελέγχου**

Στενά συνδεδεμένη με τα παραπάνω είναι η επίθεση κορεσμού του πίνακα ροών (flow-table exhaustion). Ο πίνακας ροών ενός μεταγωγέα υλοποιείται συχνά σε ακριβή, περιορισμένης χωρητικότητας μνήμη TCAM, με τυπικό μέγεθος μερικών χιλιάδων καταχωρήσεων. Ένας επιτιθέμενος που παράγει τεχνητά μεγάλο πλήθος διακριτών ροών, για παράδειγμα, στέλνοντας πακέτα με τυχαίες διευθύνσεις προέλευσης, μπορεί να γεμίσει τον πίνακα, εμποδίζοντας την εγκατάσταση κανόνων για νόμιμες ροές. Ταυτόχρονα, κάθε τέτοια νέα ροή προκαλεί table-miss και επομένως Packet-In, υπερφορτώνοντας και το κανάλι ελέγχου. Πρόκειται για την πλέον SDN-specific επίθεση, η οποία δεν έχει αντίστοιχο στα παραδοσιακά δίκτυα και αναλύεται εκτενώς στο Κεφάλαιο 6.

### **3.4 Πλαστογράφιση, δηλητηρίαση τηλεμετρίας και επιθέσεις ενδιάμεσου**

Πέραν των επιθέσεων όγκου, υπάρχουν και πιο εκλεπτυσμένες απειλές που στοχεύουν στην ακεραιότητα της πληροφορίας βάσει της οποίας ο ελεγκτής λαμβάνει αποφάσεις. Η πλαστογράφιση κανόνων ροής (flow-rule injection) αφορά την εισαγωγή κακόβουλων ή παραπλανητικών κανόνων. Μια ιδιαιτέρως ενδιαφέρουσα παραλλαγή, που εξετάζεται πειραματικά στη συνέχεια, είναι η δηλητηρίαση τηλεμετρίας (telemetry poisoning): ο

επιτιθέμενος κατασκευάζει πλαστά στατιστικά ροών ώστε να «ενοχοποιήσει» έναν νόμιμο host, προκαλώντας τον ελεγκτή να τον μπλοκάρει και δημιουργώντας έτσι έμμεση άρνηση εξυπηρέτησης. Η επίθεση αυτή αναδεικνύει τη σημασία της αυθεντικοποίησης (authentication) της πηγής της τηλεμετρίας.

### **Πλαστογράφηση, υποκλοπή και επιθέσεις ενδιάμεσου**

Οι επιθέσεις που στοχεύουν την ακεραιότητα και την εμπιστευτικότητα, παρά την ασφάλεια όγκου, αποτελούν ιδιαίτερη κατηγορία απειλών. Το ARP spoofing εκμεταλλεύεται την απουσία αυθεντικοποίησης στο πρωτόκολλο ανάλυσης διευθύνσεων: ο επιτιθέμενος αποστέλλει πλαστές αντιστοιχίσεις διεύθυνσης IP σε MAC, πείθοντας τα θύματα ότι η δική του συσκευή είναι η πύλη ή ένας άλλος νόμιμος κόμβος. Έτσι, η κίνηση δρομολογείται μέσω του επιτιθέμενου, ο οποίος μπορεί να την υποκλέψει ή να την τροποποιήσει, μια κλασική επίθεση ενδιάμεσου ανθρώπου. Σε περιβάλλον SDN, τέτοιες επιθέσεις μπορούν επιπλέον να δηλητηριάσουν την εικόνα τοπολογίας του ελεγκτή, οδηγώντας σε εσφαλμένες αποφάσεις δρομολόγησης.

Η ανίχνευση τέτοιων επιθέσεων απαιτεί διαφορετική οπτική από αυτή των επιθέσεων όγκου, καθώς το αποτύπωμά τους δεν είναι πάντοτε στατιστικά έντονο. Στην πειραματική αξιολόγηση, η συγκεντρωτική στατιστική ανίχνευση δεν αναγνώρισε την ίδια την πλαστογράφηση ARP: ο αποκλεισμός του επιτιθέμενου προέκυψε από συνοδευτική ανώμαλη δραστηριότητα και όχι από την αναγνώριση της επίθεσης καθαυτής (βλ. ενότητα 6.8.6). Εντούτοις, η πλήρης αντιμετώπιση τέτοιων απειλών ενισχύεται σημαντικά από μηχανισμούς ακεραιότητας, όπως η αυθεντικοποίηση της τηλεμετρίας, υπογραμμίζοντας τη συμπληρωματικότητα στατιστικής ανίχνευσης και κλασικής ασφάλειας.

### **3.5 Σάρωση, πλευρική κίνηση και υποκλοπή**

Η σάρωση θυρών (port scanning) αποτελεί συνήθως το πρώτο στάδιο μιας επίθεσης, καθώς ο επιτιθέμενος χαρτογραφεί τις ενεργές υπηρεσίες πριν επιλέξει διάνυσμα εκμετάλλευσης. Χαρακτηρίζεται από πολλές, σύντομες ροές προς διαφορετικές θύρες ή διευθύνσεις. Η πλευρική κίνηση (lateral movement) περιγράφει τη μετακίνηση ενός ήδη παραβιασμένου host προς άλλους εσωτερικούς κόμβους, με στόχο την κλιμάκωση της παρείσφρησης. Τέλος, επιθέσεις όπως το ARP spoofing επιτρέπουν την υποκλοπή ή τροποποίηση κίνησης (Man-in-the-Middle) μέσω πλαστών αντιστοιχίσεων διεύθυνσης. Όλες αυτές οι κατηγορίες περιλαμβάνονται στα ζωντανά σενάρια αξιολόγησης του Κεφαλαίου 6.

### 3.6 Ο ελεγκτής ως μοναδικό σημείο αποτυχίας και οι εσωτερικές απειλές

Το κοινό νήμα που διατρέχει τις παραπάνω απειλές είναι ο κεντρικός ρόλος του ελεγκτή. Η λογική κεντριοποίηση, ενώ αποτελεί το βασικό πλεονέκτημα των SDN, μετατρέπει τον ελεγκτή σε μοναδικό σημείο αποτυχίας: η επιτυχής παρεμπόδιση ή παραπλάνησή του έχει καθολικές συνέπειες για το δίκτυο. Η διαπίστωση αυτή θεμελιώνει τόσο την ανάγκη για έγκαιρη, αυτοματοποιημένη ανίχνευση όσο και τη σχεδιαστική επιλογή ενός υβριδικού μοντέλου ελέγχου (Κεφάλαιο 5), στο οποίο η βασική συνδεσιμότητα διατηρείται ακόμη και υπό πίεση, ενώ ο ελεγκτής αφιερώνεται στη λειτουργία ασφαλείας.

#### Εσωτερικές απειλές και παραβίαση ελεγκτή

Πέραν των εξωτερικών επιτιθέμενων, τα SDN είναι ευάλωτα και σε εσωτερικές απειλές. Μια παραβιασμένη εφαρμογή στο επίπεδο εφαρμογών, με πρόσβαση στη βόρεια διεπαφή, μπορεί να επιβάλει κακόβουλες πολιτικές σε ολόκληρο το δίκτυο. Ακόμη σοβαρότερη είναι η πλήρης παραβίαση του ίδιου του ελεγκτή: δεδομένου του κεντρικού του ρόλου, ο έλεγχός του από επιτιθέμενο ισοδυναμεί με έλεγχο ολόκληρου του δικτύου. Οι απειλές αυτές τεκμηριώνουν την ανάγκη για αυστηρό έλεγχο πρόσβασης, αυθεντικοποίηση και αρχή του ελάχιστου προνομίου στην αρχιτεκτονική ασφάλειας ενός SDN. Στην παρούσα υλοποίηση, η προστασία των διαχειριστικών endpoints με token και η αυθεντικοποίηση του μεταγωγέα αποτελούν πρακτικά μέτρα προς αυτή την κατεύθυνση.

### 3.7 Ταξινόμηση των απειλών, υποδομή και αντίκτυπος των επιθέσεων

Πριν από την ταξινόμηση, οι εξεταζόμενες απειλές συνοψίζονται σε ένα τυπικό μοντέλο απειλών (threat model), το οποίο για κάθε κατηγορία επίθεσης προσδιορίζει ρητά την ικανότητα του επιτιθέμενου, το προστατευόμενο αγαθό (asset), το σημείο εισόδου, τη βασική παραδοχή και τον αντίκτυπο. Το μοντέλο αυτό οριοθετεί τι καλύπτει και τι δεν καλύπτει η προτεινόμενη άμυνα.

*Πίνακας 3-1: Τυπικό μοντέλο απειλών των εξεταζόμενων επιθέσεων.*

| Ικανότητα επιτιθέμενου                         | Αγαθό (asset)                     | Σημείο εισόδου                   | Παραδοχή                               | Αντίκτυπος                          |
|------------------------------------------------|-----------------------------------|----------------------------------|----------------------------------------|-------------------------------------|
| Εξωτερικός host υψηλού ρυθμού (DDoS/SYN flood) | Διαθεσιμότητα θύματος και ελεγκτή | Επίπεδο δεδομένων (νόμιμος host) | Δεν κατέχει διαπιστευτήρια διαχείρισης | Άρνηση εξυπηρέτησης, κορεσμός πόρων |
| Επιτιθέμενος που παράγει                       | Πίνακας ροών και                  | Επίπεδο δεδομένων                | Κάθε άγνωστη ροή                       | Κορεσμός ελεγκτή,                   |

|                                                             |                                       |                                |                                                                  |                                                      |
|-------------------------------------------------------------|---------------------------------------|--------------------------------|------------------------------------------------------------------|------------------------------------------------------|
| πλήθος άγνωστων ροών (table-miss flooding)                  | κανάλι ελέγχου                        |                                | προκαλεί Packet-In                                               | καθυστέρηση                                          |
| Κακόβουλος/παραβιασμένος host στο ίδιο LAN (ARP spoof/MITM) | Ακεραιότητα κίνησης θύματος           | Επίπεδο δεδομένων (L2)         | Καμία αυθεντικοποίηση IP προς MAC                                | Υποκλοπή/αλλοίωση, χωρίς έντονο στατιστικό αποτύπωμα |
| Επιτιθέμενος που πλαστογραφεί τηλεμετρία (flow-injection)   | Ακεραιότητα διαδικασίας απόφασης      | Southbound διεπαφή του ελεγκτή | Χωρίς αυθεντικοποίηση, ο ελεγκτής θα εμπιστευόταν την τηλεμετρία | Ενοχοποίηση νόμιμου host, εσφαλμένος αποκλεισμός     |
| Παραβιασμένη εφαρμογή (εσωτερική απειλή)                    | Πολιτική ελέγχου του δικτύου          | Northbound διεπαφή             | Η εφαρμογή έχει νόμιμη πρόσβαση στη βόρεια διεπαφή               | Καθολικός έλεγχος του δικτύου                        |
| Επιτιθέμενος αναγνώρισης (σάρωση/πλευρική κίνηση)           | Εμπιστευτικότητα τοπολογίας/υπηρεσιών | Επίπεδο δεδομένων              | Χαμηλού όγκου, διακριτική δραστηριότητα                          | Χαρτογράφηση δικτύου, προετοιμασία επόμενου σταδίου  |

Για μια συνολική εικόνα, οι απειλές που εξετάστηκαν μπορούν να ταξινομηθούν ανά στόχο, μηχανισμό και επίπτωση, όπως στον ακόλουθο πίνακα. Η ταξινόμηση αυτή καθοδηγεί τον σχεδιασμό της άμυνας: κάθε κατηγορία απαιτεί διαφορετικά διαγνωστικά χαρακτηριστικά.

| Επίθεση               | Στόχος       | Μηχανισμός             | Κύρια επίπτωση     |
|-----------------------|--------------|------------------------|--------------------|
| DDoS/SYN flood        | Ελεγκτής     | Πλημμύρα νέων ροών     | Κορεσμός ελεγκτή   |
| Flow-table exhaustion | Μεταγωγέας   | Τυχαίες IPs            | Γέμισμα TCAM       |
| Telemetry poisoning   | Ελεγκτής     | Πλαστά στατιστικά      | Μπλοκ νόμιμου host |
| Port scanning         | Δίκτυο       | Πολλές σύντομες ροές   | Αναγνώριση στόχων  |
| Lateral movement      | Εσωτ. κόμβοι | Εξάπλωση παρείσφρησης  | Κλιμάκωση          |
| ARP spoofing          | Hosts        | Πλαστές αντιστοιχίσεις | Υποκλοπή (MITM)    |

**Πίνακας 3-2: Ταξινόμηση των εξεταζόμενων επιθέσεων.**

Παρατηρείται ότι οι επιθέσεις όγκου (DDoS, flow-table exhaustion) αφήνουν εμφανές αποτύπωμα στα συγκεντρωτικά χαρακτηριστικά και ανιχνεύονται εύκολα, ενώ οι εκλεπτυσμένες επιθέσεις (telemetry poisoning) απαιτούν μηχανισμούς ακεραιότητας και αυθεντικοποίησης, πέραν της καθαρής στατιστικής ανίχνευσης. Η άμυνα που προτείνεται καλύπτει και τις δύο διαστάσεις.

## Οικονομικός και λειτουργικός αντίκτυπος

Πέρα από την τεχνική διάσταση, οι επιθέσεις σε SDN έχουν σημαντικό οικονομικό και λειτουργικό αντίκτυπο. Σε περιβάλλοντα κέντρων δεδομένων και παρόχων υπηρεσιών, η διακοπή λειτουργίας του δικτύου, έστω και για λίγα λεπτά, μπορεί να συνεπάγεται σημαντική απώλεια εσόδων, παραβίαση συμφωνιών επιπέδου υπηρεσίας (SLA) και βλάβη της φήμης. Η αυτοματοποίηση της άμυνας, ώστε να μη βασίζεται σε ανθρώπινη παρέμβαση που εισάγει καθυστέρηση λεπτών, είναι επομένως όχι μόνο τεχνικά αλλά και επιχειρησιακά αναγκαία. Το προτεινόμενο σύστημα, ανιχνεύοντας και αντιδρώντας εντός του πρώτου παραθύρου παρατήρησης, ευθυγραμμίζεται με αυτή την ανάγκη.

### **Υποδομή των επιθέσεων και το οικονομικό μοντέλο**

Η κατανόηση της υποδομής πίσω από τις σύγχρονες επιθέσεις φωτίζει και τα όρια της άμυνας. Οι μεγάλης κλίμακας επιθέσεις DDoS στηρίζονται σε δίκτυα παραβιασμένων συσκευών (botnets), τα οποία συχνά ενοικιάζονται ως υπηρεσία στη μαύρη αγορά. Το γεγονός αυτό μετατρέπει την επίθεση σε μια οικονομική συναλλαγή με κόστος και όφελος για τον επιτιθέμενο. Μια αποτελεσματική άμυνα δεν χρειάζεται απαραίτητα να είναι απόλυτη. Αρκεί να αυξήσει το κόστος της επιτυχούς επίθεσης πέρα από το αναμενόμενο όφελος. Υπό αυτό το πρίσμα, η ανάλυση αντίπαλης ανθεκτικότητας αποκτά πρόσθετη σημασία: δείχνοντας ότι η αποφυγή του ζωντανού μοντέλου απαιτεί είτε δραστική μείωση της ισχύος της επίθεσης είτε δαπανηρή υποδομή πολλαπλών πηγών, τεκμηριώνει ότι το σύστημα μετατοπίζει το οικονομικό ισοζύγιο εις βάρος του επιτιθέμενου.

### **Ο ρόλος του Διαδικτύου των Πραγμάτων**

Η εκρηκτική διάδοση των συσκευών του Διαδικτύου των Πραγμάτων έχει μεταβάλει ριζικά το τοπίο των επιθέσεων. Πολλές τέτοιες συσκευές διατίθενται με αδύναμες ή προεπιλεγμένες ρυθμίσεις ασφαλείας, καθιστώντας τες εύκολο στόχο παραβίασης. Παραβιασμένες, εντάσσονται σε τεράστια botnets ικανά να εξαπολύσουν επιθέσεις πρωτοφανούς κλίμακας, όπως κατέδειξαν διαβόητες επιθέσεις της τελευταίας δεκαετίας. Το γεγονός αυτό έχει άμεση σημασία για τα SDN: η κλίμακα των σύγχρονων επιθέσεων καθιστά την ανθρώπινη παρέμβαση ανεπαρκή και επιβάλλει αυτοματοποιημένη, ταχεία άμυνα, ακριβώς το είδος άμυνας που προτείνεται εδώ. Η ικανότητα του συστήματος να ανιχνεύει και να αντιμετωπίζει επιθέσεις σε χρόνο εντός του πρώτου παραθύρου παρατήρησης αποκτά ιδιαίτερη αξία σε ένα περιβάλλον όπου οι επιθέσεις μπορούν να κλιμακωθούν ακαριαία.

### **3.8 Μηχανισμοί άμυνας και ο ρόλος του IDS**

Οι μηχανισμοί άμυνας έναντι των επιθέσεων σε SDN μπορούν να ταξινομηθούν σε τρεις μεγάλες κατηγορίες. Οι προληπτικοί μηχανισμοί (prevention) στοχεύουν στην αποτροπή της επίθεσης εξ αρχής, για παράδειγμα, μέσω αυθεντικοποίησης, ελέγχου πρόσβασης και κρυπτογράφησης του καναλιού ελέγχου. Οι ανιχνευτικοί μηχανισμοί (detection), στους οποίους εντάσσεται και το προτεινόμενο σύστημα, στοχεύουν στον έγκαιρο εντοπισμό μιας επίθεσης σε εξέλιξη. Οι μηχανισμοί απόκρισης (response) στοχεύουν στον περιορισμό της ζημιάς μετά την ανίχνευση, για παράδειγμα, μέσω απόρριψης κίνησης, rate limiting ή απομόνωσης του επιτιθέμενου. Η προσέγγιση που υιοθετείται συνδυάζει ανίχνευση και απόκριση σε έναν ενιαίο, αυτοματοποιημένο βρόχο, ενώ ενσωματώνει και προληπτικά στοιχεία (αυθεντικοποίηση τηλεμετρίας, rate limiting).

#### **Ο ρόλος του IDS στην αρχιτεκτονική ασφάλειας**

Ένα σύστημα ανίχνευσης εισβολών δεν λειτουργεί απομονωμένα αλλά ως μέρος μιας ευρύτερης αρχιτεκτονικής ασφάλειας βάθους (defense in depth). Στα SDN, το IDS αποκτά ένα μοναδικό πλεονέκτημα: χάρη στην κεντριοποιημένη εικόνα του δικτύου και στην προγραμματισιμότητα, μπορεί όχι μόνο να ανιχνεύει αλλά και να επιβάλλει άμεσα την απόκρισή του, χωρίς την ανάγκη εξωτερικού μηχανισμού. Αυτή η στενή σύζευξη ανίχνευσης και επιβολής, που στα παραδοσιακά δίκτυα απαιτεί ξεχωριστές συσκευές και χειροκίνητη διαμόρφωση, αποτελεί ένα από τα σημαντικότερα δομικά πλεονεκτήματα της προσέγγισης SDN για την ασφάλεια.

## 4. Μέθοδοι Ανίχνευσης και Μηχανική Μάθηση

### 4.1 Παραδοσιακές μέθοδοι και οι αδυναμίες τους

Τα κλασικά συστήματα ανίχνευσης εισβολών διακρίνονται σε δύο μεγάλες κατηγορίες. Τα συστήματα βάσει υπογραφών (signature-based), όπως τα Snort και Suricata [8], συγκρίνουν την κίνηση με μια βάση γνωστών προτύπων επίθεσης. Η προσέγγιση αυτή είναι ακριβής για γνωστές επιθέσεις αλλά αδυνατεί εξ ορισμού να ανιχνεύσει άγνωστες (zero-day) απειλές και απαιτεί συνεχή, χειροκίνητη ενημέρωση των υπογραφών. Τα συστήματα βάσει κατωφλίων (threshold-based) ενεργοποιούν συναγερμό όταν μια μετρική (π.χ. ρυθμός πακέτων) ξεπεράσει ένα προκαθορισμένο όριο. Είναι απλά αλλά επιρρεπή σε ψευδώς θετικά και εύκολα παρακάμψιμα από επιθέσεις χαμηλής έντασης.

### 4.2 Ανίχνευση βασισμένη σε Μηχανική Μάθηση: επισκόπηση και μηχανισμοί των αλγορίθμων

Η Μηχανική Μάθηση προσφέρει μια δυναμική εναλλακτική: αντί για στατικούς κανόνες, τα μοντέλα μαθαίνουν τα στατιστικά πρότυπα της νόμιμης και της κακόβουλης κίνησης από δεδομένα και γενικεύουν σε νέες παραλλαγές. Η επισκόπηση των Sultana κ.ά. [9] τεκμηριώνει την αυξανόμενη υιοθέτηση ML-based IDS σε περιβάλλοντα SDN, επειδή τα στατιστικά ροών που παρέχει το OpenFlow αποτελούν φυσική είσοδο για τέτοια μοντέλα. Στην παρούσα μελέτη αξιοποιούνται δύο συμπληρωματικά παραδείγματα: η επιβλεπόμενη ταξινόμηση (supervised classification), όπου το μοντέλο εκπαιδεύεται σε δεδομένα με ετικέτες, και η μη επιβλεπόμενη ανίχνευση ανωμαλιών (unsupervised anomaly detection), όπου το μοντέλο μαθαίνει μόνο τη «φυσιολογική» κατάσταση και εντοπίζει αποκλίσεις.

#### Επισκόπηση αλγορίθμων

Στη συγκριτική μελέτη του Κεφαλαίου 6 αξιολογούνται οι ακόλουθοι αλγόριθμοι:

- **Random Forest:** σύνολο (ensemble) δέντρων απόφασης με ψηφοφορία. Είναι ισχυρός, ανθεκτικός στον θόρυβο και ιδιαίτερα αποδοτικός σε δομημένα δεδομένα ροών.
- **Decision Tree:** ενιαίο δέντρο κανόνων, ερμηνεύσιμο αλλά επιρρεπές σε υπερπροσαρμογή (overfitting).
- **K-Nearest Neighbors (KNN):** ταξινόμηση βάσει εγγύτητας στον χώρο των χαρακτηριστικών.

- **Support Vector Machine (SVM):** εύρεση βέλτιστου διαχωριστικού υπερεπιπέδου με πυρήνα RBF.
- **Logistic Regression:** γραμμικός ταξινομητής, χρήσιμος ως βάση αναφοράς (baseline).
- **Multi-Layer Perceptron (MLP):** νευρωνικό δίκτυο πρόσθιας τροφοδότησης με κρυφά επίπεδα.
- **Deep MLP και 1D-CNN:** βαθύτερες αρχιτεκτονικές που εξετάζονται ως προς την απόδοσή τους σε δομημένα (tabular) δεδομένα.

### Μηχανισμοί λειτουργίας των αλγορίθμων

Για την πληρότητα της ανάλυσης, παρατίθεται συνοπτικά ο μηχανισμός λειτουργίας καθενός από τους αλγορίθμους που συγκρίνονται. Το Random Forest κατασκευάζει πλήθος δέντρων απόφασης, καθένα εκπαιδευμένο σε τυχαίο υποσύνολο δειγμάτων και χαρακτηριστικών (bagging και τυχαία επιλογή χαρακτηριστικών). Η τελική πρόβλεψη προκύπτει από ψηφοφορία των δέντρων. Η στοχαστικότητα αυτή μειώνει τη διακύμανση και καθιστά το μοντέλο ανθεκτικό στον θόρυβο και στην υπερπροσαρμογή, εξηγώντας την κορυφαία του επίδοση στα δομημένα δεδομένα ροών.

Το Decision Tree, αντίθετα, είναι ένα ενιαίο δέντρο κανόνων. Είναι άκρως ερμηνεύσιμο αλλά επιρρεπές σε υπερπροσαρμογή, ιδίως σε βαθιά δέντρα. Ο K-Nearest Neighbors ταξινομεί κάθε νέο δείγμα βάσει της πλειοψηφίας των k πλησιέστερων γειτόνων του στον χώρο χαρακτηριστικών. Είναι απλός αλλά υπολογιστικά δαπανηρός κατά την πρόβλεψη, καθώς απαιτεί σύγκριση με όλο το σύνολο εκπαίδευσης (training set). Το Support Vector Machine με πυρήνα RBF αναζητά το υπερεπίπεδο που μεγιστοποιεί το περιθώριο μεταξύ των κλάσεων σε έναν χώρο υψηλότερης διάστασης, προσφέροντας ισχυρή γενίκευση αλλά με μεγαλύτερο κόστος εκπαίδευσης.

Η Logistic Regression είναι ένας γραμμικός ταξινομητής που μοντελοποιεί την πιθανότητα κάθε κλάσης. Χρησιμεύει ως βάση αναφοράς και αναδεικνύει, μέσω της υποαπόδοσής της στο InSDN, την ανάγκη για μη γραμμικά μοντέλα σε πραγματικά δεδομένα. Το Multi-Layer Perceptron είναι νευρωνικό δίκτυο πρόσθιας τροφοδότησης με κρυφά επίπεδα και μη γραμμικές συναρτήσεις ενεργοποίησης, ικανό να μοντελοποιεί σύνθετες σχέσεις αλλά με μεγαλύτερη ευαισθησία στην επιλογή υπερπαραμέτρων (hyperparameters). Τέλος, τα μοντέλα Βαθιάς Μάθησης (Deep MLP και 1D-CNN) εξετάζονται για να διαπιστωθεί κατά πόσον η μεγαλύτερη χωρητικότητά τους αποδίδει σε δομημένα δεδομένα, συμπέρασμα

που, όπως δείχνει το Κεφάλαιο 6, είναι αρνητικό, καθώς η απουσία χωρικής ή χρονικής δομής δεν αξιοποιεί τα πλεονεκτήματά τους.

### **Η θεωρία των μεθόδων συνόλου**

Η επιτυχία των μεθόδων συνόλου, όπως το Random Forest, δεν είναι τυχαία αλλά θεμελιώνεται θεωρητικά. Η βασική ιδέα είναι ότι ο συνδυασμός πολλαπλών «αδύναμων» ή μέτριας ισχύος ταξινομητών, εφόσον αυτοί κάνουν ανεξάρτητα λάθη, μπορεί να παραγάγει έναν «ισχυρό» ταξινομητή με σημαντικά μειωμένο συνολικό σφάλμα. Στο Random Forest, η ανεξαρτησία των δέντρων ενισχύεται με δύο μηχανισμούς τυχειότητας: την εκπαίδευση κάθε δέντρου σε διαφορετικό, τυχαία επιλεγμένο υποσύνολο δειγμάτων (bootstrap) και την εξέταση τυχαίου υποσυνόλου χαρακτηριστικών σε κάθε διαχωρισμό. Έτσι, τα δέντρα αποσυσχετίζονται, και ο μέσος όρος των προβλέψεών τους μειώνει τη διακύμανση χωρίς να αυξάνει τη μεροληψία.

Η ίδια αρχή εξηγεί γιατί το Random Forest είναι ανθεκτικό στον θόρυβο και στην υπερπροσαρμογή, χαρακτηριστικά που το καθιστούν ιδανικό για θορυβώδη δεδομένα ασφάλειας. Ταυτόχρονα, όμως, η ίδια αρχή φωτίζει και την ευπάθειά του σε αντίπαλες επιθέσεις: αν όλα τα δέντρα βασίζονται στα ίδια, περιορισμένα διαγνωστικά χαρακτηριστικά, τότε μια συντονισμένη διαταραχή αυτών των χαρακτηριστικών μπορεί να παραπλανήσει ολόκληρο το σύνολο ταυτόχρονα, ακριβώς το φαινόμενο του γκρεμού που παρατηρήθηκε πειραματικά.

### **4.3 Ο αλγόριθμος Isolation Forest και η μαθηματική του θεμελίωση**

Ιδιαίτερη θέση κατέχει ο αλγόριθμος Isolation Forest [10], ο οποίος αποτελεί τη μηχανή ανίχνευσης (detection engine) του ζωντανού συστήματος. Σε αντίθεση με τους περισσότερους αλγορίθμους ανίχνευσης ανωμαλιών που μοντελοποιούν πρώτα τη φυσιολογική κατάσταση, ο Isolation Forest εκμεταλλεύεται την ίδια την ιδιότητα των ανωμαλιών: είναι λίγες και διαφορετικές, άρα «απομονώνονται» ευκολότερα. Κατασκευάζοντας τυχαία δέντρα διαχωρισμού, οι ανώμαλες παρατηρήσεις απαιτούν κατά μέσο όρο λιγότερους διαχωρισμούς για να απομονωθούν, δηλαδή έχουν μικρότερο μέσο βάθος. Το βασικό πλεονέκτημα του αλγορίθμου είναι η γραμμική υπολογιστική πολυπλοκότητα και η καταλληλότητά του για ανίχνευση χωρίς ετικέτες, ιδανική για ένα ζωντανό σύστημα που πρέπει να αποφασίζει σε πραγματικό χρόνο.

## Μαθηματική θεμελίωση του Isolation Forest

Ο Isolation Forest κατασκευάζει ένα σύνολο από isolation trees, καθένα από τα οποία διαχωρίζει επαναληπτικά τα δεδομένα επιλέγοντας τυχαία ένα χαρακτηριστικό και ένα τυχαίο σημείο διαχωρισμού μεταξύ της ελάχιστης και της μέγιστης τιμής του. Το πλήθος των διαχωρισμών που απαιτούνται για την απομόνωση μιας παρατήρησης ισοδυναμεί με το μήκος διαδρομής από τη ρίζα έως το φύλλο. Καθώς οι ανωμαλίες είναι λίγες και διακριτές, απομονώνονται με λιγότερους διαχωρισμούς και έχουν μικρότερο μέσο μήκος διαδρομής. Η τιμή ανωμαλίας (anomaly score) ορίζεται ως  $s(x, n) = 2^{-\frac{E(h(x))}{c(n)}}$ , όπου  $E(h(x))$  το μέσο μήκος διαδρομής της παρατήρησης  $x$  στα δέντρα και  $c(n)$  η μέση τιμή αναφοράς για  $n$  δείγματα. Τιμές κοντά στη μονάδα υποδεικνύουν ανωμαλία, ενώ τιμές αρκετά κάτω του 0,5 υποδεικνύουν φυσιολογικές παρατηρήσεις. Το βασικό πλεονέκτημα είναι η γραμμική πολυπλοκότητα ως προς το πλήθος των δειγμάτων και η ανεξαρτησία από ετικέτες, χαρακτηριστικά ιδανικά για ανίχνευση σε πραγματικό χρόνο.

## 4.4 Δημόσια σύνολα δεδομένων και κατηγορίες κίνησης

Η αξιολόγηση μοντέλων ML για ασφάλεια δικτύων απαιτεί αντιπροσωπευτικά σύνολα δεδομένων. Ιστορικά χρησιμοποιήθηκαν τα NSL-KDD και CICDDoS2019, τα οποία όμως δεν είναι ειδικά για SDN. Το σύνολο InSDN [11] σχεδιάστηκε ειδικά για περιβάλλοντα SDN και περιλαμβάνει τόσο νόμιμη κίνηση όσο και ευρύ φάσμα επιθέσεων (DoS, DDoS, probe, brute-force, web attacks), με χαρακτηριστικά εξαγόμενα από το εργαλείο CICFlowMeter. Υιοθετείται η δομή χαρακτηριστικών του InSDN/CICFlowMeter, ώστε το offline pipeline να είναι απευθείας συμβατό με το πραγματικό σύνολο.

### Οι κατηγορίες κίνησης του συνόλου δεδομένων

Το σύνολο δεδομένων οργανώνεται σε πέντε κατηγορίες, καθεμία με διακριτό στατιστικό αποτύπωμα. Η κανονική κίνηση (Normal) αντιπροσωπεύει τη νόμιμη δραστηριότητα και χαρακτηρίζεται από μέτριους ρυθμούς πακέτων, ομαλούς χρόνους μεταξύ αφίξεων και ισορροπημένη κατανομή σημαιών TCP. Η κατηγορία DDoS αντιστοιχεί σε κατανεμημένες επιθέσεις πλημμύρας, με πολύ υψηλό ρυθμό πακέτων και σχεδόν μηδενική διακύμανση στους χρόνους άφιξης, ένδειξη μηχανικής, αυτοματοποιημένης προέλευσης. Η κατηγορία DoS μοιάζει με την DDoS αλλά προέρχεται από μεμονωμένη πηγή, γεγονός που εξηγεί τη στατιστική τους ομοιότητα και τη συγκέντρωση των λαθών ταξινόμησης μεταξύ τους.

Η κατηγορία Probe (σάρωση) χαρακτηρίζεται από πλήθος σύντομων ροών προς διαφορετικούς προορισμούς ή θύρες, με χαμηλό όγκο ανά ροή αλλά υψηλή διασπορά. Τέλος, η κατηγορία BFA (Brute-Force Attack) αντιστοιχεί σε επαναλαμβανόμενες απόπειρες πρόσβασης, με χαρακτηριστικά μοτίβα μικρών, επαναλαμβανόμενων αιτημάτων. Η κατανόηση αυτών των αποτυπωμάτων φωτίζει τα ευρήματα της ανάλυσης SHAP: κάθε κατηγορία «ανιχνεύεται» κυρίως μέσω των χαρακτηριστικών που αποτυπώνουν την ιδιαίτερη φύση της.

#### 4.5 Χαρακτηριστικά ροής: εξαγωγή, περιγραφή και επιλογή

Το CICFlowMeter μετατρέπει την ακατέργαστη κίνηση (πακέτα) σε διανύσματα χαρακτηριστικών ανά ροή. Κάθε ροή περιγράφεται από 24 χαρακτηριστικά, όπως η διάρκεια, ο αριθμός και το μέγεθος των πακέτων ανά κατεύθυνση, ο ρυθμός πακέτων και bytes ανά δευτερόλεπτο, οι χρόνοι μεταξύ διαδοχικών αφίξεων (inter-arrival times) και το πλήθος των σημαιών TCP (SYN, ACK, RST, FIN). Η επιλογή χαρακτηριστικών βάσει ροών, αντί βάσει πακέτων, είναι κρίσιμη: αποφεύγει τη βαθιά επιθεώρηση πακέτων, σέβεται την ιδιωτικότητα του περιεχομένου και είναι εγγενώς αποδοτική, καθώς τα στατιστικά αυτά παράγονται ούτως ή άλλως από τον μεταγωγέα. Όπως θα φανεί στην ανάλυση SHAP του Κεφαλαίου 6, η τυπική απόκλιση (standard deviation) των χρόνων μεταξύ αφίξεων και ο ρυθμός πακέτων αναδεικνύονται στα πλέον διαγνωστικά χαρακτηριστικά για τις επιθέσεις πλημμύρας.

##### Τα 24 χαρακτηριστικά ροής

Ο ακόλουθος πίνακας παραθέτει το πλήρες σύνολο των 24 χαρακτηριστικών που εξάγονται ανά ροή, μαζί με τη δικτυακή τους ερμηνεία. Η ποσοτική συνεισφορά κάθε χαρακτηριστικού στην ανίχνευση, όπως προκύπτει από την ανάλυση SHAP, παρουσιάζεται και σχολιάζεται στο Κεφάλαιο 6 (ενότητα 6.3), ώστε τα αποτελέσματα να παραμένουν συγκεντρωμένα στο κεφάλαιο των πειραμάτων.

| Χαρακτηριστικό (CICFlowMeter) | Δικτυακή ερμηνεία      |
|-------------------------------|------------------------|
| Flow_IAT_Std                  | Τυπ. Απόκλιση IAT      |
| Flow_Pkts_s                   | Πακέτα/s               |
| Fwd_IAT_Mean                  | IAT Εμπρός             |
| Pkt_Len_Mean                  | Μέσο Μήκος Πακέτου     |
| Idle_Mean                     | Μέσος Χρόνος Αδράνειας |

|                   |                      |
|-------------------|----------------------|
| Bwd_IAT_Mean      | IAT Πίσω             |
| Pkt_Size_Avg      | Μέσο Μέγεθος Πακέτου |
| Flow_IAT_Mean     | Μέσο IAT             |
| Pkt_Len_Std       | Τυπ. Απόκλιση Μήκους |
| Init_Fwd_Win_Byts | Παράθυρο TCP Εμπρός  |
| Active_Mean       | Μέσος Χρόνος Ενεργός |
| TotLen_Bwd_Pkts   | Bytes Πίσω           |
| SYN_Flag_Cnt      | SYN Flags            |
| ACK_Flag_Cnt      | ACK Flags            |
| RST_Flag_Cnt      | RST Flags            |
| TotLen_Fwd_Pkts   | Bytes Εμπρός         |
| Fwd_Pkt_Len_Mean  | Μέσο Μήκος Εμπρός    |
| Down_Up_Ratio     | Λόγος Down/Up        |
| Tot_Bwd_Pkts      | Πακέτα Πίσω          |
| Bwd_Pkt_Len_Mean  | Μέσο Μήκος Πίσω      |
| FIN_Flag_Cnt      | FIN Flags            |
| Tot_Fwd_Pkts      | Πακέτα Εμπρός        |
| Flow_Duration     | Διάρκεια Ροής        |
| Flow_Byts_s       | Bytes/s              |

**Πίνακας 4-1: Τα 24 χαρακτηριστικά ροής της δομής CICFlowMeter/InSDN.**

### **Επιλογή χαρακτηριστικών και μείωση διάστασης**

Η επιλογή του κατάλληλου συνόλου χαρακτηριστικών είναι εξίσου σημαντική με την επιλογή του αλγορίθμου. Ένα υπερβολικά μεγάλο σύνολο χαρακτηριστικών αυξάνει το υπολογιστικό κόστος και τον κίνδυνο υπερπροσαρμογής, ενώ ένα υπερβολικά μικρό μπορεί να στερεί από το μοντέλο κρίσιμη πληροφορία. Η ανάλυση σημαντικότητας, τόσο μέσω των εγγενών μετρικών των δέντρων όσο και μέσω της ερμηνεύσιμης προσέγγισης SHAP, επιτρέπει τον εντοπισμό των πλέον διαγνωστικών χαρακτηριστικών και, κατ' επέκταση, τη δυνατότητα μείωσης της διάστασης χωρίς σημαντική απώλεια απόδοσης. Στο ζωντανό σύστημα, η επιλογή ενός μικρού συνόλου συγκεντρωτικών, συμπεριφορικών χαρακτηριστικών όχι μόνο μειώνει το υπολογιστικό κόστος αλλά, όπως τεκμηριώθηκε, ενισχύει και την ανθεκτικότητα έναντι αντίπαλων επιθέσεων.

## 4.6 Μετρικές αξιολόγησης και καμπύλες ROC

Η αξιολόγηση των ταξινομητών βασίζεται σε τέσσερις θεμελιώδεις μετρικές, οι οποίες προκύπτουν από τον πίνακα σύγχυσης. Η ακρίβεια (accuracy) εκφράζει το ποσοστό των ορθών προβλέψεων επί του συνόλου. Η ορθότητα (precision) εκφράζει το ποσοστό των πραγματικά θετικών μεταξύ όσων χαρακτηρίστηκαν θετικά, και είναι κρίσιμη για τον περιορισμό των ψευδώς θετικών, δηλαδή για την αποφυγή του μπλοκαρίσματος νόμιμης κίνησης. Η ανάκληση (recall) εκφράζει το ποσοστό των πραγματικά θετικών που εντοπίστηκαν, και είναι κρίσιμη για να μη διαφύγει επίθεση. Το F1-score, ως αρμονικός μέσος ορθότητας και ανάκλησης, ισορροπεί τους δύο αυτούς στόχους και αποτελεί την κύρια συγκριτική μετρική που υιοθετείται. Τέλος, η καμπύλη ROC και το εμβαδόν κάτω από αυτήν (AUC) αποτυπώνουν την ικανότητα διάκρισης του μοντέλου ανεξαρτήτως συγκεκριμένου κατωφλίου.

Στο πλαίσιο ενός συστήματος άμυνας δικτύου, η ισορροπία ορθότητας-ανάκλησης έχει άμεση επιχειρησιακή σημασία. Ένα σύστημα με χαμηλή ορθότητα παράγει πολλά ψευδώς θετικά και, μπλοκάροντας νόμιμους χρήστες, προκαλεί ουσιαστικά το ίδιο αποτέλεσμα με μια επίθεση άρνησης εξυπηρέτησης. Αντίστροφα, χαμηλή ανάκληση σημαίνει διαφυγή επιθέσεων. Γι' αυτό δίνεται έμφαση όχι μόνο στην ακρίβεια αλλά και στον περιορισμό των ψευδώς θετικών, με ιδιαίτερη αναφορά στο σενάριο αποκλειστικά νόμιμης κίνησης, όπου δεν καταγράφηκαν ψευδώς θετικά.

### Μετρικές αξιολόγησης: τυπικός ορισμός

Οι μετρικές που χρησιμοποιήθηκαν ορίζονται αυστηρά μέσω των τεσσάρων μεγεθών του πίνακα σύγχυσης: των αληθώς θετικών (TP), των αληθώς αρνητικών (TN), των ψευδώς θετικών (FP) και των ψευδώς αρνητικών (FN). Η ακρίβεια ορίζεται ως  $\frac{TP+TN}{TP+TN+FP+FN}$ ,

δηλαδή το ποσοστό των ορθών αποφάσεων. Η ορθότητα (precision) ορίζεται ως

$\frac{TP}{TP+FP}$ , εκφράζοντας την αξιοπιστία των θετικών προβλέψεων. Η ανάκληση (recall)

ορίζεται ως  $\frac{TP}{TP+FN}$ , εκφράζοντας την κάλυψη των πραγματικών θετικών. Το F1-score

ορίζεται ως ο αρμονικός μέσος  $2 * \frac{precision * recall}{precision+recall}$ , ισορροπώντας τους δύο στόχους. Ο

αρμονικός μέσος επιλέγεται αντί του αριθμητικού διότι τιμωρεί δυσανάλογα τις ακραίες ανισορροπίες: ένα μοντέλο με υψηλή ορθότητα αλλά χαμηλή ανάκληση (ή αντίστροφα) λαμβάνει χαμηλό F1.

Ένα αριθμητικό παράδειγμα αποσαφηνίζει τη σημασία τους. Έστω ένα σύστημα που, σε 1.000 ροές εκ των οποίων 100 είναι επιθέσεις, εντοπίζει σωστά τις 95 (TP=95, FN=5) αλλά χαρακτηρίζει και 10 νόμιμες ως επιθέσεις (FP=10). Τότε η ορθότητα είναι  $95/105 \approx 0,905$ , η ανάκληση  $95/100 = 0,95$  και το  $F1 \approx 0,927$ . Στο πλαίσιο ενός συστήματος άμυνας, τα δέκα ψευδώς θετικά αντιστοιχούν σε δέκα νόμιμους χρήστες που θα μπλοκάρονταν άδικα. Το παράδειγμα καθιστά σαφές γιατί η ορθότητα, και όχι μόνο η ακρίβεια, αποτελεί καθοριστικό κριτήριο για ένα σύστημα που λαμβάνει αυτόματα μέτρα αποκλεισμού.

### **Καμπύλες ROC και precision-recall**

Η αξιολόγηση ενός ταξινομητή δεν εξαντλείται σε μια μεμονωμένη τιμή μετρικής, καθώς αυτή εξαρτάται από το επιλεγμένο κατώφλι απόφασης. Οι καμπύλες ROC αποτυπώνουν τη σχέση μεταξύ του ποσοστού αληθώς θετικών και του ποσοστού ψευδώς θετικών σε όλο το φάσμα κατωφλίων, και το εμβαδόν κάτω από αυτές (AUC) συνοψίζει τη συνολική διακριτική ικανότητα. Σε σύνολα με έντονη ανισορροπία, ωστόσο, οι καμπύλες precision-recall μπορεί να είναι πιο ενημερωτικές, καθώς εστιάζουν στην απόδοση επί της μειοψηφικής κλάσης, που στα δεδομένα ασφάλειας είναι συνήθως οι επιθέσεις. Η χρήση πολλαπλών, συμπληρωματικών εργαλείων αξιολόγησης διασφαλίζει μια σφαιρική και μη παραπλανητική εικόνα της απόδοσης, αποφεύγοντας τα συμπεράσματα που θα προέκυπταν από μια μονοδιάστατη θεώρηση.

## **4.7 Σχετική βιβλιογραφία και αρχιτεκτονικές συστημάτων ανίχνευσης**

Η ανίχνευση εισβολών σε SDN με Μηχανική Μάθηση αποτελεί ενεργό ερευνητικό πεδίο. Οι Braga κ.ά. [1] πρότειναν έναν ελαφρύ ανιχνευτή DDoS βασισμένο σε αυτο-οργανούμενους χάρτες (SOM) πάνω σε χαρακτηριστικά ροών NOX/OpenFlow. Η εργασία τους θεμελίωσε την ιδέα ότι τα στατιστικά ροών, τα οποία ο μεταγωγέας παράγει έτσι κι αλλιώς, αρκούν για αποτελεσματική ανίχνευση χωρίς βαθιά επιθεώρηση πακέτων. Η παρούσα μελέτη υιοθετεί το ίδιο θεμελιώδες σκεπτικό, επεκτείνοντάς το με σύγχρονους αλγορίθμους συνόλου και με αυτόματη αντιμετώπιση.

Η επισκόπηση των Sultana κ.ά. [9] κατηγοριοποιεί τις προσεγγίσεις ML-based IDS σε SDN και επισημαίνει τόσο την υψηλή ακρίβεια των μεθόδων όσο και τα ανοιχτά ζητήματα κλιμάκωσης και ανθεκτικότητας. Οι Scott-Hayward κ.ά. [6] παρέχουν τη συστηματικότερη επισκόπηση ασφάλειας SDN, ταξινομώντας τις απειλές ανά επίπεδο και τεκμηριώνοντας

τον ρόλο του ελεγκτή ως σημείου συγκέντρωσης ρίσκου. Οι Shin & Gu [12] ήταν από τους πρώτους που κατέδειξαν πειραματικά τη σκοπιμότητα επιθέσεων στο control plane, ενώ οι Elsayed κ.ά. [11] κάλυψαν ένα σημαντικό κενό δημοσιεύοντας το InSDN, το πρώτο σύνολο δεδομένων ειδικά σχεδιασμένο για SDN.

Σε σχέση με την παραπάνω βιβλιογραφία, η συνεισφορά της παρούσας μελέτης έγκειται στη σύζευξη offline σύγκρισης μοντέλων και ζωντανής, end-to-end λειτουργίας μέσα σε ένα ενιαίο σύστημα, καθώς και στην πειραματική διερεύνηση της αντίπαλης ανθεκτικότητας, μια διάσταση που συχνά παραλείπεται στις εφαρμοσμένες μελέτες IDS.

### **Αρχιτεκτονικές συστημάτων ανίχνευσης εισβολών**

Τα συστήματα ανίχνευσης εισβολών ταξινομούνται κατά δύο βασικούς άξονες. Ως προς τη θέση παρακολούθησης, διακρίνονται σε δικτυακά (Network-based IDS, NIDS), που παρακολουθούν την κίνηση του δικτύου, και σε βασισμένα σε host (Host-based IDS, HIDS), που παρακολουθούν τη δραστηριότητα μεμονωμένων συστημάτων. Το προτεινόμενο σύστημα ανήκει στην πρώτη κατηγορία, καθώς αναλύει στατιστικά ροών του δικτύου. Ως προς τη μέθοδο ανίχνευσης, διακρίνονται σε βασισμένα σε κατάχρηση (misuse/signature-based), που εντοπίζουν γνωστά πρότυπα, και σε βασισμένα σε ανωμαλία (anomaly-based), που εντοπίζουν αποκλίσεις από τη φυσιολογική συμπεριφορά. Η προσέγγιση που ακολουθείται συνδυάζει και τις δύο φιλοσοφίες: το επιβλεπόμενο σκέλος προσεγγίζει τη λογική της κατάχρησης, ενώ το μη επιβλεπόμενο σκέλος (Isolation Forest) υλοποιεί καθαρή ανίχνευση ανωμαλιών.

## **4.8 Προεπεξεργασία, ρύθμιση υπερπαραμέτρων και γενίκευση**

Η ποιότητα της προεπεξεργασίας καθορίζει σε μεγάλο βαθμό την τελική απόδοση. Τα χαρακτηριστικά εισόδου του μοντέλου είναι αριθμητικά χαρακτηριστικά ροής που προκύπτουν από τη δομή CICFlowMeter/InSDN. Η κωδικοποίηση εφαρμόστηκε αποκλειστικά στις ετικέτες των κλάσεων (label encoding) και όχι σε αναγνωριστικά όπως διευθύνσεις IP, ονόματα hosts ή θύρες. Τα τελευταία δεν χρησιμοποιήθηκαν ως χαρακτηριστικά εισόδου, ώστε να μην εισαχθούν τεχνητές αριθμητικές αποστάσεις σε αλγορίθμους ευαίσθητους στη μετρική, όπως ο KNN και το SVM. Πέραν της κωδικοποίησης ετικετών, το pipeline εκτελεί καθαρισμό των δεδομένων (αφαίρεση μη έγκυρων ή ελλιπών εγγραφών) και κανονικοποίηση των αριθμητικών χαρακτηριστικών με StandardScaler, ώστε όλα να έχουν μηδενικό μέσο και μοναδιαία διακύμανση. Ο

διαχωρισμός σε σύνολα εκπαίδευσης και ελέγχου είναι στρωματοποιημένος, διατηρώντας τις αναλογίες των κλάσεων σε όλα τα υποσύνολα.

Η ανισορροπία κλάσεων, η υπερεκπροσώπηση της νόμιμης κίνησης έναντι ορισμένων σπάνιων επιθέσεων, αποτελεί γνωστή πρόκληση στα δεδομένα ασφάλειας. Εδώ, η επιλογή μετρικών που δεν παραπλανώνται από την ανισορροπία (precision, recall, F1 αντί μόνο accuracy) και η χρήση διασταυρούμενης επικύρωσης μετριάζουν τον κίνδυνο παραπλανητικών συμπερασμάτων. Στο πραγματικό σύνολο InSDN, όπου η ανισορροπία είναι εντονότερη, η πτώση των μετρικών σε σχέση με το συνθετικό σύνολο είναι ενδεικτική αυτής ακριβώς της δυσκολίας.

### **Ισοζύγιο μεροληψίας-διακύμανσης**

Η επιλογή μοντέλου συνδέεται στενά με το κλασικό ισοζύγιο μεροληψίας-διακύμανσης. Ένα υπερβολικά απλό μοντέλο, όπως η Logistic Regression, εμφανίζει υψηλή μεροληψία: δεν μπορεί να αποτυπώσει τις μη γραμμικές σχέσεις των δεδομένων, γι' αυτό και υποαποδίδει στο πραγματικό InSDN. Ένα υπερβολικά σύνθετο μοντέλο, όπως ένα βαθύ δέντρο απόφασης, εμφανίζει υψηλή διακύμανση: προσαρμόζεται στον θόρυβο των δεδομένων εκπαίδευσης και γενικεύει άσχημα. Το Random Forest επιτυγχάνει την ιδανική ισορροπία, συνδυάζοντας πολλά δέντρα υψηλής διακύμανσης ώστε, μέσω της μέσης τιμής, να μειώνεται η συνολική διακύμανση χωρίς αύξηση της μεροληψίας. Η θεωρητική αυτή ιδιότητα εξηγεί την εμπειρική υπεροχή του, τόσο στο συνθετικό όσο και στο πραγματικό σύνολο.

### **Μεθοδολογία ρύθμισης υπερπαραμέτρων**

Η επίτευξη της βέλτιστης απόδοσης ενός μοντέλου απαιτεί προσεκτική ρύθμιση των υπερπαραμέτρων του, με αυστηρό διαχωρισμό μεταξύ επιλογής και τελικής αξιολόγησης. Για τον Isolation Forest η ρύθμιση πραγματοποιείται με εξαντλητική αναζήτηση στους 108 συνδυασμούς του πλέγματος (πλήθος δέντρων, μέγεθος δείγματος, βαθμός μόλυνσης, ποσοστό χαρακτηριστικών). Κάθε συνδυασμός αξιολογείται σε ανεξάρτητο σύνολο επικύρωσης (validation set) με κριτήριο το ROC-AUC, και η επιλεγμένη διαμόρφωση αποτιμάται μία και μοναδική φορά σε εντελώς ξεχωριστό σύνολο ελέγχου (test set), το οποίο δεν συμμετέχει στην αναζήτηση. Για το Random Forest, όπου ο χώρος υπερπαραμέτρων είναι μεγαλύτερος, χρησιμοποιείται τυχαioποιημένη αναζήτηση με είκοσι πέντε διαμορφώσεις, καθεμία αξιολογούμενη με τριπλή διασταυρούμενη επικύρωση. Η επικύρωση αυτή είναι στρωματοποιημένη και ομαδοποιημένη

(StratifiedGroupKFold), με τις ομάδες να ορίζονται από τα πανομοιότυπα διανύσματα χαρακτηριστικών, ενώ ο κανονικοποιητής εντάσσεται σε διοχέτευση (Pipeline) και προσαρμόζεται ξεχωριστά σε κάθε πτυχή. Έτσι αποκλείεται η διαρροή τόσο από την κανονικοποίηση όσο και από τα ακριβή διπλότυπα. Και στις δύο περιπτώσεις η επιλογή γίνεται στα δεδομένα επικύρωσης και η τελική τιμή αναφέρεται στο ανεξάρτητο σύνολο ελέγχου, μειώνοντας τον κίνδυνο υπερπροσαρμογής στις υπερπαραμέτρους.

Καθοριστική για την αξιοπιστία της αξιολόγησης είναι η αυστηρή διάκριση μεταξύ των δεδομένων εκπαίδευσης, επικύρωσης και ελέγχου. Στα πειράματα εφαρμόζεται τριμερής στρωματοποιημένος διαχωρισμός, με περίπου 55% των δεδομένων για εκπαίδευση, 15% για επικύρωση και 30% για έλεγχο. Η επιλογή του καλύτερου μοντέλου και των υπερπαραμέτρων γίνεται αποκλειστικά στο σύνολο επικύρωσης, ενώ το σύνολο ελέγχου παραμένει εντελώς αόρατο έως την τελική, μία και μοναδική μέτρηση. Ο διαχωρισμός είναι επιπλέον ανθεκτικός στη διαρροή: τα πανομοιότυπα διανύσματα χαρακτηριστικών αντιμετωπίζονται ως ομάδες και δεν μοιράζονται μεταξύ των συνόλων. Ο κανονικοποιητής προσαρμόζεται αποκλειστικά στα δεδομένα εκπαίδευσης και εφαρμόζεται αμετάβλητος στα υπόλοιπα, ώστε να αποκλείεται η μεταφορά στατιστικής πληροφορίας. Η παράβλεψη των αρχών αυτών, η λεγόμενη διαρροή δεδομένων (data leakage), αποτελεί συχνή πηγή υπερεκτιμημένων αποτελεσμάτων στη βιβλιογραφία.

Οφείλει, ωστόσο, να επισημανθεί ένας ουσιώδης περιορισμός που αφορά ειδικά το σύνολο InSDN. Οι επιθέσεις πλημμύρας παράγουν εκ φύσεως πανομοιότυπες ροές: το 47,5% των εγγραφών του συνόλου αποτελούν ακριβή διπλότυπα σε επίπεδο διανύσματος χαρακτηριστικών, με το ποσοστό να ανέρχεται στο 98,8% για την κλάση DDoS και στο 34,7% για την κλάση Probe, ενώ στις υπόλοιπες κλάσεις παραμένει κάτω του 7%. Η αφαίρεση των διπλότυπων θα εξάλειφε σχεδόν ολόκληρη την κλάση DDoS και θα καθιστούσε το σύνολο μη αντιπροσωπευτικό του ίδιου του φαινομένου που μελετάται. Για τον λόγο αυτό διατηρήθηκαν. Με τον τυχαίο διαχωρισμό, πανομοιότυπα διανύσματα εμφανίζονται και στα δύο σύνολα: μετρήθηκε ότι το 50,2% των δειγμάτων του συνόλου ελέγχου έχει ακριβές αντίγραφο στο σύνολο εκπαίδευσης, γεγονός που θα μπορούσε να ευνοήσει την απομνημόνευση. Για να αποτιμηθεί η πραγματική επίπτωση, εφαρμόστηκε συγκριτικά ένας διαχωρισμός ανθεκτικός στη διαρροή (leakage-resistant): κάθε μοναδικό διάνυσμα χαρακτηριστικών αντιμετωπίζεται ως ομάδα και οι ομάδες δεν μοιράζονται μεταξύ εκπαίδευσης και ελέγχου (στρωματοποιημένη ομαδοποίηση, StratifiedGroupKFold), με αποτέλεσμα μηδενική επικάλυψη διανυσμάτων στο σύνολο

ελέγχου. Το εύρημα είναι διαφωτιστικό: το μακρομέσο (macro-averaged) F1 του Random Forest στο InSDN ΔΕΝ μειώνεται, αλλά παραμένει ουσιαστικά σταθερό (από 0,9448 με τυχαίο διαχωρισμό σε 0,9472 με τον ανθεκτικό). Η ερμηνεία είναι ότι τα διπλότυπα συγκεντρώνονται συντριπτικά στην κλάση DDoS, η οποία είναι έτσι κι αλλιώς εύκολα διαχωρίσιμη, ενώ οι δύσκολες κλάσεις, όπως η BFA με μόλις 2% διπλότυπα, δεν επηρεάζονται. Επομένως η υψηλή απόδοση δεν φαίνεται να οφείλεται κυρίως στην επικάλυψη ακριβώς πανομοιότυπων διανυσμάτων. Δεν αποκλείεται, ωστόσο, διαρροή σε επίπεδο συνεδρίας επίθεσης, αρχείου προέλευσης ή χρονικής συσχέτισης, την οποία ο διαχωρισμός ανά διάνυσμα δεν εξαλείφει. Ο αυστηρότερος διαχωρισμός με ομαδοποίηση ανά συνεδρία ή χρονική διάταξη παραμένει κατεύθυνση μελλοντικής εργασίας. Παρ' όλα αυτά, τα αποτελέσματα στο InSDN ερμηνεύονται συντηρητικά ως ένδειξη συμβατότητας του pipeline με πραγματικά δεδομένα και ως αντιπροσωπευτικό μέτρο υιοθετείται το μακρομέσο (macro-averaged) F1, το οποίο αναδεικνύει τη δυσκολία στις μειοψηφικές κατηγορίες, όπως η BFA με μόλις 1.405 δείγματα.

### **Γενίκευση και μετατόπιση εννοιών**

Μια θεμελιώδης πρόκληση για κάθε σύστημα Μηχανικής Μάθησης που λειτουργεί σε πραγματικό περιβάλλον είναι η μετατόπιση εννοιών (concept drift): η σταδιακή μεταβολή των στατιστικών ιδιοτήτων της κίνησης με τον χρόνο. Η νόμιμη κίνηση ενός δικτύου εξελίσσεται καθώς αλλάζουν οι εφαρμογές, οι συνήθειες των χρηστών και η υποδομή, ενώ οι επιθέσεις εξελίσσονται καθώς οι επιτιθέμενοι επινοούν νέες τεχνικές. Ένα μοντέλο εκπαιδευμένο σε παλαιότερα δεδομένα ενδέχεται σταδιακά να χάσει την ακρίβειά του. Η αντιμετώπιση της πρόκλησης αυτής απαιτεί μηχανισμούς παρακολούθησης της απόδοσης και περιοδικής επανεκπαίδευσης. Το μη επιβλεπόμενο μοντέλο του προτεινόμενου συστήματος, που μαθαίνει τη φυσιολογική κατάσταση, προσφέρει εδώ ένα σχετικό πλεονέκτημα, καθώς μπορεί να επαναπροσαρμοστεί στη μεταβαλλόμενη έννοια της «κανονικότητας» με σχετική ευκολία.

## **4.9 Ζητήματα ιδιωτικότητας και δεοντολογίας**

Η ανάλυση δικτυακής κίνησης εγείρει ζητήματα ιδιωτικότητας. Ένα σημαντικό πλεονέκτημα της προσέγγισης βάσει ροών, έναντι της βαθιάς επιθεώρησης πακέτων, είναι ότι δεν απαιτεί πρόσβαση στο περιεχόμενο των επικοινωνιών: τα στατιστικά ροών (πλήθος πακέτων, μεγέθη, χρόνοι) είναι μεταδεδομένα και όχι δεδομένα χρήστη. Έτσι, η μέθοδος σέβεται εγγενώς την ιδιωτικότητα του περιεχομένου, ενώ παραμένει αποτελεσματική. Από

δεοντολογικής άποψης, η αυτοματοποιημένη απόρριψη κίνησης απαιτεί προσοχή ώστε να μην πλήττει νόμιμους χρήστες. Η ελαχιστοποίηση των ψευδώς θετικών, ιδίως στο σενάριο αποκλειστικά νόμιμης κίνησης όπου δεν καταγράφηκαν ψευδώς θετικά, αποτελεί όχι μόνο τεχνική αλλά και δεοντολογική απαίτηση.

#### **4.10 Εκδόσεις και εξέλιξη του OpenFlow**

Το πρωτόκολλο OpenFlow έχει εξελιχθεί μέσα από διαδοχικές εκδόσεις. Η έκδοση 1.0 εισήγαγε τον ενιαίο πίνακα ροών και τα βασικά πεδία ταιριάσματος. Η έκδοση 1.1 πρόσθεσε τη διοχέτευση πολλαπλών πινάκων και τους πίνακες ομάδων. Οι επόμενες εκδόσεις (1.2-1.5) διεύρυναν τα πεδία ταιριάσματος, βελτίωσαν τη διαχείριση σφαλμάτων και πρόσθεσαν λειτουργίες όπως τα meters για rate limiting, χαρακτηριστικό άμεσα σχετικό με την αντιμετώπιση της επίθεσης κορεσμού control plane που μελετάται στη συνέχεια. Η επίγνωση της εξέλιξης αυτής είναι σημαντική, καθώς οι δυνατότητες άμυνας ενός SDN εξαρτώνται άμεσα από την έκδοση του πρωτοκόλλου που υποστηρίζει το υλικό.

## 5. Μεθοδολογία και Υλοποίηση

Η υλοποίηση του συστήματος χωρίζεται σε δύο συμπληρωματικές μεθόδους. Η Μέθοδος Α αφορά τη ζωντανή ανίχνευση και αντιμετώπιση μέσα σε προσομοιωμένο δίκτυο SDN, ενώ η Μέθοδος Β αφορά την offline ανάλυση ροών με Μηχανική Μάθηση σε δεδομένα δομής InSDN. Ολόκληρος ο κώδικας αναπτύχθηκε σε γλώσσα Python και οργανώνεται σε ένα αναπαραγώγιμο περιβάλλον βασισμένο σε Docker.

### 5.1 Συνολική αρχιτεκτονική του συστήματος

Το ζωντανό σύστημα αποτελείται από τέσσερα συνεργαζόμενα δομικά στοιχεία, τα οποία εκτελούνται ως απομονωμένα containers και ενορχηστρώνονται μέσω Docker Compose:

| Στοιχείο                                  | Ρόλος                                                                                                                    |
|-------------------------------------------|--------------------------------------------------------------------------------------------------------------------------|
| sdn_controller (Flask, θύρα 9000)         | Μηχανή άμυνας Isolation Forest. Εκθέτει REST endpoints τηλεμετρίας, πίνακα ροών, τοπολογίας, στατιστικών και επαναφοράς. |
| sdn_dashboard (Dash/Cytoscape, θύρα 8050) | Οπτικοποίηση τοπολογίας και κίνησης σε πραγματικό χρόνο.                                                                 |
| sdn_switch                                | Μεταγωγέας overlay σε επίπεδο εφαρμογής.                                                                                 |
| sdn_mininet (Mininet + OVS, privileged)   | Εκτελεί το ζωντανό σενάριο με πραγματικά πακέτα.                                                                         |

*Πίνακας 5-1: Τα τέσσερα containers του ζωντανού συστήματος και ο ρόλος τους.*

Η ροή λειτουργίας υλοποιεί έναν κλειστό βρόχο εποπτείας-απόφασης-δράσης: ο μεταγωγέας παρέχει στατιστικά θυρών, ο ελεγκτής τα αναλύει σε πραγματικό χρόνο με τη μηχανή Isolation Forest και, όταν εντοπίσει επίθεση, επαναπρογραμματίζει το δίκτυο εγκαθιστώντας κανόνα απόρριψης.

### 5.2 Αρχιτεκτονική ελέγχου: υβριδικό μοντέλο SDN

Η υλοποίηση ακολουθεί υβριδική αρχιτεκτονική SDN. Η βασική προώθηση πακέτων εκτελείται από τον Open vSwitch, ο οποίος λειτουργεί σε failMode=standalone, ενώ ο ελεγκτής λειτουργεί ως λογικά κεντριοποιημένη εφαρμογή ασφαλείας: συλλέγει τηλεμετρία, εκτελεί ανίχνευση ανωμαλιών και εγκαθιστά κανόνες απόρριψης μέσω μηχανισμών συμβατών με τη σημασιολογία OpenFlow (εργαλείο ovs-ofctl και REST τηλεμετρία). Με τον τρόπο αυτό διατηρείται ο διαχωρισμός επιπέδου ελέγχου και

επιπέδου δεδομένων, χωρίς η υλοποίηση να εξαρτάται από πλήρη reactive OpenFlow controller ο οποίος θα λάμβανε αποφάσεις ανά νέα ροή μέσω Packet-In/Flow-Mod. Παρά τη διαφορά αυτή στον μηχανισμό, η αρχιτεκτονική διατηρεί και τους τέσσερις πυλώνες του ορισμού του SDN [13]:

1. Διαχωρισμός επιπέδου ελέγχου και δεδομένων: ο ελεγκτής (Flask) είναι φυσικά και λογικά διαχωρισμένος από τον μεταγωγέα (OVS). Καμία απόφαση ασφαλείας δεν λαμβάνεται στο επίπεδο δεδομένων.
2. Λογικά κεντριοποιημένος έλεγχος με καθολική εποπτεία: ο ελεγκτής συγκεντρώνει τηλεμετρία από το σύνολο των θυρών και διατηρεί ενιαία εικόνα του δικτύου, επί της οποίας εκτελείται η μηχανή ανίχνευσης.
3. Προγραμματιζόμενο επίπεδο δεδομένων: όταν μια ροή χαρακτηριστεί κακόβουλη, ο ελεγκτής εγκαθιστά κανόνα υψηλής προτεραιότητας (priority=100, ip, nw\_src=<attacker>, actions=drop), η ίδια σημασιολογία match-action με ένα OpenFlow Flow-Mod.
4. Κλειστός βρόχος εποπτείας-απόφασης-δράσης: η ροή Data Collection → Inference → Automated Mitigation υλοποιεί πλήρως τον κύκλο ελέγχου μιας εφαρμογής ασφαλείας SDN.

Η επιβολή των κανόνων στον μεταγωγέα γίνεται μέσω του εργαλείου ovs-ofctl, το οποίο εκδίδει εντολές συμβατές με το OpenFlow (αίτηση στατιστικών θυρών, εγκατάσταση κανόνων ροής). Πρόκειται όμως για τοπικό, διαχειριστικό προγραμματισμό του Open vSwitch με εντολές συμβατές με OpenFlow, και όχι για ισοδύναμο κανάλι ελεγκτή-μεταγωγέα. Η διαφορά δεν περιορίζεται στον μηχανισμό μεταφοράς (τοπική κλήση αντί μόνιμης σύνδεσης TCP). Ένα πραγματικό southbound κανάλι OpenFlow προϋποθέτει μόνιμη συνεδρία ελεγκτή-μεταγωγέα, ασύγχρονα συμβάντα (Packet-In, Flow-Removed), διαπραγμάτευση ρόλου του ελεγκτή, κυριότητα του datapath και διατήρηση συνέπειας πολιτικής μεταξύ πολλαπλών μεταγωγέων. Τα στοιχεία αυτά απουσιάζουν από την παρούσα υλοποίηση, η οποία είναι εξ ορισμού υβριδική. Ο ελεγκτής λειτουργεί ως λογικά κεντριοποιημένη εφαρμογή ασφαλείας που προγραμματίζει τοπικά τον μεταγωγέα, και όχι ως πλήρης reactive OpenFlow controller.

### 5.2.1 Αιτιολόγηση της σχεδιαστικής επιλογής

Η επιλογή του υβριδικού μοντέλου έναντι του αμιγώς αντιδραστικού βασίστηκε σε δύο άξονες. Πρώτον, σε λόγους επιδόσεων και ανθεκτικότητας: στο αμιγώς αντιδραστικό μοντέλο ο ελεγκτής αποτελεί σημείο συμφόρησης και μοναδικό σημείο αποτυχίας, ενώ

στο υβριδικό η βασική συνδεσιμότητα διατηρείται ακόμη και αν ο ελεγκτής δεχθεί πίεση. Δεύτερον, σε πρακτικούς λόγους: ο ελεγκτής Ryu, παρότι διαδεδομένος, δεν συντηρείται πλέον ενεργά και παρουσιάζει ασυμβατότητες με σύγχρονες εκδόσεις της Python ( $\geq 3.10$ ) και της βιβλιοθήκης eventlet, οι οποίες επιβεβαιώθηκαν πειραματικά. Το πλήρες κύκλωμα ανίχνευσης και αντιμετώπισης υλοποιείται χωρίς εξάρτηση από εξωτερικό OpenFlow framework, με απλούστερη και πιο συντηρήσιμη αρχιτεκτονική.

### 5.3 Μέθοδος A: Ζωντανό σύστημα και αντιμετώπιση

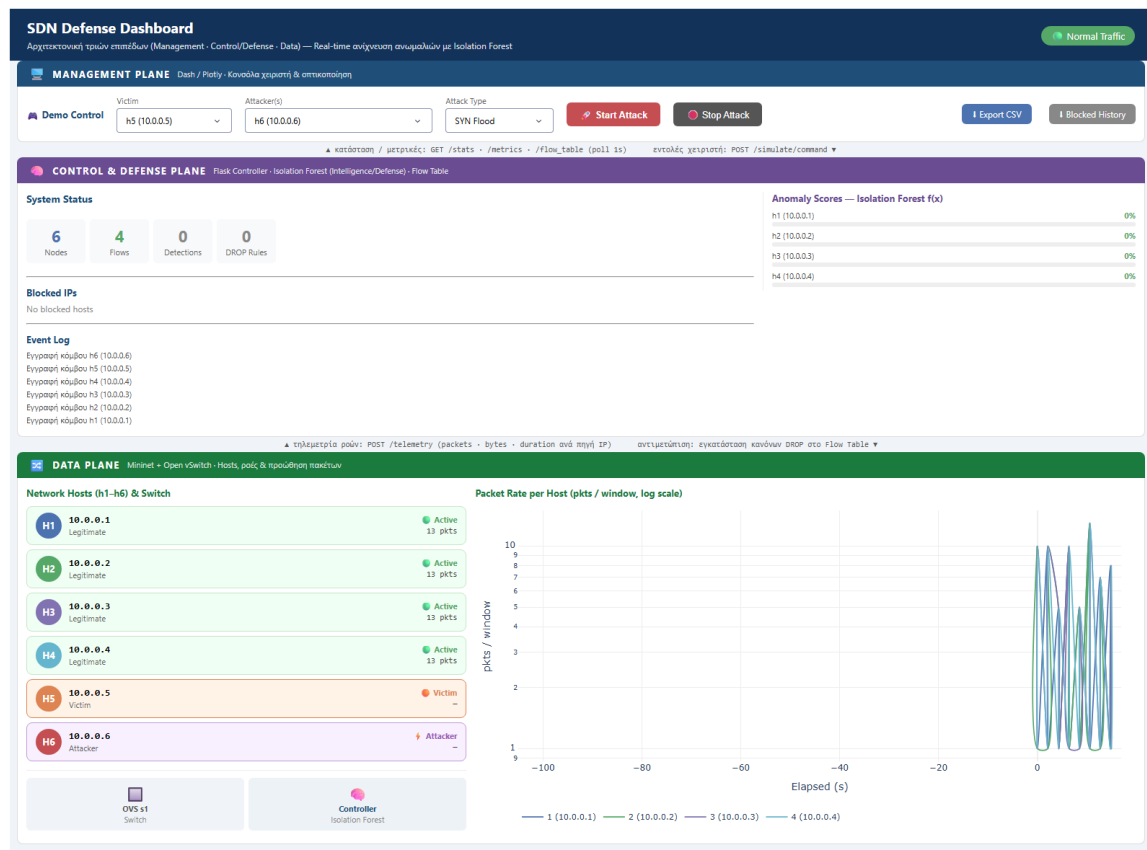
Για τη Μέθοδο A υλοποιήθηκε το ζωντανό σενάριο (simulation/mininet\_live.py). Μετά την εκκίνηση του ελεγκτή, κατασκευάζεται μεταγωγέας OVS σε λειτουργία failMode=standalone και datapath=user, επιλογή απαραίτητη στο περιβάλλον WSL2, όπου δεν υπάρχει διαθέσιμο kernel module του OVS. Το δίκτυο αποτελείται από έξι hosts: τέσσερις νόμιμους (h1-h4), έναν στόχο-θύμα (h5, 10.0.0.5) και έναν επιτιθέμενο (h6, 10.0.0.6).

Ένα νήμα παρασκηνίου ανακτά τα στατιστικά του πίνακα ροών του μεταγωγέα κάθε πέντε δευτερόλεπτα (ovs-ofctl dump-flows) και τα αποστέλλει στον ελεγκτή μέσω του endpoint τηλεμετρίας. Για τον σκοπό αυτό εγκαθίστανται κανόνες ροής ανά ζεύγος διευθύνσεων (nw\_src, nw\_dst) με ενέργεια κανονικής προώθησης, ώστε ο πίνακας ροών να διατηρεί ξεχωριστούς μετρητές ανά ροή. Ακριβέστερα, η άθροιση γίνεται ανά ζεύγος πηγής-προορισμού (per-source-destination flow aggregation) και όχι ανά πλήρη 5-tuple ροή: οι κανόνες δεν διακρίνουν πρωτόκολλο ούτε θύρες προέλευσης/προορισμού, οπότε το flow\_count μετρά διακριτούς προορισμούς και όχι διακριτές συνδέσεις. Μια πλημμύρα SYN με πολλές συνδέσεις από την ίδια πηγή προς τον ίδιο προορισμό εμφανίζεται ως μία συγκεντρωτική καταχώρηση. Η ανίχνευσή της βασίζεται στον όγκο και όχι στο πλήθος συνδέσεων. Έτσι κάθε πηγή αντιστοιχεί σε μία καταχώρηση ανά προορισμό, και τα συγκεντρωτικά χαρακτηριστικά (flow\_count, short\_flow\_ratio, μέσος αριθμός πακέτων και διάρκεια ανά ροή) υπολογίζονται από αυτά τα στατιστικά ανά ζεύγος και όχι από τη διαφορά ενός μόνο μετρητή θύρας. Τα χαρακτηριστικά τροφοδοτούνται στο μοντέλο Isolation Forest και, σε κάθε πηγή που ταξινομείται ως επιτιθέμενη, εγκαθίσταται αυτόματα κανόνας απόρριψης. Το σενάριο εκτελείται σε δύο φάσεις: μια φάση νόμιμης κίνησης (ping) και μια φάση επίθεσης (hping3 --syn --flood), κατά την οποία ο επιτιθέμενος εντοπίζεται και μπλοκάρεται, ενώ η νόμιμη κίνηση παραμένει ανεπηρέαστη.

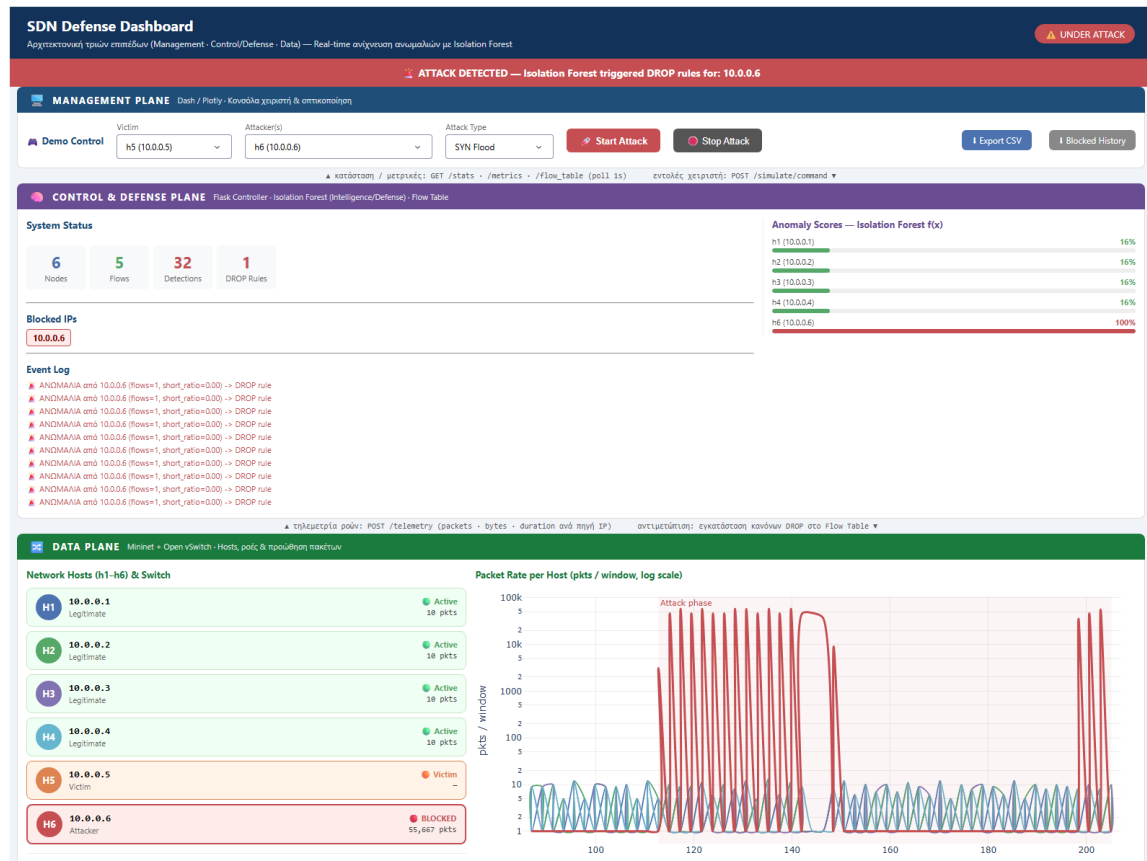
### 5.3.1 Αποφυγή ψευδώς θετικών

Ιδιαίτερη μέριμνα δόθηκε στην αποφυγή ψευδώς θετικών κατά τη φάση της νόμιμης κίνησης. Χρησιμοποιείται εντολή `ping` με είκοσι πακέτα ανά `host`, ώστε ο αριθμός πακέτων να υπερβαίνει σαφώς το κατώφλι σύντομης ροής και ο λόγος σύντομων ροών να παραμένει μηδενικός. Επιπλέον, παραλείπονται από την τηλεμετρία τα πακέτα κάτω των τεσσάρων ανά διάστημα, καθώς και η θύρα του θύματος (`h5`), η οποία αποστέλλει απαντήσεις RST στην πλημμύρα και θα μπορούσε λανθασμένα να θεωρηθεί ανώμαλη.

Τα Σχήματα 5-1 και 5-2 δείχνουν το ζωντανό dashboard στις δύο χαρακτηριστικές φάσεις του σεναρίου: την κανονική λειτουργία του δικτύου και τη στιγμή της ανίχνευσης και του αυτόματου αποκλεισμού του επιτιθέμενου κόμβου.



Σχήμα 5-1: Το ζωντανό dashboard σε φάση κανονικής λειτουργίας. Και οι έξι κόμβοι είναι ενεργοί, ο πίνακας *Anomaly Scores* δείχνει τιμές  $f(x) > 0$  (0% απειλή) για όλους τους νόμιμους κόμβους και δεν υπάρχει κανένας κανόνας DROP στο flow table.



Σχήμα 5-2: Το ίδιο dashboard κατά τη φάση επίθεσης SYN flood. Το Isolation Forest χαρακτηρίζει τον κόμβο h6 (10.0.0.6) ως ανωμαλία ( $f(x) < 0$ , 100% απειλή), ο ελεγκτής εγκαθιστά κανόνα DROP και ο επιτιθέμενος εμφανίζεται ως BLOCKED, ενώ οι νόμιμοι κόμβοι h1-h4 παραμένουν στο 0% χωρίς ψευδώς θετικά.

## 5.4 Μέθοδος B: offline ανάλυση και παραγωγή του συνθετικού συνόλου

Το offline pipeline (φάκελος ml\_pipeline/) υλοποιεί όλα τα στάδια της εκπαίδευσης και αξιολόγησης. Ως βάση χρησιμοποιήθηκε η δομή χαρακτηριστικών του CICFlowMeter, η ίδια με του InSDN. Κάθε ροή περιγράφεται από 24 χαρακτηριστικά και ταξινομείται σε πέντε κατηγορίες: κανονική κίνηση (Normal) και τέσσερις τύπους επιθέσεων (DDoS, DoS, Probe, BFA). Για την ανάπτυξη και τον έλεγχο δημιουργήθηκε συνθετικό σύνολο 20.500 ροών, το οποίο παράγεται σε δύο εκδοχές: μια προεπιλεγμένη με καθαρές, μη επικαλυπτόμενες υπογραφές ανά κατηγορία, και μια απαιτητική (παράμετρος --hard) στην οποία εισάγεται θόρυβος και ελεγχόμενη επικάλυψη μεταξύ γειτονικών κατηγοριών. Τα επίσημα αποτελέσματα του κειμένου προέρχονται από την προεπιλεγμένη εκδοχή. Το ίδιο pipeline δέχεται απευθείας και το πραγματικό σύνολο InSDN.

Τα στάδια του pipeline είναι: (α) προεπεξεργασία, καθαρισμός, κωδικοποίηση των ετικετών κλάσης, κανονικοποίηση των αριθμητικών χαρακτηριστικών με StandardScaler

και στρωματοποιημένος διαχωρισμός σε σύνολα εκπαίδευσης/ελέγχου, (β) εκπαίδευση και σύγκριση οκτώ μοντέλων, (γ) αξιολόγηση με μετρικές (accuracy, precision, recall, F1), πίνακες σύγχυσης, καμπύλες ROC και διασταυρούμενη επικύρωση, (δ) ανάλυση ερμηνευσιμότητας με SHAP.

### Παραγωγή του συνθετικού συνόλου δεδομένων

Η ανάπτυξη και ο έλεγχος του offline pipeline απαίτησαν ένα σύνολο δεδομένων με γνωστές ετικέτες και ελεγχόμενα χαρακτηριστικά. Οφείλει να τονιστεί με σαφήνεια ότι η προεπιλεγμένη εκδοχή του συνθετικού συνόλου, από την οποία προκύπτουν τα επίσημα αποτελέσματα, έχει καθαρές υπογραφές ανά κατηγορία. Οι πολύ υψηλές τιμές που παρατηρούνται σε αυτό, όπως το μακρο-F1 του Random Forest στο 1,000, είναι εγγενής συνέπεια αυτής της ευκολίας και δεν αποτελούν ένδειξη γενίκευσης. Χρησιμεύουν αποκλειστικά για τον έλεγχο ορθής λειτουργίας του pipeline. Για να αποτιμηθεί πόσο αισιόδοξες είναι, το ίδιο pipeline εφαρμόστηκε και στην απαιτητική εκδοχή (--hard), με θόρυβο και επικάλυψη κλάσεων. Ο ακόλουθος πίνακας αντιπαραβάλλει τις δύο εκδοχές: στην απαιτητική, η απόδοση μειώνεται ελαφρά αλλά ρεαλιστικά (το μακρο-F1 του Random Forest από 1,000 σε 0,995, ενώ τα ασθενέστερα μοντέλα υποχωρούν περισσότερο, όπως ο KNN από 0,990 σε 0,970). Τα ουσιαστικά συμπεράσματα της εργασίας δεν στηρίζονται πάντως στο συνθετικό σύνολο, αλλά στο πραγματικό InSDN και στα ζωντανά σενάρια.

| Μοντέλο             | clean (καθαρές υπογραφές) | hard (θόρυβος + επικάλυψη) |
|---------------------|---------------------------|----------------------------|
| Random Forest       | 1,0000                    | 0,9955                     |
| SVM (RBF)           | 0,9974                    | 0,9893                     |
| Decision Tree       | 0,9955                    | 0,9828                     |
| Logistic Regression | 0,9947                    | 0,9814                     |
| KNN                 | 0,9900                    | 0,9701                     |

*Πίνακας 5-2: Συνθετικό σύνολο, test macro-F1 στην καθαρή και στην απαιτητική εκδοχή.*

### Εναλλακτική υλοποίηση Mode B με OpenFlow

Παράλληλα με την κύρια, υβριδική υλοποίηση, το σύστημα υποστηρίζει και μια εναλλακτική λειτουργία (Mode B) που αξιοποιεί πλήρη ελεγκτή OpenFlow, διαθέσιμη μέσω ξεχωριστού προφίλ εκτέλεσης. Η δυνατότητα αυτή τεκμηριώνει ότι η αρχιτεκτονική

δεν είναι δεσμευμένη στον συγκεκριμένο μηχανισμό συλλογής τηλεμετρίας: η μηχανή ανίχνευσης και ο μηχανισμός αντιμετώπισης παραμένουν αμετάβλητοι, ανεξαρτήτως του αν η τηλεμετρία συλλέγεται μέσω `ons-ofctl` ή μέσω μιας πλήρους σύνδεσης OpenFlow. Η διάκριση αυτή είναι σημαντική για τη μελλοντική μετάβαση σε πλήρες αντιδραστικό μοντέλο, όπως συζητείται στο Κεφάλαιο 7.

## 5.5 Ασφάλεια της υλοποίησης και προστασία του ελεγκτή

Το σύστημα ενσωματώνει μηχανισμούς ασφαλείας που τεκμηριώνουν την καταλληλότητά του ως εφαρμογής κυβερνοασφάλειας, και όχι απλώς ως ερευνητικού prototype:

| Μηχανισμός                                      | Κατάσταση |
|-------------------------------------------------|-----------|
| Rate limiting (120 αιτήματα / 60s)              | Ενεργό    |
| Προστασία admin με token (X-Admin-Token)        | Ενεργό    |
| Αυθεντικοποίηση μεταγωγέα (X-Switch-Token)      | Ενεργό    |
| Εξαγωγή δεδομένων σε CSV (/export/*.csv)        | Διαθέσιμο |
| Endpoint anomaly scores (/anomaly_scores)       | Διαθέσιμο |
| Λειτουργία Mode B (Ryu/OpenFlow, --profile ryu) | Διαθέσιμο |

*Πίνακας 5-3: Μηχανισμοί ασφαλείας του ελεγκτή.*

Η αυθεντικοποίηση της τηλεμετρίας (X-Switch-Token) είναι ιδιαίτερα σημαντική ενόψει της επίθεσης δηλητηρίασης τηλεμετρίας που εξετάζεται στο Κεφάλαιο 6: χωρίς αυτήν, ένας κακόβουλος host θα μπορούσε να στείλει πλαστά στατιστικά και να ενοχοποιήσει νόμιμους κόμβους.

### Έλεγχος ρυθμού και προστασία του ελεγκτή

Ένα σύστημα που προορίζεται να προστατεύει το δίκτυο πρέπει το ίδιο να είναι ανθεκτικό σε επιθέσεις. Ο ελεγκτής προστατεύεται με μηχανισμό ελέγχου ρυθμού αιτημάτων, ο οποίος περιορίζει το πλήθος των κλήσεων που μπορεί να δεχθεί ανά μονάδα χρόνου. Έτσι, ακόμη και αν ένας επιτιθέμενος προσπαθήσει να κατακλύσει τον ίδιο τον ελεγκτή με αιτήματα, η λειτουργικότητά του διατηρείται. Ο συνδυασμός αυτού του μηχανισμού με την αυθεντικοποίηση των διαχειριστικών endpoints και της τηλεμετρίας συνθέτει μια πολυεπίπεδη προστασία του ίδιου του συστήματος άμυνας, μια αρχή θεμελιώδη στην κυβερνοασφάλεια, όπου κάθε αμυντικός μηχανισμός πρέπει να λαμβάνει μέριμνα και για τη δική του ασφάλεια.

## 5.6 REST διεπαφή του ελεγκτή

Ο ελεγκτής εκθέτει μια RESTful διεπαφή (northbound API) μέσω Flask, η οποία αποτελεί το σημείο ολοκλήρωσης όλων των στοιχείων του συστήματος. Τα κυριότερα endpoints συνοψίζονται στον ακόλουθο πίνακα.

| Endpoint              | Λειτουργία                                 |
|-----------------------|--------------------------------------------|
| POST /telemetry       | Λήψη στατιστικών ροών από τον μεταγωγέα.   |
| GET /flow_table       | Επιστροφή του τρέχοντος πίνακα ροών.       |
| GET /topology         | Επιστροφή της τοπολογίας για το dashboard. |
| GET /stats            | Συγκεντρωτικές μετρικές λειτουργίας.       |
| GET /anomaly_scores   | Τιμές ανωμαλίας ανά πηγή.                  |
| POST /reset           | Επαναφορά κατάστασης (νέο σενάριο).        |
| GET /export/flows.csv | Εξαγωγή ροών σε CSV.                       |

*Πίνακας 5-4: Κυριότερα REST endpoints του ελεγκτή.*

## 5.7 Ο βρόχος τηλεμετρίας: μορφή μηνυμάτων και αλγόριθμος απόφασης

Ο πυρήνας της ζωντανής λειτουργίας είναι ένας επαναλαμβανόμενος βρόχος με περίοδο πέντε δευτερολέπτων. Σε κάθε επανάληψη, το νήμα τηλεμετρίας εκτελεί `ons-ofctl dump-flows` στον μεταγωγέα, υπολογίζει τη διαφορά μετρητών ανά ροή σε σχέση με την προηγούμενη μέτρηση και συνθέτει, ανά πηγή IP, μια λίστα από πραγματικές ροές, καθεμία με δικό της πλήθος πακέτων, όγκο και διάρκεια. Από τη λίστα αυτή προκύπτει το διάνυσμα συγκεντρωτικών χαρακτηριστικών, το οποίο κανονικοποιείται και τροφοδοτείται στη μηχανή Isolation Forest. Αν ο πίνακας ροών δεν έχει ακόμη per-flow καταχωρήσεις, ο μηχανισμός υποχωρεί με ασφάλεια στην προγενέστερη προσέγγιση της διαφοράς μετρητή θύρας. Αν η πηγή ταξινομηθεί ως επιτιθέμενη, ο ελεγκτής εκδίδει εντολή εγκατάστασης κανόνα απόρριψης με υψηλή προτεραιότητα. Ο κανόνας φέρει πεπερασμένο χρόνο ζωής (lease) ώστε ο αποκλεισμός να μην είναι μόνιμος. Όσο η επίθεση συνεχίζεται, ένα ανεξάρτητο νήμα παρακολουθεί τον μετρητή του ίδιου του κανόνα απόρριψης, που παραμένει η μόνη ζωντανή ένδειξη για μια πηγή της οποίας η κίνηση πλέον απορρίπτεται, και ανανεώνει το lease πριν αυτό λήξει. Έτσι η αντιμετώπιση καλύπτει ολόκληρη τη διάρκεια της επίθεσης και όχι μόνο το πρώτο TTL. Όταν η κακόβουλη κίνηση σταματήσει,

το lease αφήνεται να λήξει και η πηγή αποδεσμεύεται. Ο κύκλος ανίχνευση, εγκατάσταση, λήξη, επανεκτίμηση, ανανέωση ή αποδέσμευση αναλύεται ποσοτικά στο Κεφάλαιο 6.

Η επιλογή παραθύρου πέντε δευτερολέπτων αποτελεί συμβιβασμό μεταξύ ταχύτητας απόκρισης και στατιστικής αξιοπιστίας: παράθυρα πολύ μικρά εισάγουν θόρυβο και ψευδώς θετικά, ενώ παράθυρα πολύ μεγάλα καθυστερούν την αντίδραση. Όπως δείχνει η ανάλυση καθυστέρησης, το παράθυρο αυτό επιτρέπει ανίχνευση ήδη από το πρώτο διάστημα εμφάνισης της επίθεσης.

### **Μορφή μηνυμάτων τηλεμετρίας**

Η επικοινωνία μεταξύ του μεταγωγέα και του ελεγκτή γίνεται με δομημένα μηνύματα JSON. Κάθε μήνυμα τηλεμετρίας περιέχει τη διεύθυνση προέλευσης, τη διεύθυνση προορισμού και μια λίστα ροών, καθεμία περιγραφόμενη από το πλήθος πακέτων, το πλήθος bytes και τη διάρκεια. Η απλότητα και η τυποποίηση του σχήματος διευκολύνουν τόσο την επεξεργασία όσο και την επέκταση: πρόσθετα χαρακτηριστικά μπορούν να ενσωματωθούν χωρίς αλλαγή της βασικής δομής. Η αυθεντικοποίηση κάθε μηνύματος με token διασφαλίζει ότι μόνο ο εξουσιοδοτημένος μεταγωγέας μπορεί να υποβάλει τηλεμετρία, αποτρέποντας την επίθεση δηλητηρίασης.

### **Ο αλγόριθμος ανίχνευσης βήμα προς βήμα**

Ο πυρήνας της απόφασης εκτελείται από τη μηχανή ανίχνευσης σε κάθε παράθυρο δειγματοληψίας. Αρχικά, τα ακατέργαστα στατιστικά θυρών μετατρέπονται σε διαφορικές τιμές (deltas) ως προς την προηγούμενη μέτρηση, ώστε να αντικατοπτρίζουν τη δραστηριότητα του τρέχοντος παραθύρου και όχι τους σωρευτικούς μετρητές. Στη συνέχεια, οι τιμές ομαδοποιούνται ανά πηγή IP και υπολογίζονται τα συγκεντρωτικά χαρακτηριστικά: το πλήθος ενεργών ροών, ο λόγος των σύντομων ροών, ο μέσος αριθμός πακέτων ανά ροή και η μέση διάρκεια. Τα χαρακτηριστικά κανονικοποιούνται με τον ίδιο scaler που χρησιμοποιήθηκε κατά την εκπαίδευση, ώστε να διασφαλίζεται συνέπεια μεταξύ εκπαίδευσης και εξαγωγής συμπερασμάτων.

Το κανονικοποιημένο διάνυσμα τροφοδοτείται στη μηχανή Isolation Forest, η οποία επιστρέφει μια τιμή ανωμαλίας. Αν η τιμή υπερβεί το κατώφλι απόφασης, η πηγή χαρακτηρίζεται ως επιτιθέμενη. Πριν την οριστική απόφαση, εφαρμόζονται ορισμένοι κανόνες ασφαλείας που περιορίζουν τα ψευδώς θετικά, για παράδειγμα, η παράβλεψη πηγών με ελάχιστη δραστηριότητα και η εξαίρεση της θύρας του θύματος, η οποία εκπέμπει απαντήσεις RST στην πλημμύρα. Τέλος, για κάθε επιβεβαιωμένη επίθεση,

εκδίδεται εντολή εγκατάστασης κανόνα απόρριψης και ενημερώνεται η κατάσταση του συστήματος και το dashboard.

## 5.8 Περιβάλλον εκτέλεσης: Docker, δικτύωση και WSL2

Η αναπαραγωγικότητα αποτέλεσε ρητή σχεδιαστική προτεραιότητα. Ολόκληρο το σύστημα ενορχηστρώνεται μέσω ενός αρχείου Docker Compose, το οποίο ορίζει και τα τέσσερα containers, τις μεταξύ τους συνδέσεις και τις θύρες. Με μία εντολή, ο αξιολογητής μπορεί να ανεγείρει ολόκληρη τη στοίβα και να εκτελέσει τόσο τα ζωντανά σενάρια όσο και το offline pipeline. Τα σενάρια `run_all.sh` και `run_live_experiments.sh` αυτοματοποιούν πλήρως την αναπαραγωγή των αποτελεσμάτων, ενώ ένα σύνολο αυτοματοποιημένων ελέγχων (tests) και μια ροή συνεχούς ενσωμάτωσης (CI) επιβεβαιώνουν την ακεραιότητα του κώδικα σε κάθε αλλαγή.

Το περιβάλλον εκτέλεσης ήταν Windows με WSL2. Η επιλογή αυτή παρουσίασε μια τεχνική ιδιαιτερότητα: ο πυρήνας του WSL2 δεν περιλαμβάνει το kernel module του Open vSwitch, με αποτέλεσμα η τυπική εκκίνηση της υπηρεσίας να μην ενεργοποιεί τον δαίμονα `ovs-vswitchd`. Η λύση ήταν η ρητή εκκίνηση του δαίμονα σε userspace λειτουργία και η κατασκευή του μεταγωγέα με `datapath=user` και `failMode=standalone`. Η επιλογή αυτή, αν και επιβεβλημένη από το περιβάλλον, ευθυγραμμίζεται με το υβριδικό μοντέλο ελέγχου, καθώς επιτρέπει στον μεταγωγέα να λειτουργεί ως αυτόνομος learning switch.

### Απομόνωση και δικτύωση των containers

Η επιλογή της τεχνολογίας containers για την ανάπτυξη του συστήματος εξυπηρετεί πολλαπλούς σκοπούς. Κάθε στοιχείο εκτελείται σε απομονωμένο περιβάλλον με τις δικές του εξαρτήσεις, εξαλείφοντας τις συγκρούσεις βιβλιοθηκών και διασφαλίζοντας ότι η συμπεριφορά είναι ίδια σε κάθε μηχανήμα. Η μεταξύ τους επικοινωνία γίνεται μέσω ενός εικονικού δικτύου που ορίζει το Docker Compose, με σαφώς καθορισμένες θύρες και ονόματα υπηρεσιών. Ο μεταγωγέας εκτελείται σε προνομιακό (privileged) container, καθώς απαιτεί πρόσβαση σε λειτουργίες δικτύου του πυρήνα για τη δημιουργία εικονικών διεπαφών και τη διαχείριση του Open vSwitch.

Η προσέγγιση αυτή καθιστά ολόκληρο το πείραμα φορητό και αναπαραγωγίμο: ο αξιολογητής δεν χρειάζεται να εγκαταστήσει χειροκίνητα εξαρτήσεις ή να ρυθμίσει το περιβάλλον, παρά μόνο να διαθέτει το Docker. Η φορητότητα αυτή είναι κρίσιμη για την επιστημονική αξία της μελέτης, καθώς επιτρέπει την ανεξάρτητη επαλήθευση των αποτελεσμάτων από τρίτους, μια θεμελιώδη αρχή της επιστημονικής μεθόδου.

## **Ιδιαιτερότητες του περιβάλλοντος WSL2**

Η ανάπτυξη σε περιβάλλον Windows με WSL2 απαίτησε την αντιμετώπιση συγκεκριμένων τεχνικών προκλήσεων. Η σημαντικότερη αφορούσε την απουσία του kernel module του Open vSwitch στον πυρήνα του WSL2, η οποία εμπόδιζε την τυπική λειτουργία του μεταγωγέα. Η λύση της ρητής εκκίνησης του δαίμονα σε userspace λειτουργία και της κατασκευής του μεταγωγέα με datapath τύπου user αποδείχθηκε αξιόπιστη και, όπως προαναφέρθηκε, εναρμονισμένη με το υβριδικό μοντέλο ελέγχου. Η τεκμηρίωση αυτής της λύσης έχει αξία και για μελλοντικούς ερευνητές που εργάζονται στο ίδιο, ολοένα και δημοφιλέστερο, περιβάλλον ανάπτυξης.

## **5.9 Οπτικοποίηση σε πραγματικό χρόνο**

Ένα σημαντικό στοιχείο του συστήματος είναι το dashboard οπτικοποίησης, υλοποιημένο με Dash και Cytoscape. Το dashboard παρουσιάζει σε πραγματικό χρόνο την τοπολογία του δικτύου, με τους κόμβους να αλλάζουν χρώμα ανάλογα με την κατάστασή τους (νόμιμος, υπό παρακολούθηση, μπλοκαρισμένος), καθώς και ένα διάγραμμα του ρυθμού πακέτων που εξελίσσεται χρονικά. Έτσι, ο χρήστης παρακολουθεί οπτικά τη στιγμή της επίθεσης, την ανίχνευση και την επιβολή του κανόνα απόρριψης. Πέραν της επιδεικτικής του αξίας, το dashboard λειτουργεί και ως εργαλείο επαλήθευσης, καθιστώντας άμεσα ορατή την ορθή λειτουργία του κλειστού βρόχου εποπτείας-απόφασης-δράσης.

## **5.10 Διαχείριση κατάστασης, ταυτοχρονισμού και σφαλμάτων**

Η ζωντανή λειτουργία απαιτεί προσεκτική διαχείριση κατάστασης. Ο ελεγκτής διατηρεί τη λίστα των ενεργών κανόνων απόρριψης με τους χρόνους λήξης τους, το ιστορικό των ανιχνεύσεων και τις σωρευτικές μετρικές. Καθώς το νήμα τηλεμετρίας και οι εισερχόμενες κλήσεις REST εκτελούνται ταυτόχρονα, η πρόσβαση στην κοινή κατάσταση προστατεύεται ώστε να αποφεύγονται συνθήκες ανταγωνισμού (race conditions). Η σχεδίαση αυτή εξασφαλίζει ότι, ακόμη και υπό υψηλό ρυθμό τηλεμετρίας κατά τη διάρκεια μιας επίθεσης, οι αποφάσεις παραμένουν συνεπείς και το σύστημα δεν εισέρχεται σε ασυνεπή κατάσταση.

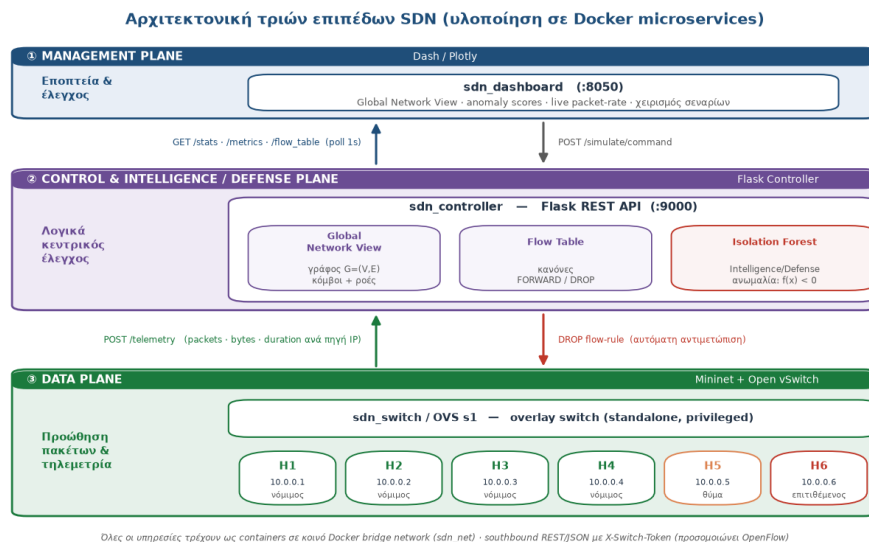
## **Χειρισμός σφαλμάτων και ανθεκτικότητα**

Ένα σύστημα που προορίζεται για λειτουργία σε πραγματικό χρόνο πρέπει να είναι ανθεκτικό σε σφάλματα. Ο ελεγκτής χειρίζεται με χάρη τις περιπτώσεις ελλιπούς ή καθυστερημένης τηλεμετρίας, τις παροδικές αστοχίες επικοινωνίας με τον μεταγωγέα και

τις μη έγκυρες εισόδους, χωρίς να διακόπτεται η λειτουργία του. Ο μηχανισμός rate limiting προστατεύει τον ίδιο τον ελεγκτή από υπερφόρτωση αιτημάτων, ενώ η περιοδική φύση του βρόχου τηλεμετρίας εξασφαλίζει ότι μια μεμονωμένη αστοχία σε ένα παράθυρο δεν επηρεάζει τα επόμενα. Η σχεδίαση αυτή αντικατοπτρίζει την αρχή ότι ένα σύστημα ασφαλείας πρέπει το ίδιο να είναι ασφαλές και σταθερό.

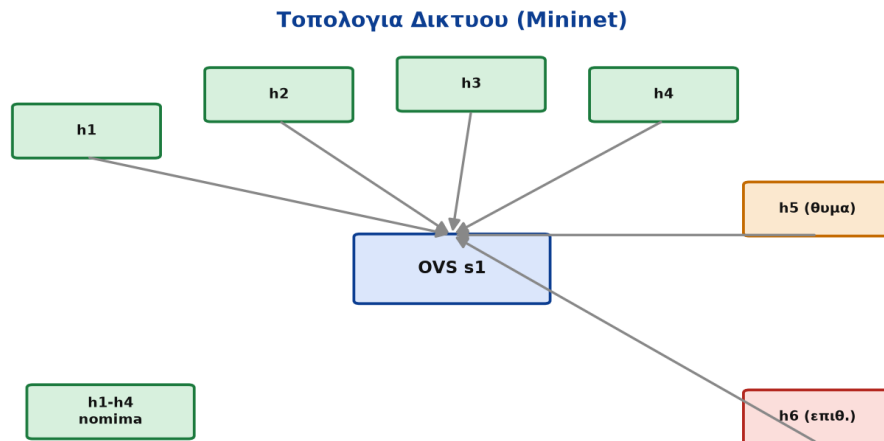
## 5.11 Σχηματική αναπαράσταση της αρχιτεκτονικής και του βρόχου ελέγχου

Η συνολική αρχιτεκτονική του συστήματος, με τα τέσσερα συνεργαζόμενα containers και τις μεταξύ τους ροές πληροφορίας, αποτυπώνεται στο ακόλουθο σχήμα. Ο ελεγκτής λαμβάνει τηλεμετρία, εκτελεί την ανίχνευση και επιστρέφει εντολές απόρριψης προς τον μεταγωγέα, ενώ το dashboard παρακολουθεί την κατάσταση σε πραγματικό χρόνο.



**Σχήμα 5-3: Σχηματική αναπαράσταση της αρχιτεκτονικής του συστήματος.**

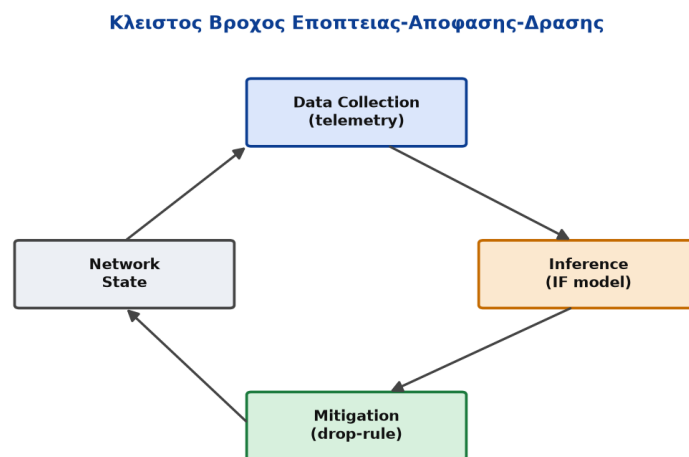
Η τοπολογία του προσομοιωμένου δικτύου αποτελείται από έξι hosts συνδεδεμένους σε έναν μεταγωγέα OVS. Οι τέσσερις πρώτοι (h1-h4) παράγουν νόμιμη κίνηση, ο h5 λειτουργεί ως θύμα και ο h6 ως επιτιθέμενος.



*Σχήμα 5-4: Τοπολογία του προσομοιωμένου δικτύου με έξι hosts.*

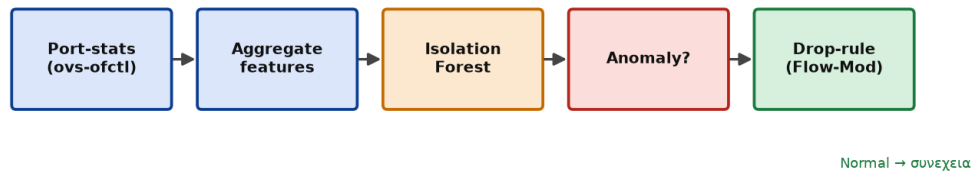
### Ο βρόχος ελέγχου (control loop) σε σχηματική μορφή

Η λειτουργία του συστήματος υλοποιεί έναν κλειστό βρόχο τεσσάρων σταδίων. Το ακόλουθο σχήμα αποτυπώνει τη διαδοχή Data Collection → Inference → Mitigation → ενημέρωση κατάστασης δικτύου, καθώς και τη ροή ανίχνευσης-αντιμετώπισης βήμα προς βήμα.



*Σχήμα 5-5: Ο κλειστός βρόχος εποπτείας-απόφασης-δράσης.*

## Ροή Ανίχνευσης και Αντιμετώπισης



Σχήμα 5-6: Η ροή ανίχνευσης και αντιμετώπισης βήμα προς βήμα.

### 5.12 Στρατηγική ελέγχου και συνεχής ενσωμάτωση

Η αξιοπιστία του συστήματος διασφαλίζεται μέσα από μια ολοκληρωμένη στρατηγική αυτοματοποιημένου ελέγχου. Το σύνολο των ελέγχων καλύπτει πολλαπλά επίπεδα: ελέγχους μονάδας για τη λογική της μηχανής ανίχνευσης, ελέγχους της REST διεπαφής του ελεγκτή, ελέγχους της υγείας των containers, ελέγχους παλινδρόμησης του μοντέλου (ώστε η ακρίβεια να μην υποβαθμίζεται σε νέες εκδόσεις), ελέγχους των ζωντανών σεναρίων και ελέγχους επικύρωσης ασφαλείας. Οι έλεγχοι αυτοί εκτελούνται αυτόματα σε κάθε αλλαγή του κώδικα μέσω μιας ροής συνεχούς ενσωμάτωσης (CI), η οποία επιβεβαιώνει ότι κάθε τροποποίηση διατηρεί την ακεραιότητα και την απόδοση του συστήματος.

Η επένδυση αυτή στην ποιότητα του λογισμικού, αν και συχνά παραβλέπεται σε ερευνητικά prototypes, είναι ουσιώδης για την αξιοπιστία των αποτελεσμάτων: διασφαλίζει ότι τα πειραματικά ευρήματα είναι αναπαραγώγιμα και ότι δεν οφείλονται σε παροδικά ή τυχαία σφάλματα. Επιπλέον, καθιστά το σύστημα κατάλληλη βάση για μελλοντική επέκταση, καθώς κάθε νέα προσθήκη ελέγχεται αυτόματα ως προς τη συμβατότητά της με την υπάρχουσα λειτουργικότητα.

### 5.13 Κύκλος ζωής πειράματος: μοντέλα και παραγωγή κίνησης

Ένα πρακτικό αλλά ουσιώδες ζήτημα είναι η διατήρηση της συνέπειας μεταξύ της φάσης εκπαίδευσης και της φάσης λειτουργίας. Τα εκπαιδευμένα μοντέλα, μαζί με τους μετασχηματιστές κανονικοποίησης και τους κωδικοποιητές ετικετών, αποθηκεύονται σειριοποιημένα και φορτώνονται κατά την εκκίνηση του ελεγκτή. Είναι κρίσιμο ο ίδιος μετασχηματιστής κανονικοποίησης που προσαρμόστηκε στα δεδομένα εκπαίδευσης να

χρησιμοποιείται και κατά την εξαγωγή συμπερασμάτων. Διαφορετικά, η κατανομή των χαρακτηριστικών κατά τη λειτουργία θα διέφερε από αυτή της εκπαίδευσης, υπονομεύοντας τις προβλέψεις. Η διασφάλιση αυτής της συνέπειας αποτελεί συχνά παραβλεπόμενη αλλά κρίσιμη λεπτομέρεια για την αξιόπιστη ανάπτυξη μοντέλων Μηχανικής Μάθησης σε παραγωγή.

### **Κύκλος ζωής ενός πειράματος**

Κάθε ζωντανό πείραμα ακολουθεί έναν καθορισμένο κύκλο ζωής. Αρχικά, ο ελεγκτής επαναφέρεται σε καθαρή κατάσταση μέσω του αντίστοιχου endpoint, ώστε τα αποτελέσματα να μην επηρεάζονται από προηγούμενες εκτελέσεις. Στη συνέχεια, στήνεται η τοπολογία και ξεκινά η φάση νόμιμης κίνησης, κατά την οποία επιβεβαιώνεται η απουσία ψευδώς θετικών. Ακολουθεί η φάση επίθεσης, όπου ενεργοποιείται ο μηχανισμός ανίχνευσης και αντιμετώπισης. Καθ' όλη τη διάρκεια, οι μετρήσεις καταγράφονται και εξάγονται σε αρχεία για μετέπειτα ανάλυση. Ο σαφής αυτός κύκλος ζωής εξασφαλίζει ότι κάθε πείραμα είναι απομονωμένο, επαναλήψιμο και συγκρίσιμο με τα υπόλοιπα.

### **Παραγωγή νόμιμης και κακόβουλης κίνησης**

Η αξιοπιστία της ζωντανής αξιολόγησης εξαρτάται από τον ρεαλισμό της παραγόμενης κίνησης. Για τη νόμιμη κίνηση χρησιμοποιήθηκαν τυπικά εργαλεία δικτύου που παράγουν ελεγχόμενα μοτίβα επικοινωνίας, ενώ για τις επιθέσεις αξιοποιήθηκαν πραγματικά εργαλεία, όπως το hping3 για την πλημμύρα SYN. Η χρήση πραγματικών εργαλείων επίθεσης, αντί για απλή προσομοίωση στατιστικών, είναι σημαντική: εξασφαλίζει ότι το σύστημα αξιολογείται έναντι της πραγματικής συμπεριφοράς των επιθέσεων στο επίπεδο των πακέτων, και όχι έναντι μιας εξιδανικευμένης εκδοχής τους. Έτσι, τα αποτελέσματα αντικατοπτρίζουν πιστότερα την αναμενόμενη απόδοση σε πραγματικές συνθήκες.

Ιδιαίτερη προσοχή δόθηκε στη ρύθμιση της νόμιμης κίνησης ώστε να είναι αντιπροσωπευτική και όχι τετριμμένη. Η επιλογή του πλήθους των πακέτων και του ρυθμού αποστολής έγινε ώστε η νόμιμη κίνηση να διαφοροποιείται σαφώς από τα μοτίβα των επιθέσεων, χωρίς όμως να είναι εξωπραγματικά «καθαρή». Αυτή η ισορροπία είναι που επέτρεψε την επίτευξη μηδενικών ψευδώς θετικών στο σενάριο αποκλειστικά νόμιμης κίνησης, χωρίς να καθιστά την ανίχνευση τετριμμένη.

## 6. Πειράματα και Αποτελέσματα

### 6.1 Πειραματική διάταξη

Τα πειράματα εκτελέστηκαν σε περιβάλλον Linux (WSL2) με ενορχήστρωση μέσω Docker. Η αξιολόγηση δεν είναι ενιαίου τύπου και η διάκριση των επιπέδων της είναι ουσιώδης για την ορθή ερμηνεία των αποτελεσμάτων. Η ζωντανή αξιολόγηση (Μέθοδος Α) περιλαμβάνει ένα πείραμα σε επίπεδο πακέτου, όπου πραγματικά πακέτα διασχίζουν τον μεταγωγέα OVS, και πειράματα συνθετικής τηλεμετρίας σε επίπεδο API, όπου κατασκευασμένα διανύσματα στατιστικών αποστέλλονται απευθείας στη διεπαφή του ελεγκτή. Επιπλέον, η επίθεση κορεσμού του control plane και οι αναλύσεις καθυστέρησης και αντιμετώπισης υλοποιούνται ως προσομοιώσεις. Η offline αξιολόγηση (Μέθοδος Β) πραγματοποιήθηκε επί του συνθετικού συνόλου των 20.500 ροών, με στρωματοποιημένο διαχωρισμό σε σύνολα εκπαίδευσης και ελέγχου, καθώς και επί του πραγματικού συνόλου InSDN. Ο ακόλουθος πίνακας αποσαφηνίζει τι τεκμηριώνει και τι δεν τεκμηριώνει κάθε τύπος πειράματος. Όλα τα αποτελέσματα είναι αναπαραγώγιμα μέσω των σεναρίων `run_all.sh` (offline) και `run_live_experiments.sh` (ζωντανά).

| Τύπος πειράματος                  | Υλοποίηση                                                                                                   | Τι τεκμηριώνει                                                     | Τι ΔΕΝ τεκμηριώνει                                                                                |
|-----------------------------------|-------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------|---------------------------------------------------------------------------------------------------|
| <b>Offline αξιολόγηση ML</b>      | ml_pipeline/, συνθετικό σύνολο και InSDN (δομή CICFlowMeter)                                                | Τη συγκριτική ικανότητα ταξινόμησης οκτώ μοντέλων σε δεδομένα ροών | Λειτουργία σε πραγματικό χρόνο. Γενίκευση σε κίνηση παραγωγής, λόγω των διπλότυπων ροών του InSDN |
| <b>Πείραμα σε επίπεδο πακέτου</b> | simulation/mininet_live.py: επίθεση με hping3, τηλεμετρία μέσω ovs-ofctl dump-flows, κανόνας απόρριψης στον | Ότι ο βρόχος τηλεμετρίας, ανίχνευσης                               | Τα υπόλοιπα πέντε σενάρια. Πλήρη                                                                  |

|                                                        |                                                                                                 |                                                                                                              |                                                                                                  |
|--------------------------------------------------------|-------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------|
|                                                        | OVS                                                                                             | και επιβολής λειτουργεί end-to-end με πραγματικά πακέτα (σενάριο πλημμύρας SYN)                              | reactive σημασιολογία OpenFlow με Packet-In/Flow-Mod ανά ροή                                     |
| <b>Πειράματα συνθετικής τηλεμετρίας σε επίπεδο API</b> | run_live_experiments.sh: κατασκευασμένα διανύσματα στατιστικών προς τη διεπαφή /telemetry       | Τη συμπεριφορά της μηχανής απόφασης και του μηχανισμού απόκρισης υπό ελεγχόμενα προφίλ ροών                  | Ότι τα ίδια πρότυπα θα προκύψουν από πραγματική κίνηση. Ανάλυση σε επίπεδο πρωτοκόλλου, π.χ. ARP |
| <b>Προσομοίωση διακριτών γεγονότων</b>                 | simulation/control_plane_saturation.py, ml_pipeline/latency_analysis.py, mitigation_analysis.py | Τη δυναμική του κορεσμού του control plane και τη συμπεριφορά της μηχανής απόφασης υπό διαφορετικές εντάσεις | Μετρήσεις σε πραγματικό ελεγκτή OpenFlow ή σε φυσικό δίκτυο                                      |

*Πίνακας 6-1: Τύποι πειραμάτων και το εύρος των συμπερασμάτων που επιτρέπουν.*

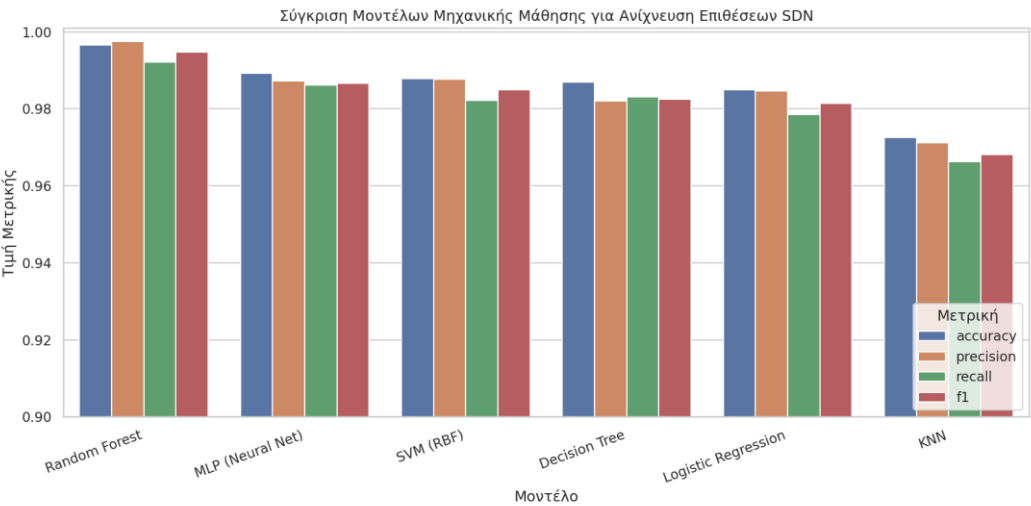
## 6.2 Σύγκριση κλασικών μοντέλων Μηχανικής Μάθησης

Το πρώτο πείραμα συγκρίνει τα έξι κλασικά μοντέλα ως προς τις τέσσερις βασικές μετρικές ταξινόμησης. Ο Πίνακας που ακολουθεί συνοψίζει τα αποτελέσματα στο

συνθετικό σύνολο. Το Random Forest επιτυγχάνει την υψηλότερη επίδοση σε όλες τις μετρικές, με F1-score άνω του 0,999, ενώ διατηρεί και τον ταχύτερο χρόνο πρόβλεψης μεταξύ των ισχυρών μοντέλων.

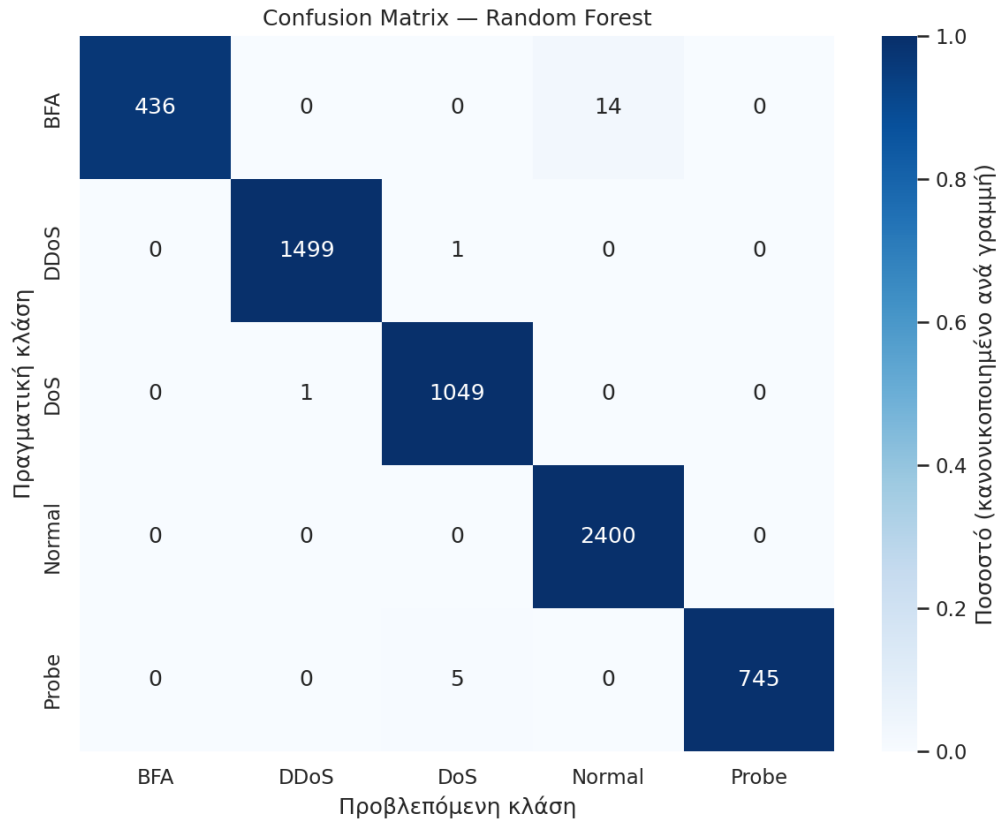
| Μοντέλο             | Accuracy | Precision | Recall | F1     |
|---------------------|----------|-----------|--------|--------|
| Random Forest       | 0,9998   | 0,9999    | 0,9998 | 0,9998 |
| MLP (Neural Net)    | 0,9974   | 0,9974    | 0,9974 | 0,9974 |
| SVM (RBF)           | 0,9969   | 0,9971    | 0,9966 | 0,9969 |
| Decision Tree       | 0,9958   | 0,9956    | 0,9943 | 0,9949 |
| Logistic Regression | 0,9953   | 0,9950    | 0,9952 | 0,9951 |
| KNN                 | 0,9893   | 0,9891    | 0,9882 | 0,9885 |

**Πίνακας 6-2: Σύγκριση κλασικών μοντέλων στο συνθετικό σύνολο (24 χαρακτηριστικά).**



**Σχήμα 6-1: Σύγκριση κλασικών μοντέλων Μηχανικής Μάθησης ως προς τις τέσσερις βασικές μετρικές.**

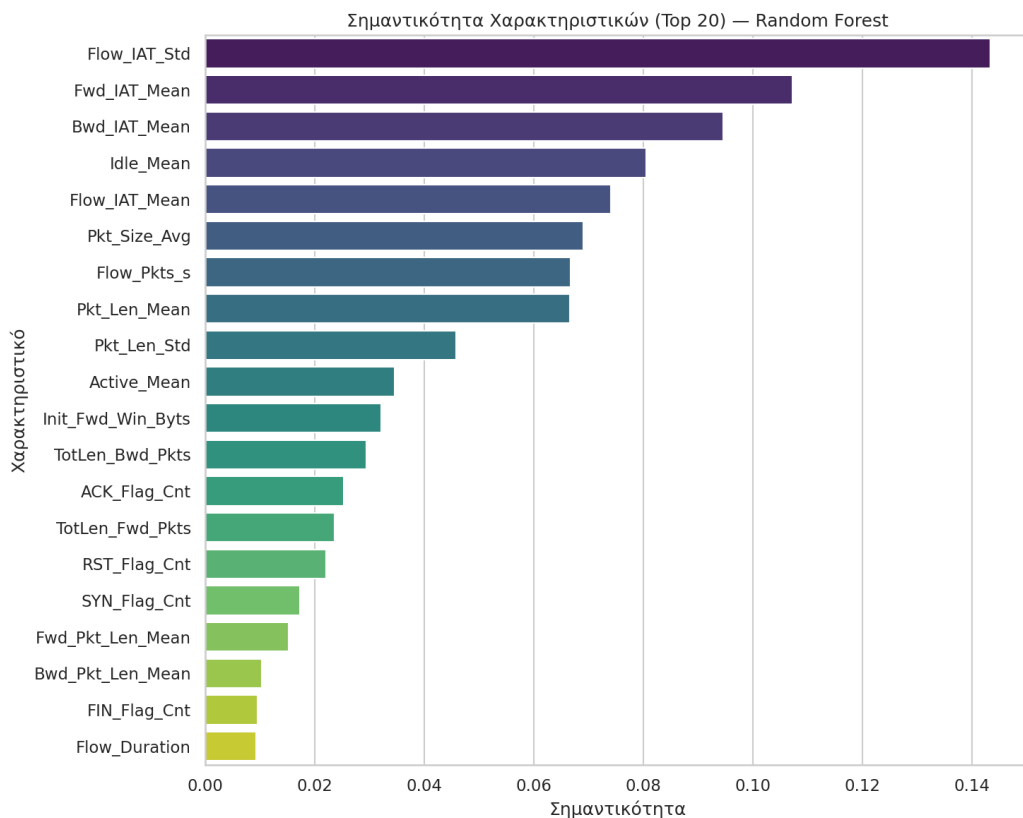
Ο πίνακας σύγχυσης (confusion matrix) του καλύτερου μοντέλου δείχνει ότι οι λανθασμένες ταξινομήσεις είναι ελάχιστες και εντοπίζονται κυρίως μεταξύ των κατηγοριών DoS και DDoS, οι οποίες παρουσιάζουν φυσική στατιστική ομοιότητα (και οι δύο είναι επιθέσεις πλημμύρας).



Σχήμα 6-2: Πίνακας σύγχυσης του βέλτιστου κλασικού μοντέλου (Random Forest).

### 6.3 Σημαντικότητα χαρακτηριστικών και ερμηνευσιμότητα (SHAP)

Η ανάλυση σημαντικότητας αποκαλύπτει ποια χαρακτηριστικά ροής συνεισφέρουν περισσότερο στη διάκριση των επιθέσεων. Χαρακτηριστικά όπως ο ρυθμός πακέτων ανά δευτερόλεπτο, οι χρόνοι μεταξύ αφίξεων και το πλήθος των σημαιών TCP είναι ιδιαίτερα διακριτικά για τις επιθέσεις πλημμύρας.



Σχήμα 6-3: Σημαντικότητα των σημαντικότερων χαρακτηριστικών κατά το Random Forest.

### Ανάλυση ερμηνευσιμότητας με SHAP

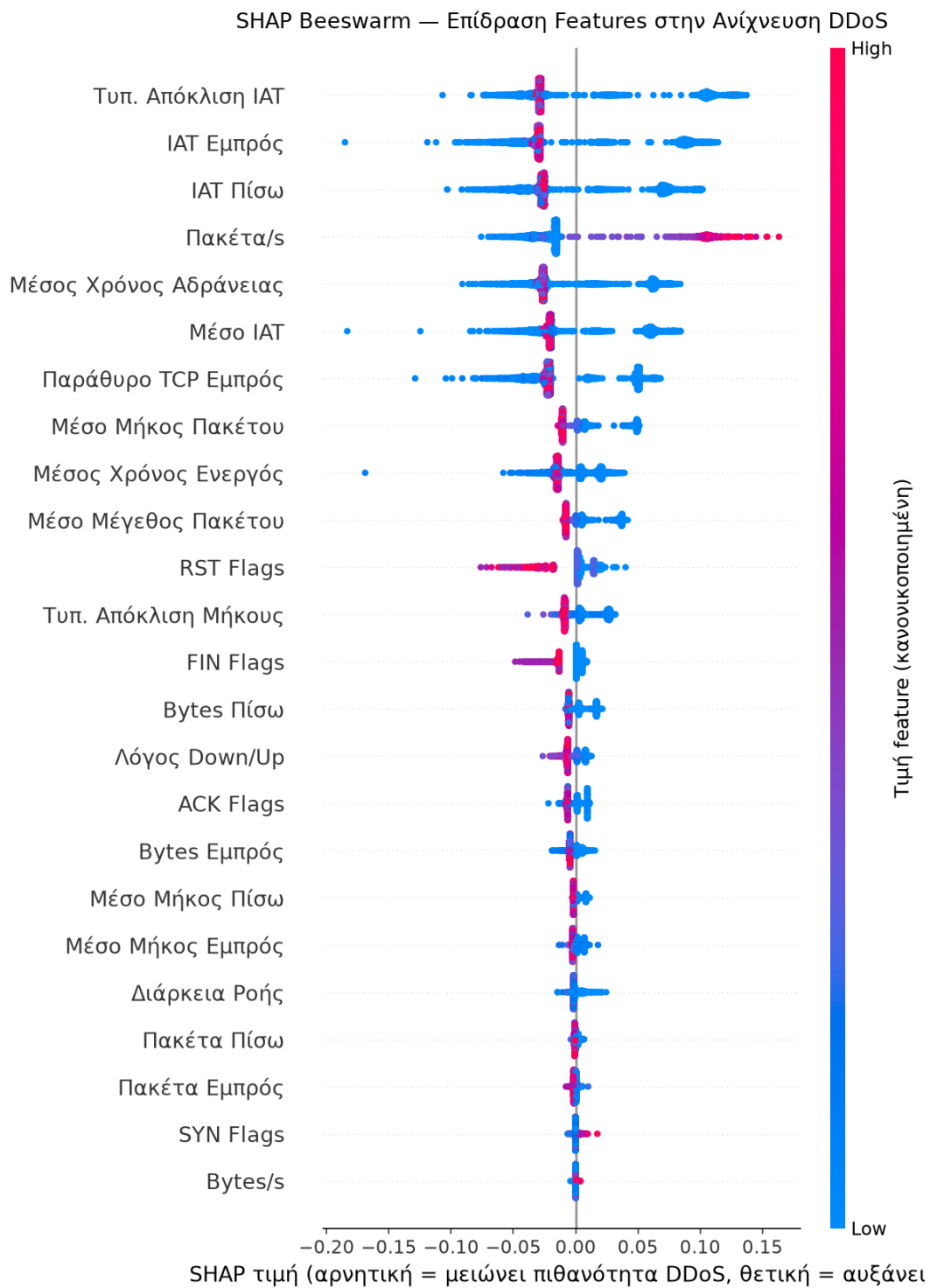
Τα μοντέλα Μηχανικής Μάθησης, παρά την υψηλή ακρίβειά τους, λειτουργούν συχνά ως «μαύρα κουτιά». Στην κυβερνοασφάλεια αυτό είναι προβληματικό, καθώς ο αναλυτής χρειάζεται να κατανοήσει γιατί μια ροή χαρακτηρίστηκε κακόβουλη πριν λάβει αμυντικές αποφάσεις. Το SHAP (SHapley Additive exPlanations) [14] κατανέμει τη συνεισφορά κάθε χαρακτηριστικού στην τελική πρόβλεψη, αξιοποιώντας τις Shapley Values από τη θεωρία παιγνίων. Χρησιμοποιήθηκαν 2.000 στρωματοποιημένα δείγματα, με υπολογισμό τιμών SHAP για πέντε κλάσεις και 24 χαρακτηριστικά.

Ο ακόλουθος πίνακας παρουσιάζει τα πέντε σημαντικότερα χαρακτηριστικά (global, μέση απόλυτη τιμή SHAP). Τα ευρήματα είναι ερμηνεύσιμα από δικτυακή σκοπιά: η τυπική απόκλιση των χρόνων μεταξύ αφίξεων και ο ρυθμός πακέτων αναδεικνύονται ως τα πλέον διαγνωστικά για τις επιθέσεις πλημμύρας.

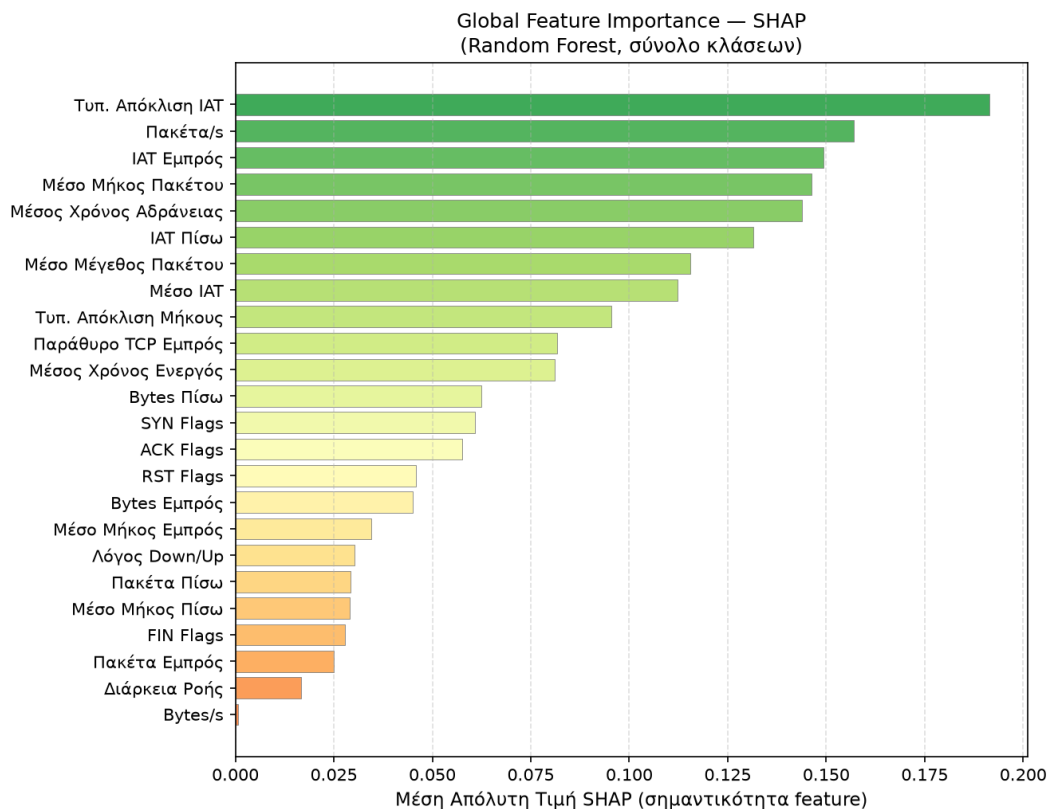
| # | Χαρακτηριστικό    | Μέση<br> SHAP | Δικτυακή ερμηνεία                                    |
|---|-------------------|---------------|------------------------------------------------------|
| 1 | Τυπ. Απόκλιση IAT | 0,192         | Ανωμαλία στους χρόνους άφιξης, χαρακτηριστικό flood. |

|   |                        |       |                                                            |
|---|------------------------|-------|------------------------------------------------------------|
| 2 | Πακέτα/s               | 0,157 | Υψηλός ρυθμός = DDoS/DoS, χαμηλός = σάρωση.                |
| 3 | IAT Εμπρός             | 0,149 | Σχεδόν μηδενικό IAT = burst επίθεση.                       |
| 4 | Μέσο Μήκος Πακέτου     | 0,146 | Μικρά πακέτα = SYN flood, μεγάλα = εκτεταμένη επικοινωνία. |
| 5 | Μέσος Χρόνος Αδράνειας | 0,144 | Ξεχωρίζει σάρωση από πλημμύρα.                             |

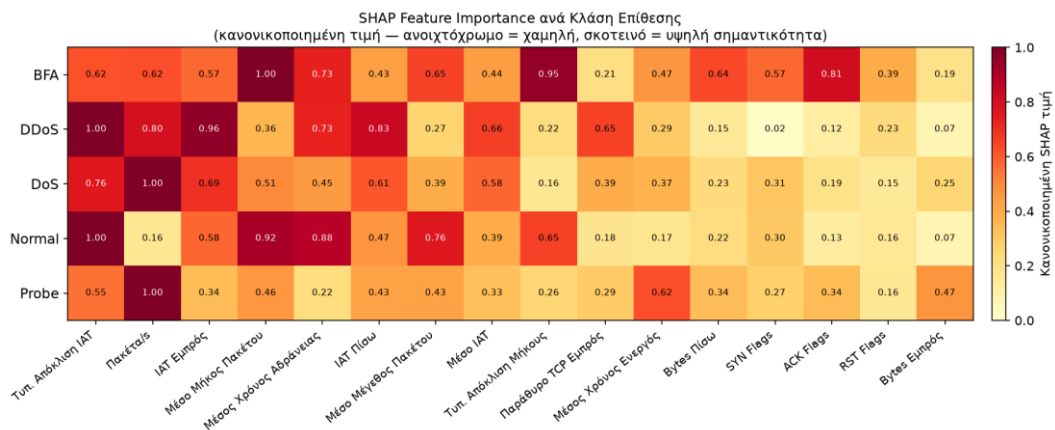
**Πίνακας 6-3: Τα πέντε σημαντικότερα χαρακτηριστικά κατά την ανάλυση SHAP.**



Σχήμα 6-4: Διάγραμμα SHAP (beeswarm), κατεύθυνση και μέγεθος επίδρασης ανά χαρακτηριστικό.



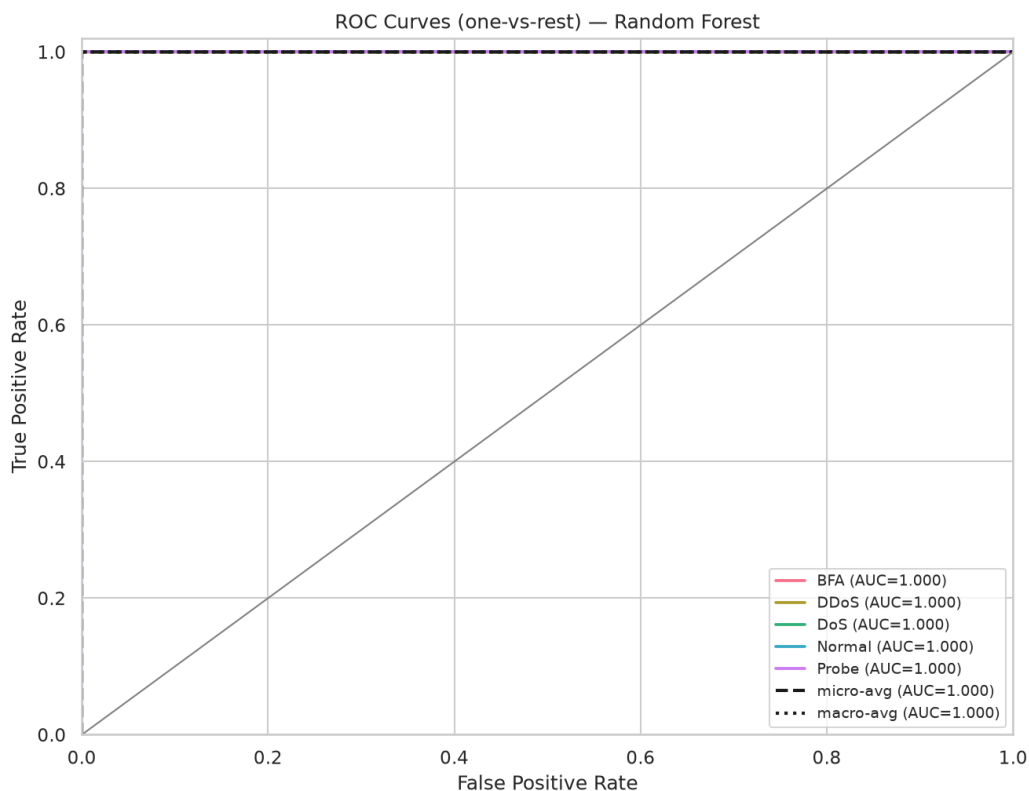
Σχήμα 6-5: Global σημαντικότητα χαρακτηριστικών κατά SHAP (μέση απόλυτη τιμή).



Σχήμα 6-6: Θερμικός χάρτης SHAP: ποια χαρακτηριστικά ανιχνεύουν ποια κατηγορία επίθεσης.

## 6.4 Καμπύλες ROC και διασταυρούμενη επικύρωση

Οι καμπύλες ROC (one-vs-rest) επιβεβαιώνουν την ικανότητα διάκρισης του μοντέλου ανά κατηγορία, με τιμές AUC πολύ κοντά στη μονάδα για όλες τις κλάσεις, γεγονός που υποδηλώνει σαφή διαχωρισμό μεταξύ νόμιμης και κακόβουλης κίνησης σε όλο το φάσμα κατωφλίων.



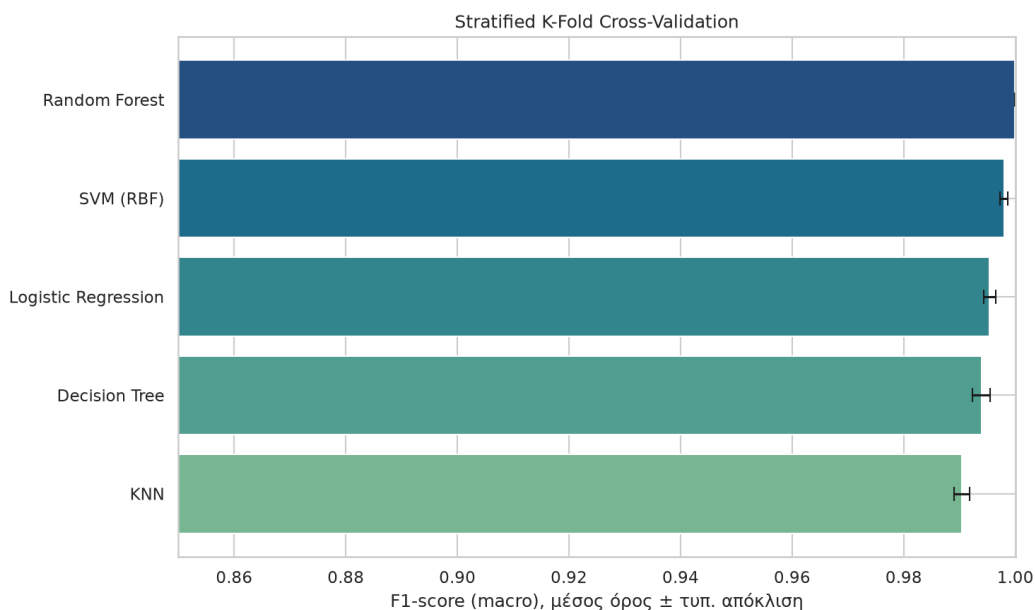
Σχήμα 6-7: Καμπύλες ROC ανά κατηγορία επίθεσης (one-vs-rest).

#### Διασταυρούμενη επικύρωση

Για να αποδειχθεί ότι τα αποτελέσματα είναι σταθερά και όχι προϊόν τυχαίου διαχωρισμού, εφαρμόστηκε διασταυρούμενη επικύρωση πέντε διπλώσεων (5-fold). Οι μικρές τυπικές αποκλίσεις επιβεβαιώνουν τη σταθερότητα, με το Random Forest να παραμένει σταθερά πρώτο και με το στενότερο εύρος διακύμανσης.

| Μοντέλο             | F1 (μέσος) | Τυπ. Απόκλιση | F1 (ελάχισ.) | F1 (μέγ.) |
|---------------------|------------|---------------|--------------|-----------|
| Random Forest       | 0,99995    | 0,00010       | 0,99976      | 1,00000   |
| SVM (RBF)           | 0,99795    | 0,00066       | 0,99678      | 0,99878   |
| Logistic Regression | 0,99538    | 0,00110       | 0,99344      | 0,99653   |
| Decision Tree       | 0,99390    | 0,00159       | 0,99128      | 0,99558   |
| KNN                 | 0,99041    | 0,00140       | 0,98873      | 0,99283   |

Πίνακας 6-4: Διασταυρούμενη επικύρωση 5-fold (F1-score).



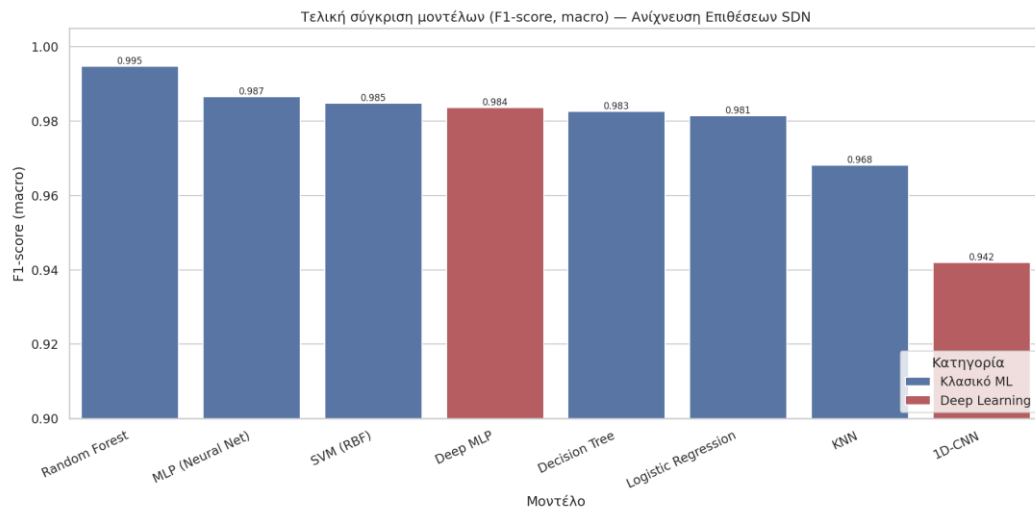
Σχήμα 6-8: Διασταυρούμενη επικύρωση 5-fold: F1-score (μέσος ± τυπική απόκλιση).

## 6.5 Σύγκριση με μοντέλα Βαθιάς Μάθησης

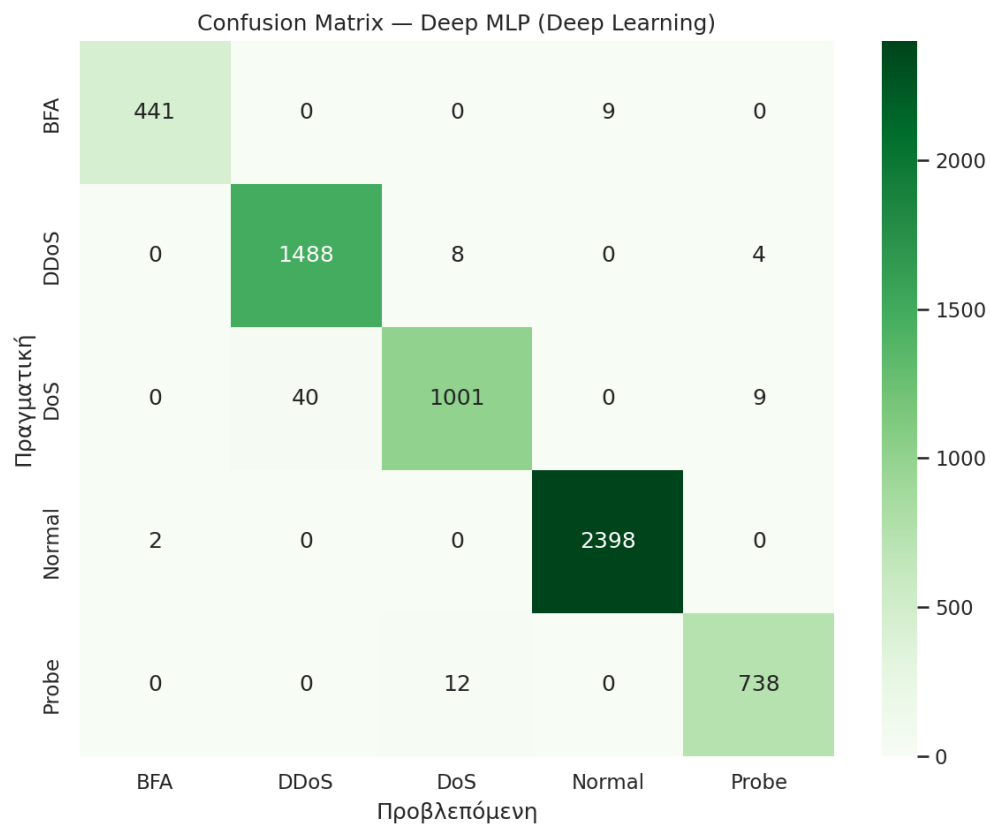
Η δεύτερη εκδοχή του pipeline περιλαμβάνει δύο μοντέλα Βαθιάς Μάθησης: ένα βαθύ MLP και ένα μονοδιάστατο συνελκτικό δίκτυο (1D-CNN). Η συγκεντρωτική σύγκριση και των οκτώ μοντέλων δείχνει ότι τα κλασικά μοντέλα συνόλου, και ιδιαίτερα το Random Forest, υπερτερούν των μοντέλων Βαθιάς Μάθησης σε αυτού του τύπου τα δομημένα (tabular) δεδομένα. Το εύρημα αυτό συμφωνεί με την ευρύτερη βιβλιογραφία [15], σύμφωνα με την οποία τα gradient-boosted και ensemble δέντρα παραμένουν ανταγωνιστικά ή ανώτερα σε πίνακες χαρακτηριστικών, όπου η βαθιά μάθηση δεν αξιοποιεί χωρική ή χρονική δομή.

| Μοντέλο  | Accuracy | F1     | Χρόνος εκπ. (s) | Τύπος         |
|----------|----------|--------|-----------------|---------------|
| Deep MLP | 0,9863   | 0,9836 | 18,33           | Deep Learning |
| 1D-CNN   | 0,9511   | 0,9420 | 11,42           | Deep Learning |

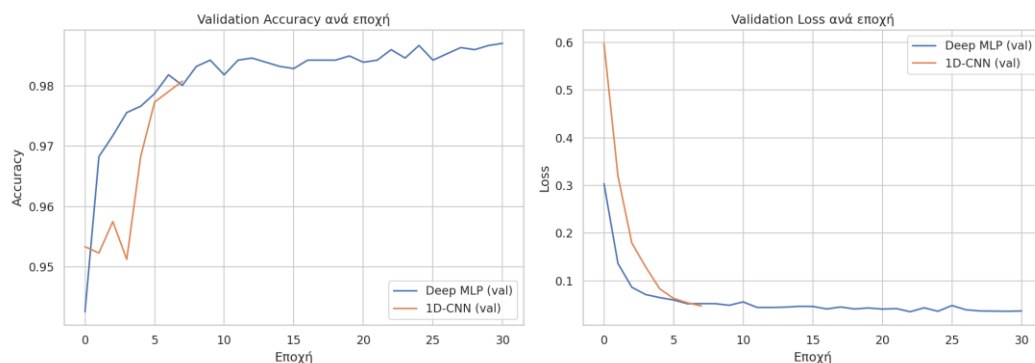
Πίνακας 6-5: Απόδοση των μοντέλων Βαθιάς Μάθησης στο συνθετικό σύνολο.



**Σχήμα 6-9: Συνολική σύγκριση και των οκτώ μοντέλων (κλασικά και βαθιάς μάθησης).**



**Σχήμα 6-10: Πίνακας σύγκρισης του μοντέλου Deep MLP.**



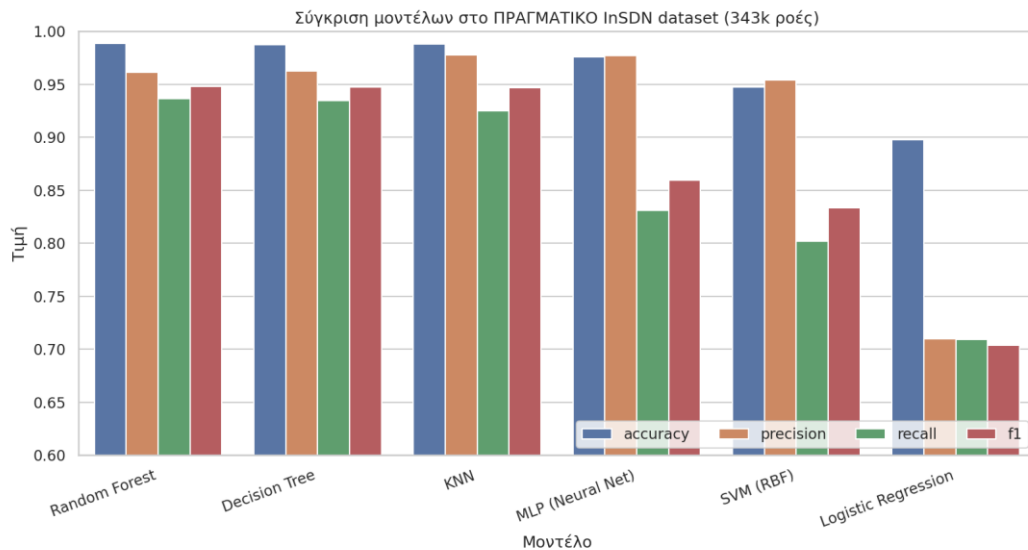
**Σχήμα 6-11: Ιστορικό εκπαίδευσης των μοντέλων Βαθιάς Μάθησης (loss/accuracy ανά εποχή).**

## 6.6 Αξιολόγηση στο πραγματικό σύνολο InSDN

Πέραν του συνθετικού συνόλου, τα μοντέλα αξιολογήθηκαν και στο πραγματικό σύνολο InSDN. Το υψηλότερο μακρο-F1 επιτυγχάνεται οριακά από τον KNN (0,952), με το Random Forest να ακολουθεί (0,945). Το Random Forest όμως συνδυάζει την υψηλότερη ορθότητα (0,9899) με χρόνο πρόβλεψης δύο τάξεις μεγέθους μικρότερο από τον KNN (0,08 s έναντι 11,9 s στο σύνολο ελέγχου), γεγονός που το καθιστά την πρακτικά προτιμότερη επιλογή για ανάπτυξη σε ελεγκτή SDN. Η πτώση των γραμμικών μοντέλων (Logistic Regression) είναι εμφανώς μεγαλύτερη, γεγονός που αναδεικνύει την ανάγκη για μη γραμμικά μοντέλα σε πραγματικά δεδομένα. Τα αποτελέσματα αυτά ερμηνεύονται ως ενδεικτική αξιολόγηση της συμβατότητας του pipeline με πραγματικά δεδομένα ροών και όχι ως αυστηρή απόδειξη γενίκευσης: όπως τεκμηριώνεται στη συνέχεια, η υψηλή παρουσία διπλότυπων ροών σε συνδυασμό με τυχαίο διαχωρισμό ευνοεί την απομνημόνευση και ανεβάζει τεχνητά τις μετρικές.

| Μοντέλο             | Accuracy | Precision | Recall | F1     |
|---------------------|----------|-----------|--------|--------|
| KNN                 | 0,9898   | 0,9791    | 0,9324 | 0,9523 |
| Random Forest       | 0,9899   | 0,9614    | 0,9309 | 0,9446 |
| Decision Tree       | 0,9893   | 0,9520    | 0,9358 | 0,9435 |
| MLP (Neural Net)    | 0,9740   | 0,9690    | 0,9049 | 0,9306 |
| SVM (RBF)           | 0,9386   | 0,9407    | 0,8076 | 0,8322 |
| Logistic Regression | 0,9107   | 0,8254    | 0,7310 | 0,7289 |

**Πίνακας 6-6: Σύγκριση μοντέλων στο πραγματικό σύνολο InSDN.**



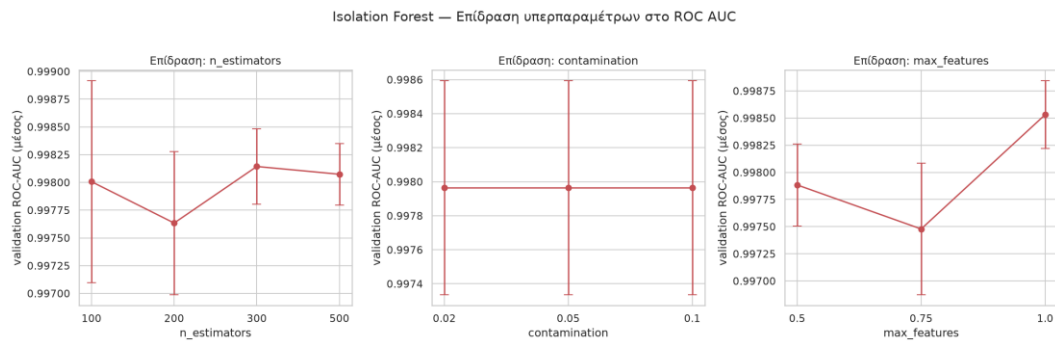
Σχήμα 6-12: Σύγκριση μοντέλων στο πραγματικό σύνολο δεδομένων InSDN.

## 6.7 Αξιολόγηση και ρύθμιση του Isolation Forest

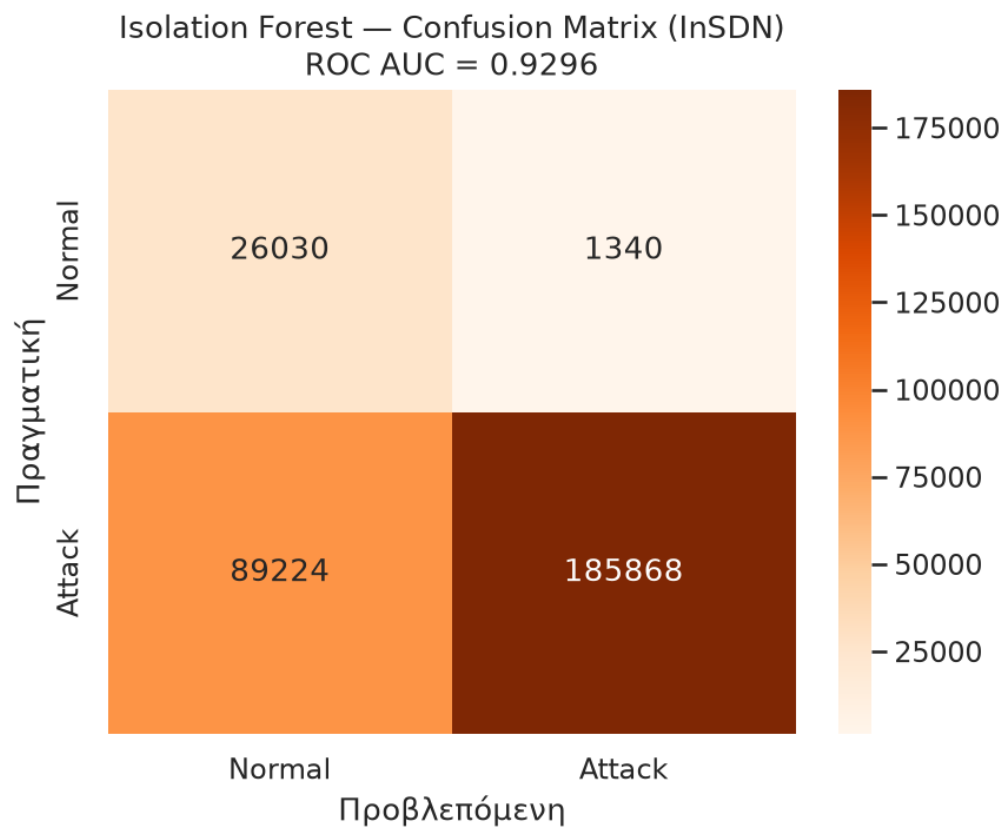
Το ζωντανό σύστημα βασίζεται στον Isolation Forest, ο οποίος αξιολογήθηκε σε δύο σύνολα με πολύ διαφορετική δυσκολία, όπως συνοψίζει ο ακόλουθος πίνακας. Στο συνθετικό σύνολο, όπου οι κλάσεις έχουν καθαρές υπογραφές, επιτυγχάνει precision 0,987, recall 0,999 και ROC-AUC 0,998. Στο πραγματικό InSDN η εικόνα είναι ουσιαστικά διαφορετική: το precision παραμένει υψηλό (0,993), αλλά το recall πέφτει στο 0,676 και το F1 στο 0,804, με ROC-AUC 0,930. Η πτώση του recall σημαίνει ότι, στα ρεαλιστικά δεδομένα, ο μη επιβλεπόμενος ανιχνευτής αφήνει να διαφύγει περίπου το ένα τρίτο των επιθέσεων. Οι τιμές του συνθετικού συνόλου δεν πρέπει επομένως να θεωρηθούν αντιπροσωπευτικές της πραγματικής απόδοσης. Αντιπροσωπευτικές είναι οι τιμές του InSDN.

| Μετρική          | Συνθετικό (καθαρές υπογραφές) | InSDN (πραγματικό) |
|------------------|-------------------------------|--------------------|
| <b>Precision</b> | 0,987                         | 0,993              |
| <b>Recall</b>    | 0,999                         | 0,676              |
| <b>F1-score</b>  | 0,993                         | 0,804              |
| <b>ROC-AUC</b>   | 0,998                         | 0,930              |

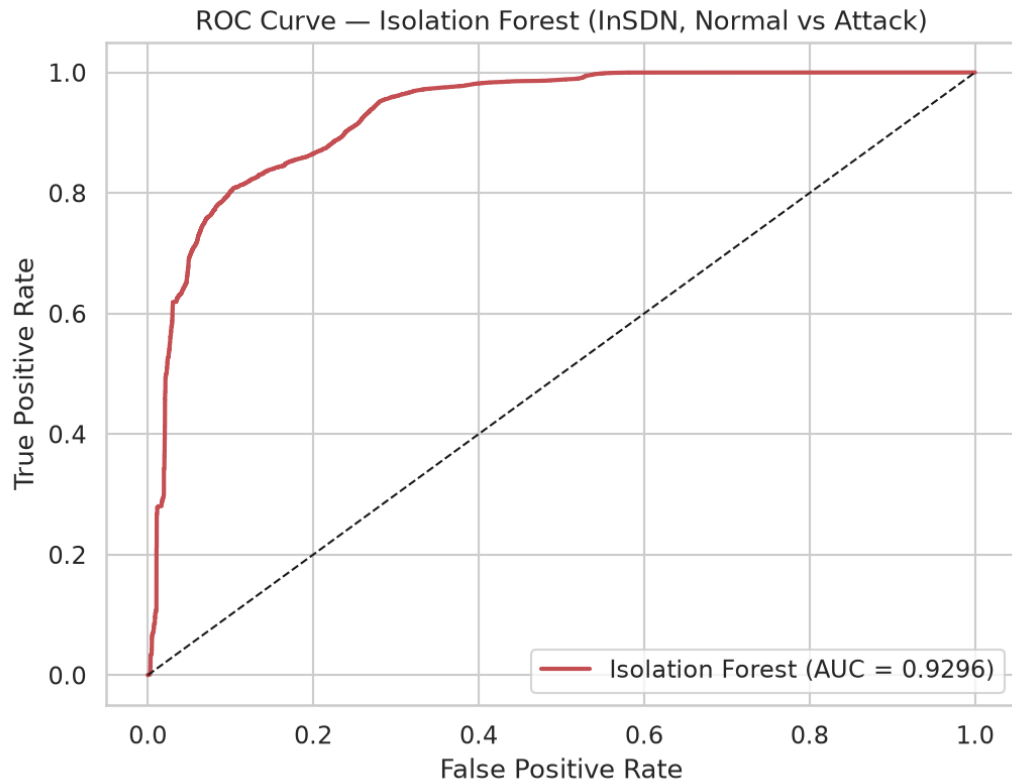
Πίνακας 6-7: Μετρικές του Isolation Forest.



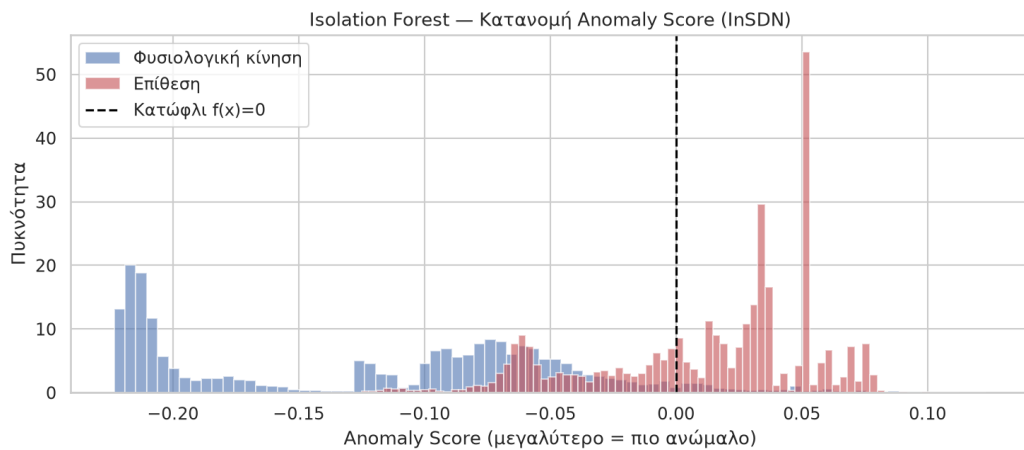
Σχήμα 6-13: Ρύθμιση υπερπαραμέτρων του Isolation Forest (ROC-AUC και F1 ανά συνδυασμό).



Σχήμα 6-14: Πίνακας σύγχυσης του Isolation Forest.



**Σχήμα 6-15: Καμπύλη ROC του Isolation Forest.**



**Σχήμα 6-16: Κατανομή anomaly scores του Isolation Forest για νόμιμη και κακόβουλη κίνηση.**

Έχοντας τεκμηριώσει την ακρίβεια της ταξινόμησης στις ενότητες 6.2 έως 6.7, οι επόμενες ενότητες μεταβαίνουν από το «πόσο ακριβές είναι το μοντέλο» στο «πόσο χρήσιμο και αξιόπιστο είναι σε πραγματικές συνθήκες», εξετάζοντας διαδοχικά την ερμηνευσιμότητα, τα ζωντανά σενάρια, την καθυστέρηση, την αντιμετώπιση και την ανθεκτικότητα.

## **Ρύθμιση υπερπαραμέτρων του Isolation Forest**

Η ρύθμιση των υπερπαραμέτρων του Isolation Forest διερευνήθηκε συστηματικά με εξαντλητική αναζήτηση στους 108 συνδυασμούς του πλέγματος. Η επιλογή της διαμόρφωσης έγινε σε ανεξάρτητο σύνολο επικύρωσης (validation set) και η τελική τιμή μετρήθηκε μία φορά σε ξεχωριστό σύνολο ελέγχου. Το κεντρικό εύρημα είναι ότι το ROC-AUC επικύρωσης παραμένει υψηλό (άνω του 0,99) σε ένα ευρύ φάσμα συνδυασμών, με τη βέλτιστη διαμόρφωση να επιτυγχάνει ROC-AUC 0,999 στο ανεξάρτητο σύνολο ελέγχου, γεγονός που υποδηλώνει ευρωστία του αλγορίθμου ως προς την επιλογή παραμέτρων. Ο πλήρης πίνακας με τους κορυφαίους συνδυασμούς, ταξινομημένους κατά το ROC-AUC επικύρωσης, παρατίθεται στο Παράρτημα Β ώστε να μην επιβαρύνει τη ροή του κειμένου.

## **Ανάλυση ευαισθησίας υπερπαραμέτρων**

Η ευρωστία του Isolation Forest ως προς τις υπερπαραμέτρους εξετάστηκε συστηματικά. Δοκιμάστηκαν συνδυασμοί του πλήθους δέντρων, του μεγέθους δείγματος ανά δέντρο, του βαθμού μόλυνσης (contamination) και του ποσοστού χαρακτηριστικών. Το κρίσιμο εύρημα είναι ότι το ROC-AUC παραμένει σταθερά υψηλό (άνω του 0,99) σε ένα ευρύ φάσμα συνδυασμών, γεγονός που υποδηλώνει ότι η απόδοση δεν εξαρτάται κρίσιμα από μια λεπτομερή ρύθμιση. Η σταθερότητα αυτή είναι επιθυμητή σε ένα πρακτικό σύστημα, καθώς μειώνει τον κίνδυνο υποβάθμισης της απόδοσης λόγω μεταβολών στις συνθήκες λειτουργίας ή στη φύση της κίνησης.

## **6.8 Ζωντανά σενάρια επίθεσης και αντιμετώπισης**

Το ζωντανό σκέλος της αξιολόγησης περιλαμβάνει δύο διακριτούς τύπους πειραμάτων. Το σενάριο της πλημμύρας SYN εκτελείται σε επίπεδο πακέτου μέσα σε τοπολογία Mininet/Open vSwitch: η επίθεση παράγεται με το εργαλείο hping3, η τηλεμετρία συλλέγεται από τα per-flow στατιστικά του πίνακα ροών (ovs-ofctl dump-flows) και ο κανόνας απόρριψης εγκαθίσταται στον ίδιο τον μεταγωγέα. Τα υπόλοιπα πέντε σενάρια εκτελούνται ως πειράματα συνθετικής τηλεμετρίας σε επίπεδο API: κατασκευασμένα διανύσματα στατιστικών ροών αποστέλλονται απευθείας στη διεπαφή /telemetry του ελεγκτή, ώστε να αναπαρασταθεί το στατιστικό αποτύπωμα κάθε επίθεσης χωρίς παραγωγή πραγματικών πακέτων. Τα δεύτερα τεκμηριώνουν τη συμπεριφορά της μηχανής απόφασης και του μηχανισμού απόκρισης υπό ελεγχόμενα προφίλ ροών, δεν αποδεικνύουν όμως ότι τα ίδια πρότυπα θα προκύψουν αυτούσια από πραγματική κίνηση.

Σε κάθε σενάριο, μια φάση νόμιμης κίνησης ακολουθείται από φάση επίθεσης. Ο ακόλουθος πίνακας συνοψίζει τα μετρημένα αποτελέσματα.

| Σενάριο                            | Καθυστ. ανίχνευσης | Μπλοκ | Ψευδώς θετικά |
|------------------------------------|--------------------|-------|---------------|
| DDoS / SYN Flood                   | 1,16 s             | Ναι   | 0             |
| Σάρωση θυρών (Port Scan)           | 0,24 s             | Ναι   | 0             |
| Εξαγωγή δεδομένων (Exfiltration)   | 0,71 s             | Ναι   | 4*            |
| Εξάντληση πίνακα ροών              | 0,14 s             | Ναι   | 0             |
| Πλευρική κίνηση (Lateral Movement) | 0,31 s             | Ναι   | 1*            |
| ARP Spoof / MITM                   | -                  | Ναι   | 0             |
| Μόνο νόμιμη κίνηση (έλεγχος FP)    | -                  | -     | 0 / 4 (0%)    |

*Πίνακας 6-8: Πειραματικές μετρήσεις ανά προφίλ αξιολόγησης (packet-level και API-level σενάρια).*

Τα αποτελέσματα δεν είναι ομοιόμορφα και δεν πρέπει να παρουσιαστούν ως ενιαία επιτυχία. Σε τρία σενάρια, την πλημμύρα SYN, τη σάρωση θυρών και την εξάντληση του πίνακα ροών, η απόκριση ήταν καθαρή: ο επιτιθέμενος εντοπίστηκε σε λιγότερο από ένα δευτερόλεπτο και δεν καταγράφηκε κανένα ψευδώς θετικό. Στα υπόλοιπα τρία αναδείχθηκαν ουσιώδεις περιορισμοί. Στην εξαγωγή δεδομένων ο επιτιθέμενος μπλοκαρίστηκε, αλλά μαζί του αποκλείστηκαν και οι τέσσερις νόμιμοι hosts του σεναρίου, δηλαδή το σύστημα προκάλεσε άρνηση εξυπηρέτησης στους ίδιους τους χρήστες που όφειλε να προστατεύσει. Στην πλευρική κίνηση καταγράφηκε ένα ψευδώς θετικό έναντι μίας μόνο ορθής ανίχνευσης. Στο ARP spoofing το σύστημα δεν παρήγαγε καμία ορθή ανίχνευση της πλαστογράφησης (μηδέν αληθώς θετικά, δύο ψευδώς αρνητικά (false negatives)) και ο τελικός αποκλεισμός του επιτιθέμενου προέκυψε από τη συνοδευτική στατιστική δραστηριότητα, όχι από αναγνώριση της επίθεσης. Τα ευρήματα αυτά οριοθετούν το πεδίο εφαρμογής: η προσέγγιση είναι αποτελεσματική σε επιθέσεις με έντονο στατιστικό αποτύπωμα στον όγκο ή στο πλήθος των ροών, ενώ υστερεί όταν η επίθεση είναι πρωτοκολλικής φύσης ή όταν η νόμιμη κίνηση είναι από μόνη της στατιστικά ακραία.

#### **Αναλυτική περιγραφή των ζωντανών σεναρίων**

Η ενότητα αυτή περιγράφει αναλυτικά καθένα από τα έξι ζωντανά σενάρια που συνοψίστηκαν ανωτέρω, παραθέτοντας τις επιμέρους μετρήσεις και την ερμηνεία τους.

### 6.8.1 DDoS / SYN Flood

Το σενάριο της πλημμύρας SYN είναι το μόνο που εκτελείται σε επίπεδο πακέτου. Η πραγματική, end-to-end εκτέλεση γίνεται μέσα σε τοπολογία Mininet/Open vSwitch, ανεβασμένη μέσω docker compose: ο επιτιθέμενος host 10.0.0.6 εξαπολύει πραγματική πλημμύρα SYN κατά του θύματος 10.0.0.5 με το εργαλείο hping3, η τηλεμετρία συλλέγεται από τα στατιστικά του πίνακα ροών (ovs-ofctl dump-flows) και ο κανόνας απόρριψης εγκαθίσταται στον ίδιο τον μεταγωγέα. Σε καταγεγραμμένη τέτοια εκτέλεση (φάκελος results/live/mininet\_run\_validated\_\*) ο επιτιθέμενος παρήγαγε δεκάδες χιλιάδες πακέτα ανά παράθυρο και εντοπίστηκε εντός του πρώτου παραθύρου παρατήρησης. Κρίσιμο για την τεκμηρίωση της αντιμετώπισης είναι ότι ο κανόνας απόρριψης δεν απλώς εγκαταστάθηκε, αλλά έκοψε πραγματικά πακέτα στο επίπεδο δεδομένων: ο μετρητής `n_packets` του κανόνα DROP στον πίνακα ροών του OVS επιβεβαίωσε πραγματικά απορριφθέντα πακέτα, ενώ στα νόμιμα παράθυρα κίνησης δεν καταγράφηκε κανένα ψευδώς θετικό. Κάθε κανόνας φέρει πεπερασμένο lease (`hard_timeout` συγχρονισμένο με το TTL του ελεγκτή). Όσο η επίθεση συνεχίζεται το lease ανανεώνεται αυτόματα, ώστε η απόρριψη να καλύπτει ολόκληρη τη διάρκειά της αντί για ένα μόνο TTL. Σε καταγεγραμμένη εκτέλεση με τον τελικό κώδικα (αναγνωριστικό `mininet_run_20260714_184311`), επίθεση εξήντα δευτερολέπτων με TTL δέκα δευτερολέπτων οδήγησε σε 1.456.155 συνολικά απορριφθέντα πακέτα κατανεμημένα σε εννέα διαδοχικά leases, χωρίς κανένα ψευδώς θετικό. Όταν η κακόβουλη κίνηση σταματά, το τελευταίο lease λήγει και η συνδεσιμότητα της πηγής αποκαθίσταται. Η αναλυτική μέτρηση της κάλυψης δίνεται στην ενότητα 6.10. Πρέπει να τονιστεί ότι τα υπόλοιπα σενάρια, καθώς και το script `demo_10min.sh`, δεν αποτελούν packet-level απόδειξη: στέλνουν κατασκευασμένη τηλεμετρία απευθείας στη διεπαφή του ελεγκτή (API-level) και δεν παράγουν πραγματικά πακέτα. Οι μετρήσεις καθυστέρησης του αυτοματοποιημένου runner (`ddos_metrics.csv`), οι οποίες κυμαίνονται σε κλάσματα του δευτερολέπτου, αφορούν αυτή την API-level διαδρομή και δεν είναι συγκρίσιμες με την packet-level εκτέλεση. Κάθε αποτέλεσμα φέρει ρητά τον τύπο του πειράματος (`experiment_type`) ώστε να μη συγχέονται οι δύο διαδρομές.

### 6.8.2 Σάρωση θυρών (Port Scan)

Στο σενάριο σάρωσης, ο επιτιθέμενος διερευνά πολλαπλές θύρες του θύματος παράγοντας πλήθος σύντομων ροών. Παρά τη χαμηλότερη ένταση σε σχέση με την πλημμύρα, το χαρακτηριστικό αποτύπωμα των πολλών σύντομων ροών οδήγησε σε ανίχνευση μέσα σε

μόλις 0,24 δευτερόλεπτα, με δύο ορθές ανιχνεύσεις, χωρίς ψευδώς θετικά στο σενάριο αυτό και επιτυχή αποκλεισμό του επιτιθέμενου. Το σενάριο αναδεικνύει ότι το σύστημα δεν περιορίζεται στις επιθέσεις όγκου.

### **6.8.3 Εξαγωγή δεδομένων (Data Exfiltration)**

Το σενάριο εξαγωγής δεδομένων αναπαριστά τη μεταφορά περίπου 9,5 MB εκτός δικτύου με ρυθμό 8 Mbps. Ο επιτιθέμενος εντοπίστηκε σε 0,71 δευτερόλεπτα, ωστόσο το αποτέλεσμα δεν μπορεί να χαρακτηριστεί επιτυχές: μαζί με τον επιτιθέμενο αποκλείστηκαν και οι τέσσερις νόμιμοι hosts (10.0.0.1 έως 10.0.0.4), δηλαδή τέσσερα ψευδώς θετικά έναντι δύο ορθών ανιχνεύσεων. Ο μη επιβλεπόμενος Isolation Forest επισημαίνει ως ανώμαλη κάθε κίνηση υψηλού όγκου και δεν διακρίνει τη νόμιμη μεταφορά μεγάλων αρχείων από την κακόβουλη εξαγωγή δεδομένων, καθώς τα δύο φαινόμενα έχουν σχεδόν ταυτόσημο αποτύπωμα στα συγκεντρωτικά χαρακτηριστικά που χρησιμοποιεί. Πρόκειται για ουσιώδη περιορισμό και όχι για αποδεκτό κόστος: σε πραγματική ανάπτυξη, ο αποκλεισμός όλων των hosts υψηλού εύρους ζώνης θα ισοδυναμούσε με άρνηση εξυπηρέτησης. Η άρση του απαιτεί συμφραζόμενα ανά εφαρμογή και προορισμό ή προσαρμοστικά κατώφλια ανά host, στοιχεία που δεν περιλαμβάνονται στην παρούσα υλοποίηση.

### **6.8.4 Εξάντληση πίνακα ροών**

Το σενάριο εξάντλησης παράγει 300 ροές ανά host ανά κύκλο δειγματοληψίας, προσομοιώνοντας την προσπάθεια γεμίσματος του πίνακα ροών. Η ανίχνευση ήταν η ταχύτερη όλων, με καθυστέρηση μόλις 0,14 δευτερολέπτων και ανά-host χρόνους ανίχνευσης από 0,04 έως 0,22 δευτερόλεπτα. Και οι τέσσερις επιτιθέμενοι hosts μπλοκαρίστηκαν, χωρίς κανένα ψευδώς θετικό. Το αποτέλεσμα επιβεβαιώνει ότι οι επιθέσεις με εκρηκτική δημιουργία ροών αφήνουν το εντονότερο αποτύπωμα και ανιχνεύονται σχεδόν ακαριαία.

### **6.8.5 Πλευρική κίνηση (Lateral Movement)**

Στο σενάριο πλευρικής κίνησης, ένας παραβιασμένος εσωτερικός host (10.0.0.3) σαρώνει τέσσερις άλλους εσωτερικούς κόμβους. Το σύστημα ανίχνευσε τη δραστηριότητα σε 0,31 δευτερόλεπτα και μπλόκαρε τον επιτιθέμενο, καταγράφοντας όμως μία ορθή ανίχνευση έναντι ενός ψευδώς θετικού. Η αναλογία αυτή είναι οριακή και δεν επιτρέπει ισχυρισμό αξιόπιστης ανίχνευσης. Η εσωτερική σάρωση παράγει πρότυπα ροών που επικαλύπτονται

σημαντικά με τη νόμιμη εσωτερική επικοινωνία, όπως οι υπηρεσίες ανακάλυψης δικτύου, και τα συγκεντρωτικά χαρακτηριστικά δεν επαρκούν για τον διαχωρισμό τους.

#### 6.8.6 ARP Spoofing / MITM

Το σενάριο ARP spoofing αναπαριστά επίθεση ενδιάμεσου ανθρώπου, όπου ο επιτιθέμενος (10.0.0.6) πλαστογραφεί την ταυτότητα της πύλης (10.0.0.1). Το αποτέλεσμα είναι αρνητικό και καταγράφεται ως τέτοιο: το σύστημα δεν παρήγαγε καμία ορθή ανίχνευση της πλαστογράφησης, με μηδέν αληθώς θετικά και δύο ψευδώς αρνητικά. Ο επιτιθέμενος τελικά αποκλείστηκε, αλλά εξαιτίας της συνοδευτικής στατιστικής δραστηριότητας και όχι επειδή αναγνωρίστηκε η ίδια η επίθεση. Το εύρημα είναι αναμενόμενο και διαφωτιστικό: η ανίχνευση ARP spoofing απαιτεί ανάλυση σε επίπεδο πρωτοκόλλου, δηλαδή έλεγχο της αντιστοίχισης διευθύνσεων IP προς MAC, την οποία ένα σύστημα που βασίζεται αποκλειστικά σε συγκεντρωτικά στατιστικά ροών δεν μπορεί εξ ορισμού να επιτελέσει. Το σενάριο οριοθετεί έτσιρητά το όριο της στατιστικής προσέγγισης.

#### Συγκεντρωτικά δεδομένα ανά σενάριο

Για πληρότητα, παρατίθενται τα αναλυτικά αριθμητικά δεδομένα καθενός από τα ζωντανά σενάρια, όπως καταγράφηκαν κατά την εκτέλεση.

| Σενάριο           | Διάρκ. (s) | Ανιχν. | TP | FP | Latency (s) |
|-------------------|------------|--------|----|----|-------------|
| DDoS / SYN flood  | 60         | 30     | -  | 0  | 1,16        |
| Port scan         | 20         | 2      | 2  | 0  | 0,24        |
| Data exfiltration | 20         | 10     | 2  | 4  | 0,71        |
| Flow exhaustion   | 20         | 10     | 4  | 0  | 0,14        |
| Lateral movement  | 20         | 3      | 1  | 1  | 0,31        |
| ARP spoof         | 20         | 5      | 0  | 0  | -           |

*Πίνακας 6-9: Αναλυτικά δεδομένα ανά ζωντανό σενάριο.*

Στο σενάριο εξάντλησης πίνακα ροών, οι ανά-host χρόνοι ανίχνευσης κυμάνθηκαν από 0,04 s (10.0.0.1) έως 0,22 s (10.0.0.4), με μέση τιμή 0,14 s, η ταχύτερη μεταξύ όλων των σεναρίων, όπως αναμένεται από το έντονο αποτύπωμα της εκρηκτικής δημιουργίας ροών.

## 6.9 Καθυστέρηση ανίχνευσης και αποτελεσματικότητα αντιμετώπισης

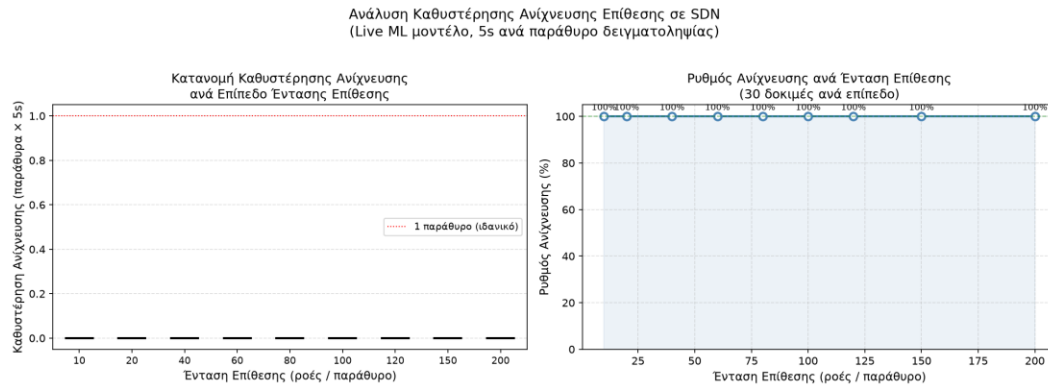
Η αναφερόμενη καθυστέρηση αφορά τον χρόνο από την επεξεργασία του πρώτου παραθύρου τηλεμετρίας που περιέχει την επίθεση έως την παραγωγή απόφασης και την ενεργοποίηση της αντιμετώπισης. Επομένως, η τιμή αυτή δεν ταυτίζεται απαραίτητα με τον συνολικό χρόνο από το πρώτο κακόβουλο πακέτο, ο οποίος εξαρτάται από τη θέση της επίθεσης μέσα στο παράθυρο δειγματοληψίας των πέντε δευτερολέπτων. Με αυτόν τον ορισμό, μικρή καθυστέρηση σημαίνει λιγότερη ζημιά και δυνατότητα εγκατάστασης κανόνα απόρριψης πριν κορεστεί ο ελεγκτής.

Εκτελέστηκαν 30 ανεξάρτητες δοκιμές για εννέα επίπεδα έντασης (10-200 ροές ανά παράθυρο). Το κεντρικό εύρημα είναι ιδιαίτερα σημαντικό: 100% ρυθμός ανίχνευσης με μηδενική καθυστέρηση (εντός του πρώτου παραθύρου) σε όλες τις εντάσεις, ακόμη και στη χαμηλότερη δοκιμασμένη.

| Ένταση (ροές/παράθυρο) | Ρυθμός ανίχνευσης | Μέση καθυστ. | Αστοχίες |
|------------------------|-------------------|--------------|----------|
| 10                     | 100%              | 0,0 s        | 0/30     |
| 20                     | 100%              | 0,0 s        | 0/30     |
| 40                     | 100%              | 0,0 s        | 0/30     |
| 100                    | 100%              | 0,0 s        | 0/30     |
| 200                    | 100%              | 0,0 s        | 0/30     |

*Πίνακας 6-10: Ρυθμός ανίχνευσης και καθυστέρηση ανά ένταση επίθεσης (30 δοκιμές).*

Η ερμηνεία είναι ότι ακόμη και η ελάχιστη δοκιμασμένη ένταση (10 ροές) είναι περίπου 2,5 φορές πάνω από τη φυσιολογική κίνηση (~4 ροές) και με εντελώς διαφορετικό λόγο σύντομων ροών. Η επίθεση είναι επομένως ορατή από το πρώτο κιόλας παράθυρο. Σε αντίθεση, τα συμβατικά IDS που βασίζονται σε αντιστοίχιση υπογραφών ανά πακέτο τυπικά απαιτούν περισσότερο χρόνο, καθώς εξαρτώνται από τη διαθεσιμότητα ενημερωμένων υπογραφών και από επεξεργασία ανά πακέτο.



**Σχήμα 6-17: Καθυστέρηση ανίχνευσης και ρυθμός ανίχνευσης συναρτήσει της έντασης της επίθεσης.**

### Αποτελεσματικότητα αντιμετώπισης

Η αξιολόγηση της αντιμετώπισης πραγματοποιήθηκε σε 50 ανεξάρτητες δοκιμές με σενάριο τριών φάσεων (νόμιμη κίνηση, επίθεση, επανάληψη μετά τη λήξη του block). Μετρήθηκαν ο χρόνος έως την ανίχνευση, η κάλυψη αντιμετώπισης, η μείωση κακόβουλης κίνησης, το ποσοστό ψευδώς θετικών και ο ρυθμός επανα-ανίχνευσης.

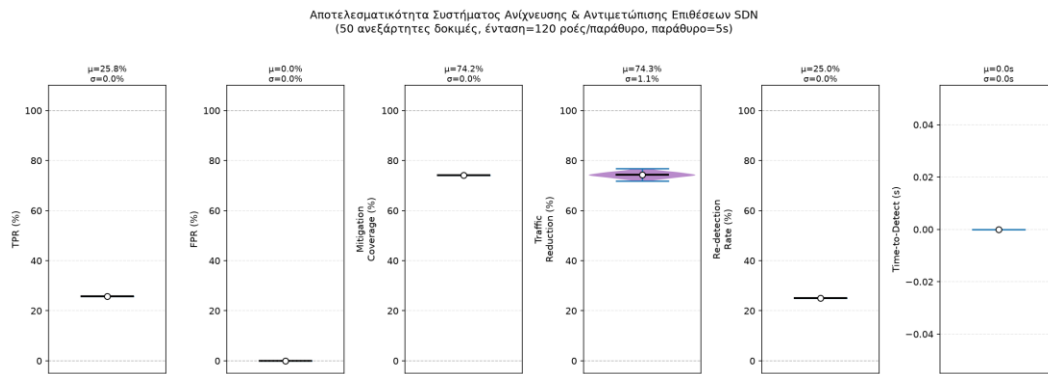
| Μετρική                    | Αποτέλεσμα | Τυπ. Απόκλιση |
|----------------------------|------------|---------------|
| <b>Time-to-Detect</b>      | 0,0 s      | ±0,0 s        |
| <b>Mitigation Coverage</b> | 74,2%      | ±0,0%         |
| <b>Traffic Reduction</b>   | 74,3%      | ±1,1%         |
| <b>False Positive Rate</b> | 0,0% *     | ±0,0%         |
| <b>Re-detection Rate</b>   | 100%       | -             |

**Πίνακας 6-11: Μετρικές αποτελεσματικότητας αντιμετώπισης (50 δοκιμές).**

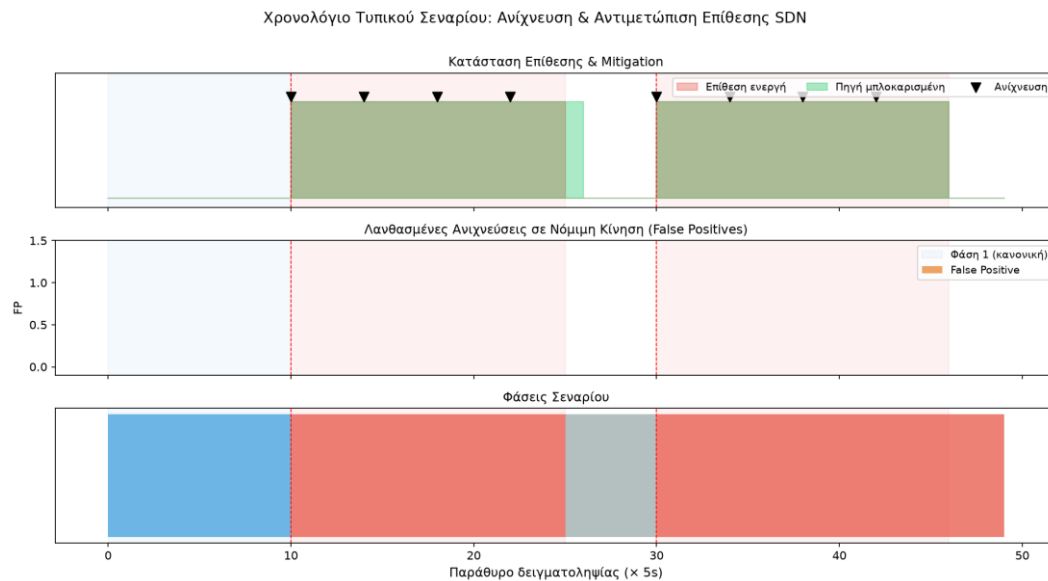
\* Το μηδενικό ποσοστό ψευδώς θετικών αφορά το συγκεκριμένο σενάριο αντιμετώπισης (νόμιμη κίνηση και DDoS flood). Σε ορισμένα άλλα live σενάρια με στατιστικά ακραία, αλλά νόμιμη, κίνηση εμφανίστηκαν περιορισμένα ψευδώς θετικά (βλ. ενότητα 6.8).

Η μηδενική καθυστέρηση ανίχνευσης συνδυάζεται με μηδενικό ποσοστό ψευδώς θετικών στο σενάριο αυτό και κάλυψη αντιμετώπισης 74,2%. Η τελευταία τιμή αντικατοπτρίζει τη φυσιολογική δυναμική του κύκλου ανίχνευσης-αποκλεισμού: κάθε κύκλος αποτελείται από ένα παράθυρο ανίχνευσης και τρία παράθυρα αποκλεισμού, δηλαδή ο επιτιθέμενος παραμένει μπλοκαρισμένος το 74% της συνολικής διάρκειας της επίθεσης, χωρίς καμία διαρροή ψευδώς θετικών στη νόμιμη κίνηση. Η τιμή αυτή προκύπτει από σύντομες API-level δοκιμές, όπου το αρχικό παράθυρο ανίχνευσης καταλαμβάνει μεγάλο μέρος της

διάρκειας. Στην packet-level εκτέλεση μεγαλύτερης διάρκειας, όπου ο κανόνας ανανεώνεται συνεχώς όσο η επίθεση εξελίσσεται, η κάλυψη ανέρχεται σε 97,7% της συνολικής επίθεσης και σε 100% από τη στιγμή της πρώτης ανίχνευσης και έπειτα, όπως αναλύεται στην ενότητα 6.10.



**Σχήμα 6-18:** Κατανομές (violin plots) των μετρικών αποτελεσματικότητας αντιμετώπισης.



**Σχήμα 6-19:** Χρονολόγιο τυπικού σεναρίου αντιμετώπισης (ανίχνευση, αποκλεισμός, επανα-ανίχνευση).

## 6.10 Επικύρωση της per-flow τηλεμετρίας σε πραγματική εκτέλεση

Πέρα από την αποτίμηση των επιμέρους σεναρίων, το ζωντανό σύστημα εκτελέστηκε end-to-end σε πραγματική στοίβα Docker, με τον ελεγκτή, τον μεταγωγέα Open vSwitch και μια τοπολογία Mininet έξι κόμβων. Σκοπός ήταν η επικύρωση ότι η τηλεμετρία που τροφοδοτεί τη μηχανή απόφασης προέρχεται από πραγματικά per-flow στατιστικά του πίνακα ροών. Η εξέταση του πίνακα ροών κατά την εκτέλεση (ovs-ofctl dump-flows) επιβεβαίωσε ότι κάθε ζεύγος διευθύνσεων διατηρεί ξεχωριστούς μετρητές πακέτων, όγκου

και διάρκειας, και ότι η πλημμύρα SYN του επιτιθέμενου παρήγαγε δεκάδες χιλιάδες πακέτα σε ένα παράθυρο (33.582 σε μία μέτρηση), τα οποία ταξινομήθηκαν ορθά ως επίθεση και οδήγησαν σε άμεση εγκατάσταση κανόνα απόρριψης.

Η ζωντανή εκτέλεση, ωστόσο, ανέδειξε ένα εύρημα που δεν ήταν ορατό στις offline δοκιμές: το μη επιβλεπόμενο μοντέλο σήμαινε ως ανωμαλία περίπου το 14% των παραθύρων νόμιμης, χαμηλού όγκου κίνησης (τέσσερα ψευδώς θετικά σε είκοσι οκτώ παράθυρα). Η ανάλυση εντόπισε δύο αιτίες, ορατές μόνο επειδή η τηλεμετρία είχε πλέον την πιστότητα ανά ροή. Πρώτον, τα στατιστικά του πίνακα ροών αναφέρουν τη σωρευτική διάρκεια κάθε ροής, η οποία αυξάνεται μονότονα (37, 60, 90 δευτερόλεπτα και πέρα). Ένα τέτοιο αχαλίνωτο μέγεθος αποτελεί κακό χαρακτηριστικό, και για τον λόγο αυτό η διάρκεια φράχθηκε σε ένα άνω όριο ώστε μια μακρόβια σταθερή ροή να αντιστοιχεί σε σταθερή τιμή. Δεύτερον, η κατανομή στην οποία είχε εκπαιδευτεί το ζωντανό μοντέλο θεωρούσε φυσιολογικό μέγεθος πακέτου μεταξύ 250 και 1400 bytes και διάρκεια έως 15 δευτερόλεπτα, ενώ η πραγματική νόμιμη κίνηση περιλαμβάνει μικρά πακέτα ελέγχου (ping περίπου 98 bytes) και μακρόβιες ροές. Τα εύρη επεκτάθηκαν αντίστοιχα ώστε να καλύπτουν τη ρεαλιστική κίνηση, χωρίς να αλλοιωθεί ο διαχωρισμός των επιθέσεων, οι οποίες παραμένουν διακριτές μέσω του όγκου και του πλήθους των σύντομων ροών.

Μετά τη διόρθωση, το σύστημα επανεκτελέστηκε στην ίδια στοίβα. Δεν καταγράφηκε κανένα ψευδώς θετικό στη νόμιμη κίνηση, ενώ ο επιτιθέμενος εξακολούθησε να ανιχνεύεται και να μπλοκάρεται αξιόπιστα εντός του πρώτου παραθύρου. Το ποσοστό ψευδώς θετικών στη νόμιμη κίνηση μειώθηκε έτσι από περίπου 14% σε 0%, χωρίς καμία απώλεια στην ικανότητα ανίχνευσης. Το επεισόδιο αυτό είναι αξιοσημείωτο και ως μεθοδολογικό αποτέλεσμα: η βελτίωση της πιστότητας της τηλεμετρίας δεν ήταν απλώς μια τεχνική διόρθωση, αλλά αποκάλυψε μια λανθάνουσα αναντιστοιχία μεταξύ των υποθέσεων εκπαίδευσης και της πραγματικής κατανομής της κίνησης, την οποία μόνο η ζωντανή μέτρηση μπορούσε να φανερώσει. Ο πλήρης κύκλος υλοποίησης, μέτρησης, εντοπισμού, διόρθωσης και επανεπικύρωσης καταγράφεται με τα αντίστοιχα ακατέργαστα αρχεία στον φάκελο `results/live/`.

Η ίδια πραγματική στοίβα χρησιμοποιήθηκε για να μετρηθεί η αποτελεσματικότητα της αντιμετώπισης σε επίθεση διάρκειας μεγαλύτερης από ένα TTL, ώστε να ελεγχθεί αν ο κανόνας απόρριψης καλύπτει ολόκληρη την επίθεση. Σε επίθεση εξήντα δευτερολέπτων με TTL δέκα δευτερολέπτων, οι καθυστερήσεις μετρήθηκαν με μονότονο ρολόι από τη στιγμή εκκίνησης της επίθεσης: πρώτη κακόβουλη τηλεμετρία στα 1,14 s, απόφαση του

μοντέλου στα 1,16 s, εγκατάσταση κανόνα στα 1,17 s και πρώτο πραγματικά απορριφθέν πακέτο στα 1,48 s. Οι τιμές αυτές αντικαθιστούν την προγενέστερα αναφερόμενη ενιαία καθυστέρηση, η οποία δεν συνοδευόταν από χρονοσημάνσεις. Χάρη στην αυτόματη ανανέωση του lease, ο κανόνας παρέμεινε ενεργός σε εννέα διαδοχικές περιόδους (οκτώ ανανεώσεις) και απέρριψε συνολικά 1.456.155 πακέτα, με κάλυψη 97,7% της συνολικής διάρκειας της επίθεσης και 100% από τη στιγμή της πρώτης ανίχνευσης και έπειτα. Το μη καλυπτόμενο 2,3% αντιστοιχεί ακριβώς στο σύντομο διάστημα πριν την πρώτη ανίχνευση. Καθ' όλη τη διάρκεια, η νόμιμη κίνηση δεν επηρεάστηκε (ping νόμιμου host με μηδενική απώλεια και σταθερό RTT), ενώ ο ελεγκτής ενημερωνόταν για κάθε ανανέωση μέσω ειδικής διεπαφής επιβολής, ώστε ο πίνακας ροών του και το data plane να μη λήγουν σε διαφορετικές στιγμές.

Για να απομονωθεί η συνεισφορά του μηχανισμού ανανέωσης, η ίδια επίθεση επαναλήφθηκε με το χρόνο ζωής του κανόνα ρυθμισμένο σε πέντε, δέκα και είκοσι δευτερόλεπτα, καθώς και με την προληπτική ανανέωση απενεργοποιημένη. Ο ακόλουθος πίνακας συνοψίζει τα αποτελέσματα.

*Πίνακας 6-12: Κάλυψη αντιμετώπισης σε πραγματική packet-level εκτέλεση (επίθεση 60 s), συνάρτηση του χρόνου ζωής του κανόνα και της ανανέωσης.*

| Ρύθμιση        | TTL (s) | Ανανέωση | Κάλυψη (συνολ.) | Κάλυψη (μετά ανίχν.) | Leases (ανανεώσεις) | Απορ. πακέτα |
|----------------|---------|----------|-----------------|----------------------|---------------------|--------------|
| Κανονική       | 10      | Ναι      | 97,7%           | 100%                 | 9 (8)               | 1.456.155    |
| Χωρίς ανανέωση | 10      | Όχι      | 91,4%           | 93,6%                | 6 (5)               | 1.333.599    |
| Μικρό TTL      | 5       | Ναι      | 96,9%           | 100%                 | 21 (20)             | 1.415.331    |
| Μεγάλο TTL     | 20      | Ναι      | 97,7%           | 100%                 | 5 (4)               | 1.458.553    |

Η γραμμή «Χωρίς ανανέωση» αντιστοιχεί σε αντιδραστική μόνο επανεγκατάσταση (η προληπτική ανανέωση απενεργοποιημένη): η κάλυψη πέφτει, δείχνοντας ότι η προληπτική ανανέωση είναι αναγκαία για να μη μεσολαβούν παράθυρα χωρίς ενεργό κανόνα. Το μικρότερο TTL απαιτεί περισσότερες ανανεώσεις για την ίδια κάλυψη, το μεγαλύτερο λιγότερες. Και στις δύο περιπτώσεις η επίθεση καλύπτεται πλήρως μετά την ανίχνευση.

Για να αποκτήσουν στατιστική αξιοπιστία οι μετρήσεις και να μην στηρίζονται σε μία μόνο εκτέλεση, το σενάριο επαναλήφθηκε σε δέκα ανεξάρτητους κύκλους επίθεσης (αναγνωριστικό εκτέλεσης mininet\_run\_20260714\_195434). Και στους δέκα κύκλους ο επιτιθέμενος ανιχνεύθηκε και αποκλείστηκε (ρυθμός ανίχνευσης 100%), χωρίς κανένα

ψευδώς θετικό στη νόμιμη κίνηση. Οι κατανομές των βασικών μετρικών, με διαστήματα εμπιστοσύνης 95% του μέσου, δίνονται στον ακόλουθο πίνακα.

*Πίνακας 6-13: Κατανομές των μετρικών σε δέκα ανεξάρτητους κύκλους επίθεσης (διάμεσος, μέσος, p95 και 95% διάστημα εμπιστοσύνης του μέσου).*

| Μετρική                       | Διάμεσος | Μέσος   | p95     | 95% CI του μέσου   |
|-------------------------------|----------|---------|---------|--------------------|
| Καθυστέρηση ανίχνευσης (s)    | 1,73     | 1,78    | 2,88    | [1,39, 2,17]       |
| Πρώτο απορριφθέν πακέτο (s)   | 1,86     | 1,92    | 2,91    | [1,54, 2,31]       |
| Κάλυψη αντιμετώπισης (%)      | 94,1     | 94,1    | 97,1    | [92,9, 95,3]       |
| Κάλυψη μετά την ανίχνευση (%) | 100      | 100     | 100     | [100, 100]         |
| Απορριφθέντα πακέτα           | 740.677  | 745.091 | 776.173 | [734.640, 755.541] |

Η στενότητα των διαστημάτων εμπιστοσύνης δείχνει ότι η συμπεριφορά είναι σταθερή μεταξύ εκτελέσεων: η καθυστέρηση ανίχνευσης παραμένει κάτω από τρία δευτερόλεπτα ακόμη και στο 95ο εκατοστημόριο, ενώ η κάλυψη μετά την ανίχνευση είναι σταθερά 100%. Παράλληλα μετρήθηκε η επίδραση στο δίκτυο: σε καμία από τις δέκα εκτελέσεις η νόμιμη κίνηση δεν υπέστη απώλεια πακέτων, και η μέση καθυστέρηση διαδρομής (RTT) νόμιμου host παρέμεινε ουσιαστικά αμετάβλητη πριν, κατά τη διάρκεια και μετά την επίθεση (περίπου 4,6 ms σε κανονική λειτουργία, 4,4 ms υπό επίθεση και 4,4 ms μετά την αποκατάσταση, με μηδενική απώλεια σε κάθε φάση). Το εύρημα επιβεβαιώνει ότι η αντιμετώπιση απομονώνει τον επιτιθέμενο χωρίς να επιβαρύνει τους νόμιμους χρήστες και ότι η συνδεσιμότητα αποκαθίσταται πλήρως μόλις παύσει η επίθεση.

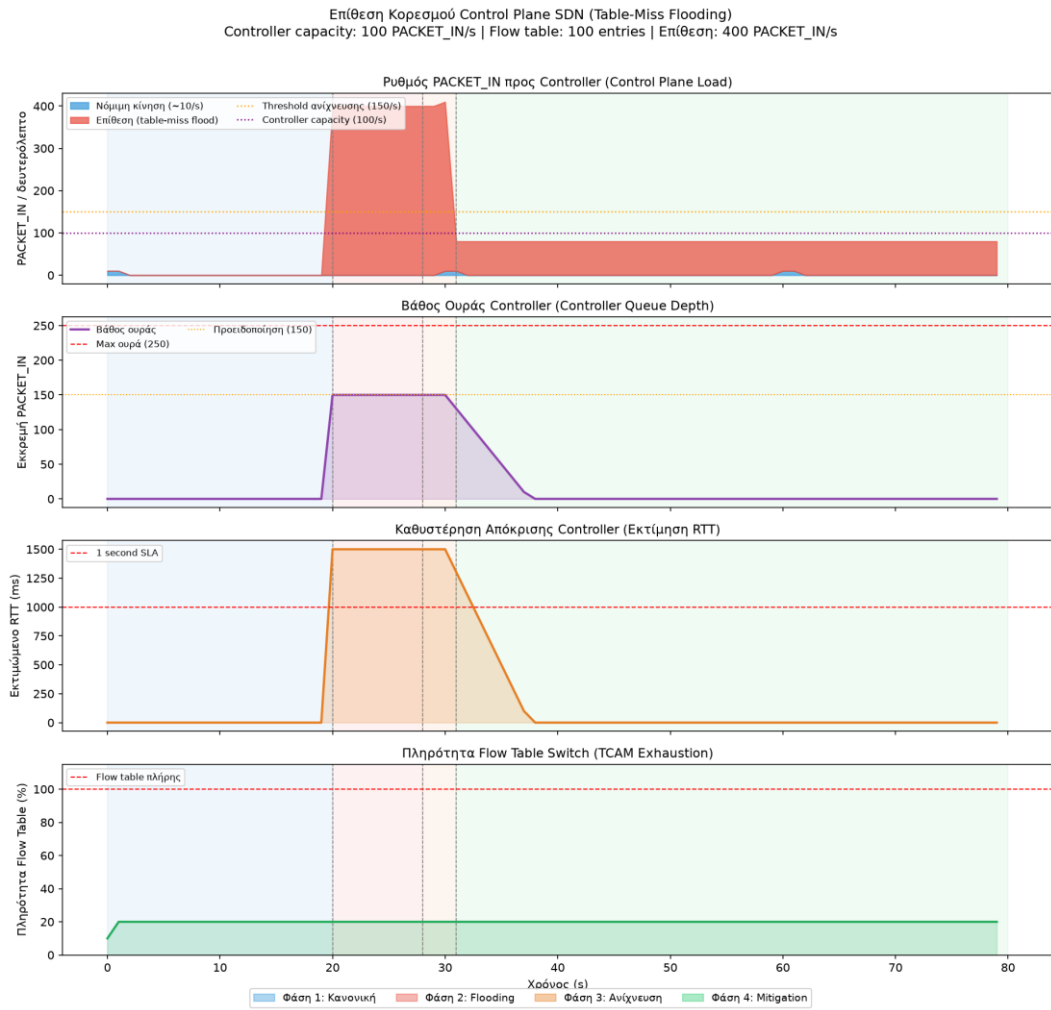
## 6.11 Επίθεσεις ειδικές του SDN: κορεσμός του control plane και δηλητηρίαση τηλεμετρίας

Η πιο SDN-specific επίθεση, η επίθεση κορεσμού του control plane (table-miss flooding), εκμεταλλεύεται το γεγονός ότι κάθε άγνωστη ροή προκαλεί μήνυμα Packet-In προς τον ελεγκτή. Σε αντίθεση με τα προηγούμενα σενάρια, το πείραμα αυτό δεν εκτελείται σε δίκτυο αλλά υλοποιείται ως προσομοίωση διακριτών γεγονότων σε Python, στην οποία μοντελοποιούνται η ουρά Packet-In του ελεγκτή, ο ρυθμός επεξεργασίας του και ο πεπερασμένος πίνακας ροών του μεταγωγέα. Τα αποτελέσματα που ακολουθούν αφορούν επομένως τη δυναμική του μοντέλου και όχι μετρήσεις σε πραγματικό ελεγκτή OpenFlow.

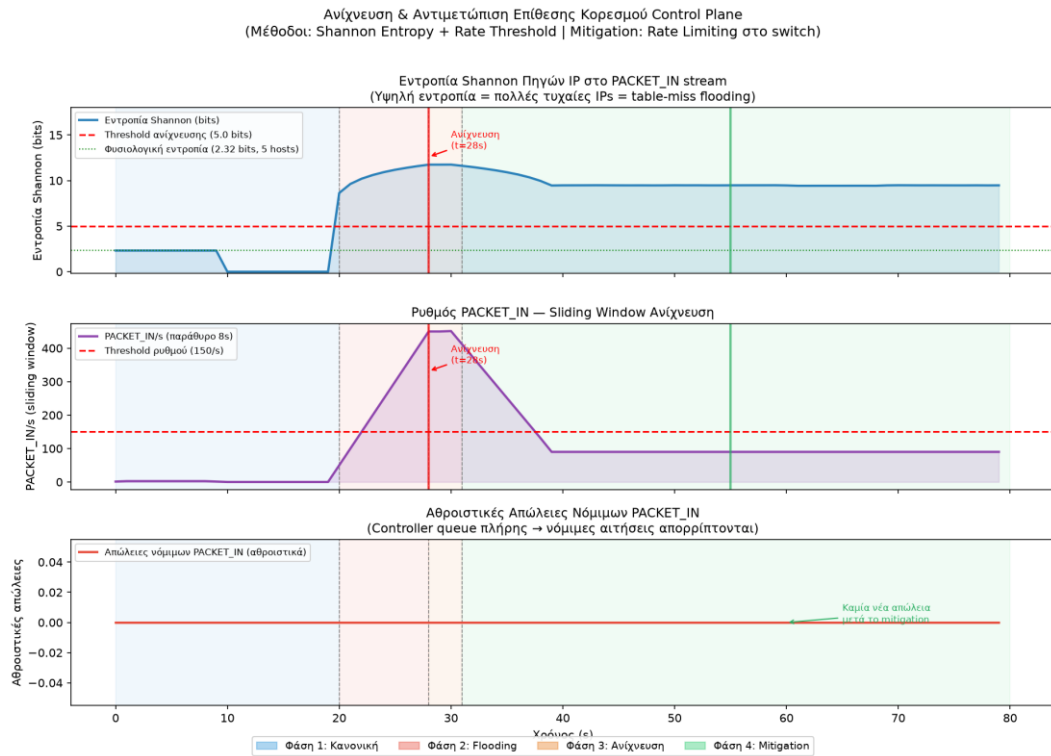
Στο μοντέλο, ο επιτιθέμενος στέλνει πακέτα με τυχαίες διευθύνσεις προέλευσης, ώστε κάθε πακέτο να είναι εγγυημένα table-miss, δημιουργώντας καταιγίδα Packet-In που οδηγεί τον ελεγκτή σε κορεσμό. Η ανίχνευση βασίζεται στην εντροπία Shannon (Shannon entropy) των διευθύνσεων προέλευσης: στη φυσιολογική κίνηση η εντροπία είναι χαμηλή (~1-2 bits), ενώ στην επίθεση με χιλιάδες τυχαίες IPs εκτοξεύεται (~11-12 bits). Η αντιμετώπιση γίνεται με καθολικό rate-limiting κανόνα στον μεταγωγέα.

| Μετρική                | Φάση Normal | Φάση Attack | Φάση Mitigated |
|------------------------|-------------|-------------|----------------|
| Ρυθμός Packet-In       | ~1/s        | 400/s       | ~81/s          |
| Βάθος ουράς            | 0/250       | 150/250     | 10/250         |
| Χρόνος απόκρισης (RTT) | 0 ms        | 1.500 ms    | 100 ms         |
| Εντροπία Shannon       | 1,16 bits   | 11,58 bits  | ~8 bits        |

*Πίνακας 6-14: Μετρήσεις κατά τη διάρκεια της επίθεσης κορεσμού control plane.*



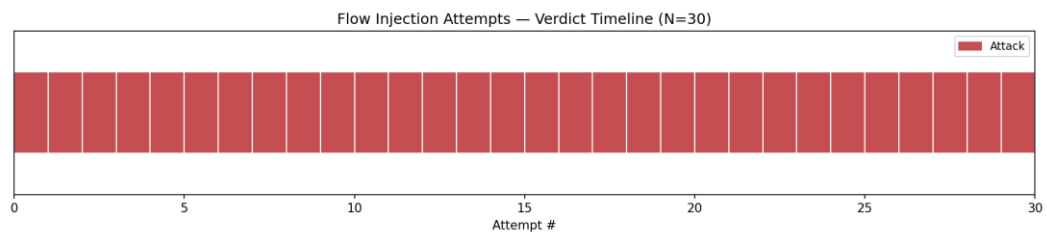
Σχήμα 6-20: Επισκόπηση της επίθεσης κορεσμού control plane (ρυθμός Packet-In, ουρά, RTT, πίνακας ροών).



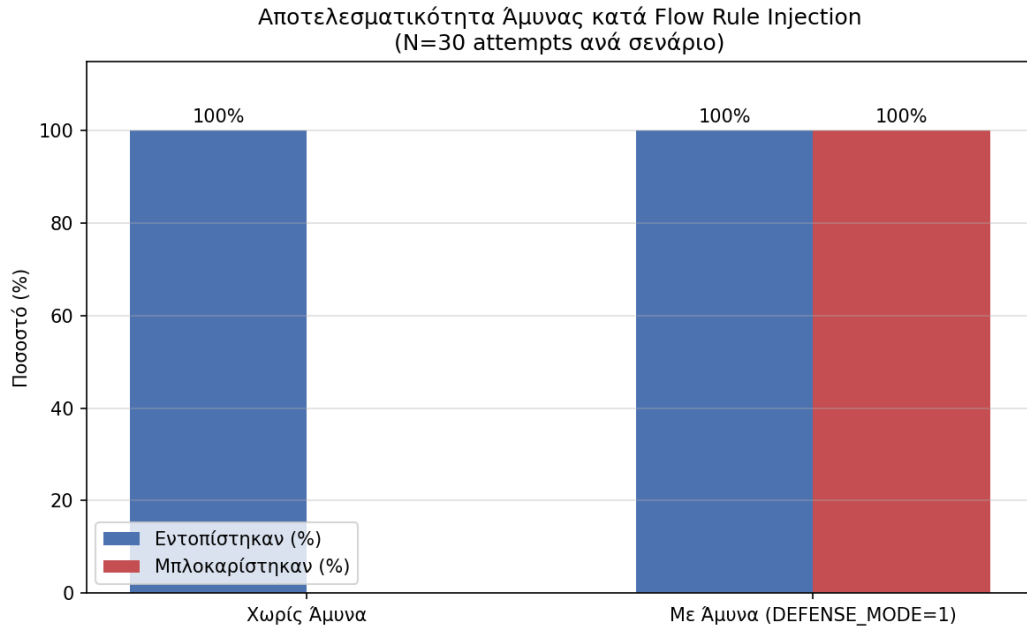
**Σχήμα 6-21: Ανίχνευση της επίθεσης κορεσμού μέσω εντροπίας Shannon.**

### Δηλητηρίαση τηλεμετρίας (flow-injection)

Το σενάριο δηλητηρίασης τηλεμετρίας εξετάζει μια πιο εκλεπτυσμένη απειλή: ο επιτιθέμενος κατασκευάζει πλαστά στατιστικά ροών με στόχο να ενοχοποιήσει έναν νόμιμο host και να προκαλέσει τον ελεγκτή να τον μπλοκάρει. Η άμυνα βασίζεται στην αυθεντικοποίηση της πηγής της τηλεμετρίας (X-Switch-Token): όταν αυτή είναι ενεργή, τα πλαστά στατιστικά απορρίπτονται πριν καν φτάσουν στη μηχανή ανίχνευσης, εξουδετερώνοντας την επίθεση χωρίς επίπτωση στη νόμιμη λειτουργία.



**Σχήμα 6-22: Χρονολόγιο της επίθεσης δηλητηρίασης τηλεμετρίας και της αντιμετώπισής της.**



*Σχήμα 6-23: Σύνοψη της αποτελεσματικότητας της άμυνας έναντι της δηλητηρίασης τηλεμετρίας.*

## 6.12 Ανθεκτικότητα σε αντίπαλες επιθέσεις

Ένα σύστημα ανίχνευσης βασισμένο σε ML είναι τόσο αξιόπιστο όσο η ανθεκτικότητά του απέναντι σε έξυπνους αντιπάλους [16], [17]. Εξετάστηκαν δύο κατηγορίες στρατηγικών αποφυγής: επιθέσεις μίμησης στον χώρο χαρακτηριστικών (mimicry) εναντίον του εποπτευόμενου Random Forest, και φυσικές στρατηγικές (slow-rate, pulse, multi-source) εναντίον του ζωντανού μοντέλου συγκεντρωτικών χαρακτηριστικών.

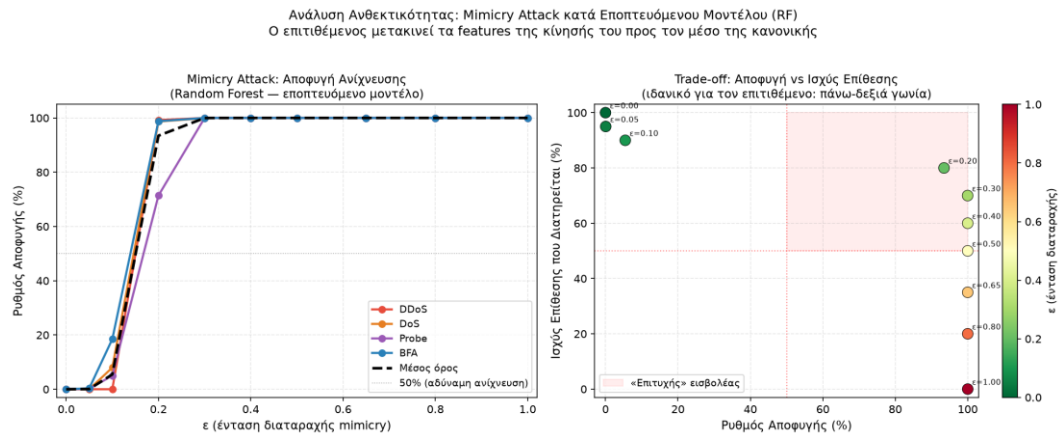
### 6.12.1 Το φαινόμενο του γκρεμού (cliff effect)

Στην επίθεση μίμησης, κάθε δείγμα επίθεσης μετακινείται προς τον μέσο όρο της νόμιμης κίνησης κατά ένα ποσοστό  $\epsilon$ . Το Random Forest εμφανίζει απότομη κατάρρευση της ανίχνευσης γύρω στο  $\epsilon \approx 0,20$ , από 5,5% σε 93,5% ρυθμό αποφυγής σε ένα μόλις βήμα. Αυτό το «φαινόμενο του γκρεμού» αντικατοπτρίζει μια γνωστή ιδιότητα των δέντρων απόφασης: τα δείγματα επίθεσης βρίσκονται συμπαγώς στον χώρο χαρακτηριστικών και, μόλις ξεπεραστεί η απόσταση ως το όριο απόφασης, μεταναστεύουν όλα μαζί στην περιοχή «Normal».

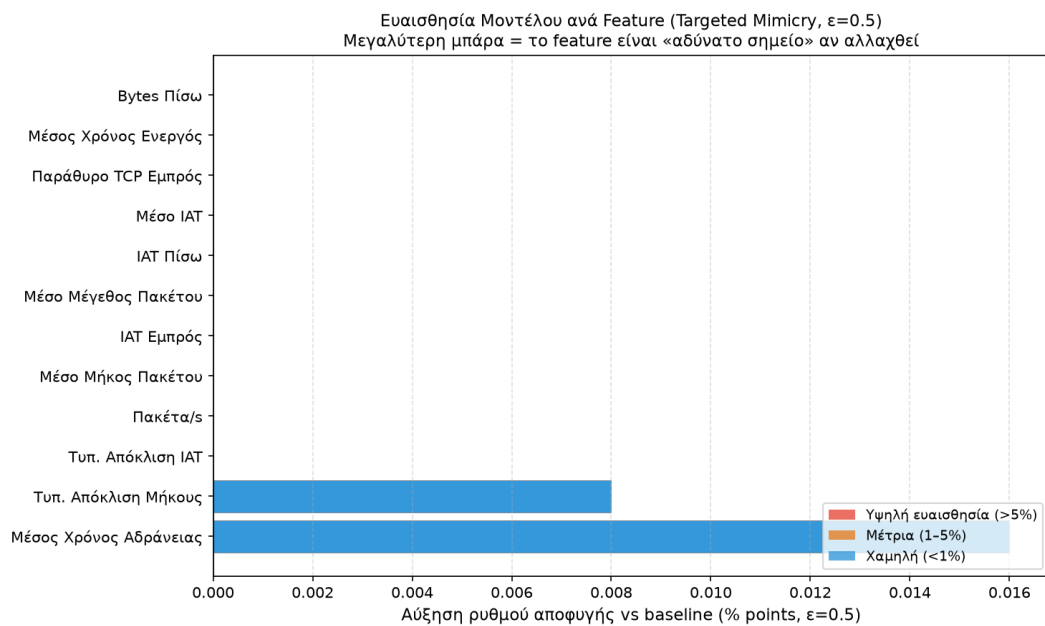
| $\epsilon$  | Ρυθμός αποφυγής | Ισχύς επίθεσης | Ερμηνεία                          |
|-------------|-----------------|----------------|-----------------------------------|
| <b>0,00</b> | 0,0%            | 100%           | Πλήρης ανίχνευση.                 |
| <b>0,10</b> | 5,5%            | 90%            | Αρχή αδυναμίας.                   |
| <b>0,20</b> | 93,5%           | 80%            | «Γκρεμός»: κατάρρευση ανίχνευσης. |

|      |      |     |                              |
|------|------|-----|------------------------------|
| 0,30 | 100% | 70% | Πλήρης αποφυγή.              |
| 0,50 | 100% | 50% | Επίθεση στα μισά της ισχύος. |
| 1,00 | 100% | 0%  | Δεν υπάρχει πλέον επίθεση.   |

**Πίνακας 6-15: Επίθεση μίμησης εναντίον του Random Forest: ρυθμός αποφυγής vs διαταραχή ε.**



**Σχήμα 6-24: Ρυθμός αποφυγής συναρτήσει της διαταραχής  $\epsilon$  (mimicry εναντίον Random Forest) και το trade-off ισχύος επίθεσης.**



**Σχήμα 6-25: Ευαισθησία ανά χαρακτηριστικό (στοχευμένη μίμηση).**

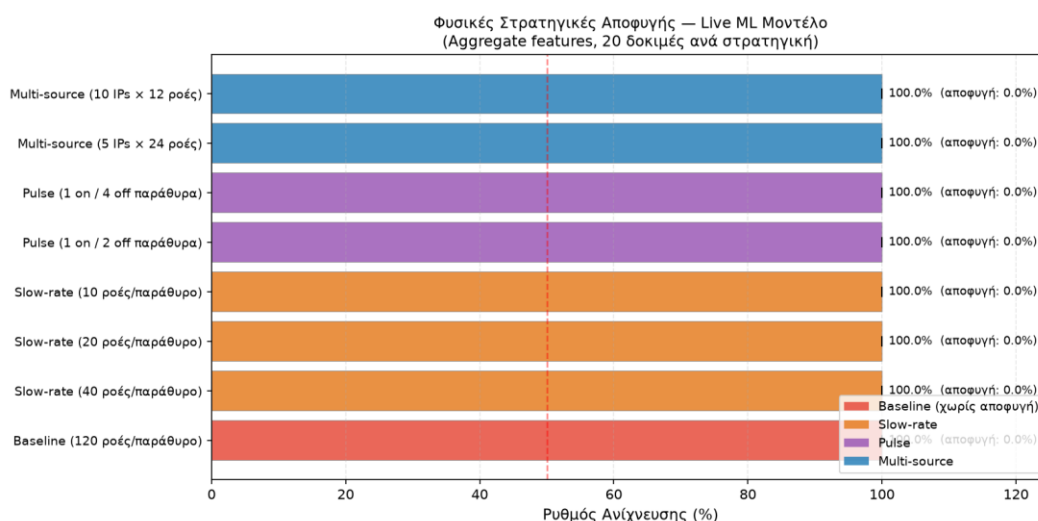
### 6.12.2 Ανθεκτικότητα του ζωντανού μοντέλου

Αντίθετα με το Random Forest, το ζωντανό μοντέλο των συγκεντρωτικών χαρακτηριστικών εμφανίζει ανθεκτικότητα κοντά στο 100%, υπό τις παραμέτρους των δοκιμών που εξετάστηκαν, έναντι όλων των φυσικών στρατηγικών αποφυγής. Ο λόγος

είναι ότι τα συγκεντρωτικά χαρακτηριστικά αποτυπώνουν τη θεμελιώδη φύση της επίθεσης: οι ροές πλημμύρας είναι εγγενώς σύντομες. Για να τις αποφύγει, ο αντίπαλος θα έπρεπε να αλλάξει θεμελιωδώς τον τρόπο επίθεσης, οπότε δεν θα επρόκειτο πλέον για την ίδια επίθεση.

| Στρατηγική                   | Ανίχνευση | Αποφυγή |
|------------------------------|-----------|---------|
| Baseline (120 ροές/παράθυρο) | 100,0%    | 0,0%    |
| Slow-rate (40 ροές)          | 100,0%    | 0,0%    |
| Slow-rate (10 ροές)          | 99,9%     | 0,1%    |
| Pulse (1 on / 4 off)         | 100,0%    | 0,0%    |
| Multi-source (10 IPs)        | 100,0%    | 0,0%    |

**Πίνακας 6-16:** Ανθεκτικότητα του ζωντανού μοντέλου έναντι φυσικών στρατηγικών αποφυγής.



**Σχήμα 6-26:** Φυσικές στρατηγικές αποφυγής εναντίον του ζωντανού μοντέλου.

Το συμπέρασμα είναι ότι το σύστημα είναι ανθεκτικό λόγω της πολυεπιπεδότητάς του: αν και το Random Forest μπορεί να εξαπατηθεί στον χώρο χαρακτηριστικών, το ζωντανό μοντέλο παραμένει ανθεκτικό επειδή εστιάζει σε συμπεριφορικά χαρακτηριστικά που ο επιτιθέμενος δεν μπορεί να αλλάξει χωρίς να εγκαταλείψει την επίθεση. Το προφίλ αυτό είναι σύμφωνο με τη βιβλιογραφία της αντίπαλης μηχανικής μάθησης [16], [17], [18], [19], [20].

Μετά την πυρηνική παρουσίαση των αποτελεσμάτων (ενότητες 6.2 έως 6.12), οι επόμενες ενότητες προσφέρουν συμπληρωματικές οπτικοποιήσεις, συγκριτική αποτίμηση, τη ρητή

συζήτηση των απειλών εγκυρότητας και την αναλυτική περιγραφή των σεναρίων, ώστε η τεκμηρίωση να είναι πλήρης χωρίς να επιβαρύνει τη ροή της κύριας ανάλυσης.

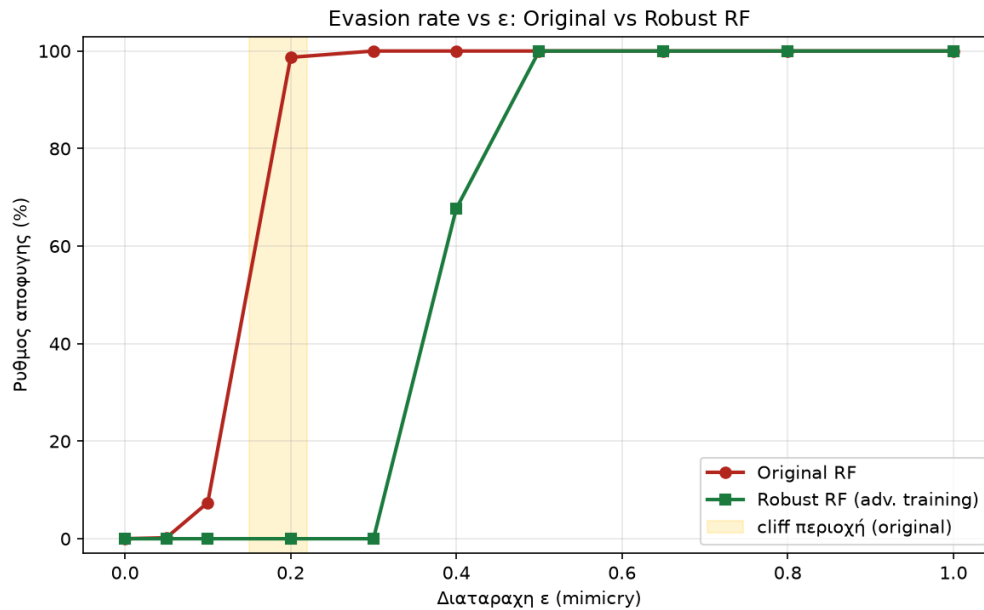
### 6.12.3 Μετριάσμός της αντίπαλης ευπάθειας μέσω adversarial training

Η ανάλυση της ενότητας 6.12.1 ανέδειξε το φαινόμενο του γκρεμού: το εποπτευόμενο μοντέλο Random Forest καταρρέει απότομα στο  $\epsilon \approx 0,20$ . Στην παρούσα ενότητα εξετάζεται ένα αντίμετρο. Εκπαιδεύτηκε ένα δεύτερο μοντέλο, το «Robust Random Forest», σε ένα σύνολο εκπαίδευσης εμπλουτισμένο με διαταραγμένα (adversarially perturbed) δείγματα επίθεσης: για κάθε δείγμα επίθεσης του συνόλου εκπαίδευσης παρήχθησαν μιμητικές (mimicry) εκδοχές του προς τον μέσο της φυσιολογικής κίνησης για  $\epsilon \in \{0,10, 0,20, 0,30\}$ , διατηρώντας την ετικέτα επίθεσης. Έτσι το μοντέλο μαθαίνει να αναγνωρίζει ως επίθεση και τις ελαφρώς μεταμφιεσμένες ροές.

Το ακόλουθο γράφημα και ο πίνακας συγκρίνουν τον ρυθμό αποφυγής των δύο μοντέλων συναρτήσει της διαταραχής  $\epsilon$ , στο ίδιο σύνολο ελέγχου.

| $\epsilon$ | Αποφυγή Original RF | Αποφυγή Robust RF |
|------------|---------------------|-------------------|
| 0,10       | 7,5%                | 0,0%              |
| 0,20       | 98,9%               | 0,0%              |
| 0,30       | 100,0%              | 0,0%              |
| 0,40       | 100,0%              | 69,0%             |
| 0,50       | 100,0%              | 100,0%            |

**Πίνακας 6-17:** Ρυθμός αποφυγής (mimicry) Original vs Robust Random Forest ανά διαταραχή  $\epsilon$ .



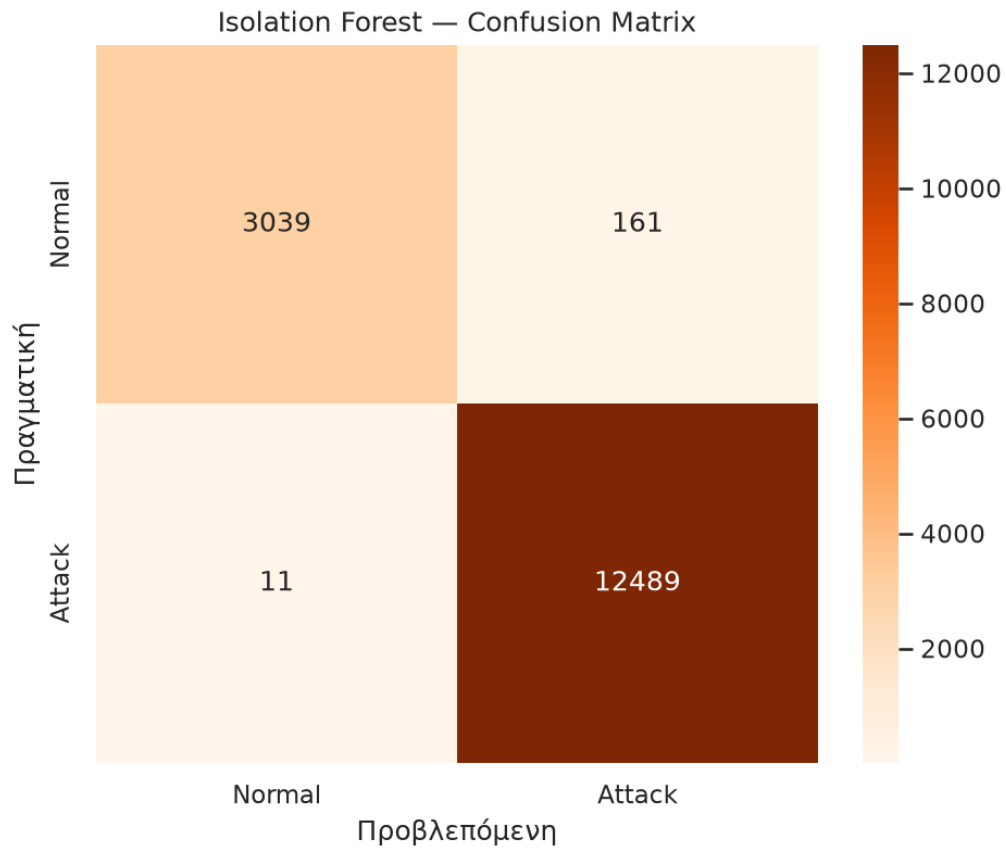
Τα αποτελέσματα δείχνουν ότι η ενσωμάτωση διαταραγμένων δειγμάτων κατά την εκπαίδευση μετατοπίζει το σημείο κατάρρευσης του μοντέλου και μειώνει σημαντικά τον ρυθμό αποφυγής στην κρίσιμη περιοχή: στο  $\epsilon=0,20$  και  $\epsilon=0,30$ , όπου το αρχικό μοντέλο αποφεύγεται σχεδόν πλήρως (99-100%), το Robust RF διατηρεί μηδενικό ρυθμό αποφυγής. Η προστασία είναι ουσιαστική στην περιοχή όπου η επίθεση παραμένει ισχυρή. Για  $\epsilon \geq 0,50$  και τα δύο μοντέλα υποχωρούν, αλλά εκεί ο επιτιθέμενος έχει ήδη θυσιάσει τουλάχιστον το 50% της ισχύος της επίθεσής του, οπότε δεν πρόκειται πλέον ουσιαστικά για την ίδια επίθεση.

Κρίσιμο είναι ότι η θωράκιση αυτή επιτυγχάνεται με μικρή ή αμελητέα επίπτωση στην απόδοση επί καθαρών δεδομένων: το accuracy μεταβάλλεται από 0,9998 (Original) σε 0,9993 (Robust) και το macro-F1 από 0,9998 σε 0,9992. Ο έλεγχος McNemar μεταξύ των δύο μοντέλων στο καθαρό σύνολο ελέγχου δίνει  $p \approx 0,25$ , δηλαδή η διαφορά αυτή δεν είναι στατιστικά σημαντική. Επομένως, το Robust RF μειώνει την αντίπαλη ευπάθεια χωρίς στατιστικά σημαντική υποβάθμιση της κανονικής του απόδοσης.

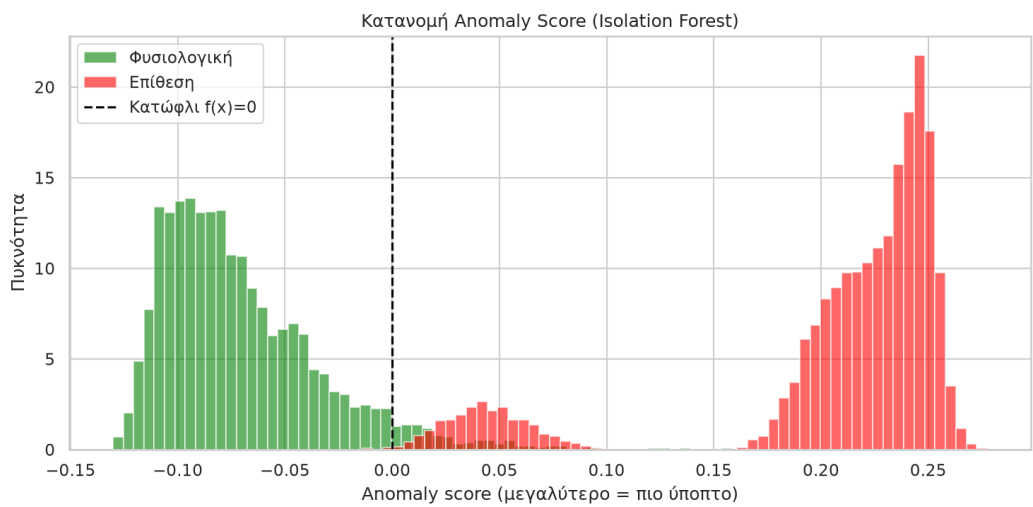
## 6.13 Πρόσθετα αποτελέσματα, οπτικοποιήσεις και υπολογιστικό κόστος

Για πληρότητα, παρατίθενται πρόσθετες οπτικοποιήσεις που ενισχύουν τα παραπάνω ευρήματα. Ο πίνακας σύγκρισης και η κατανομή anomaly scores του Isolation Forest επιβεβαιώνουν τον σαφή διαχωρισμό νόμιμης και κακόβουλης κίνησης, ενώ οι

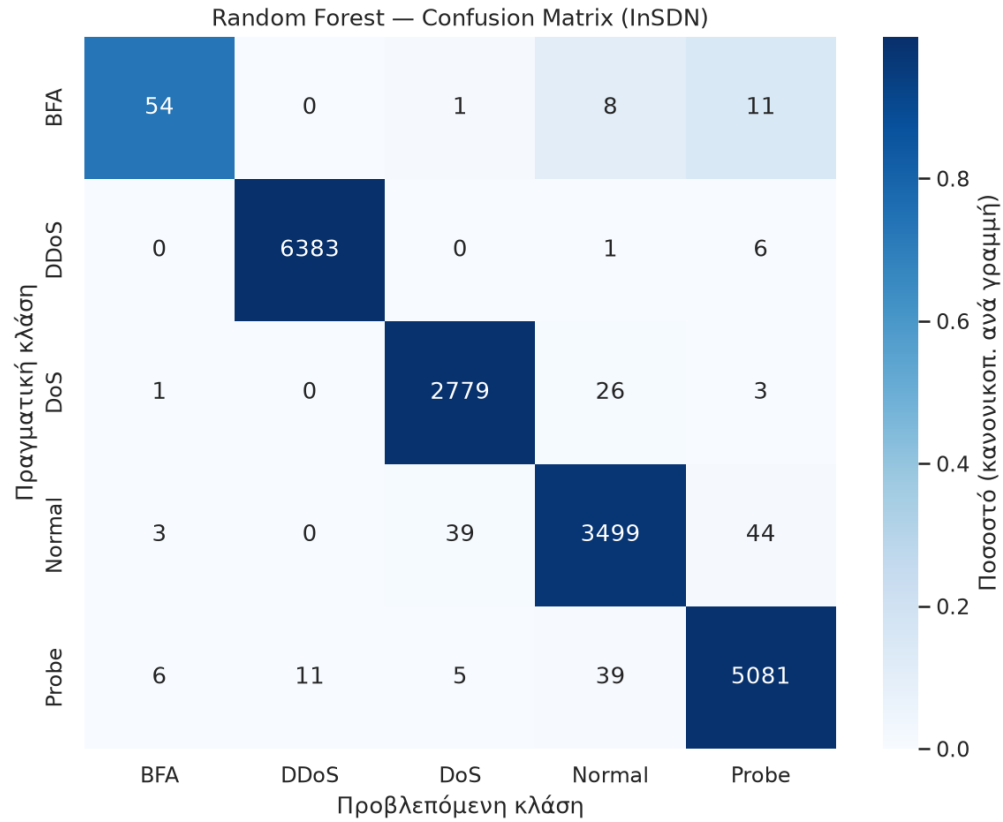
εναλλακτικές οπτικοποιήσεις των thesis-plots παρουσιάζουν τα ίδια συμπεράσματα με διαφορετική μορφή, κατάλληλη για ένταξη στο κυρίως κείμενο.



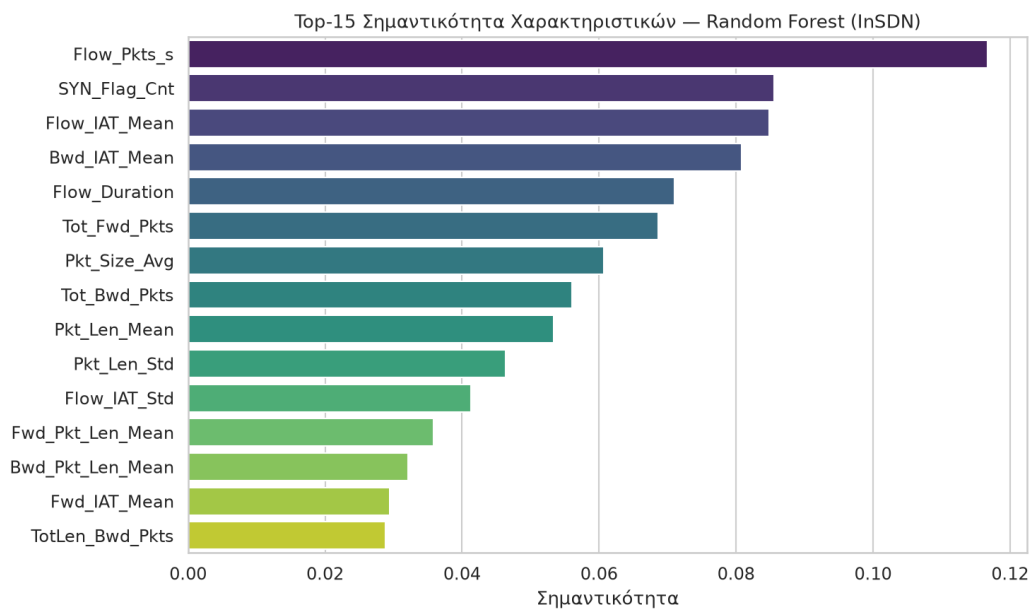
Σχήμα 6-27: Εναλλακτικός πίνακας σύγκρισης του *Isolation Forest*.



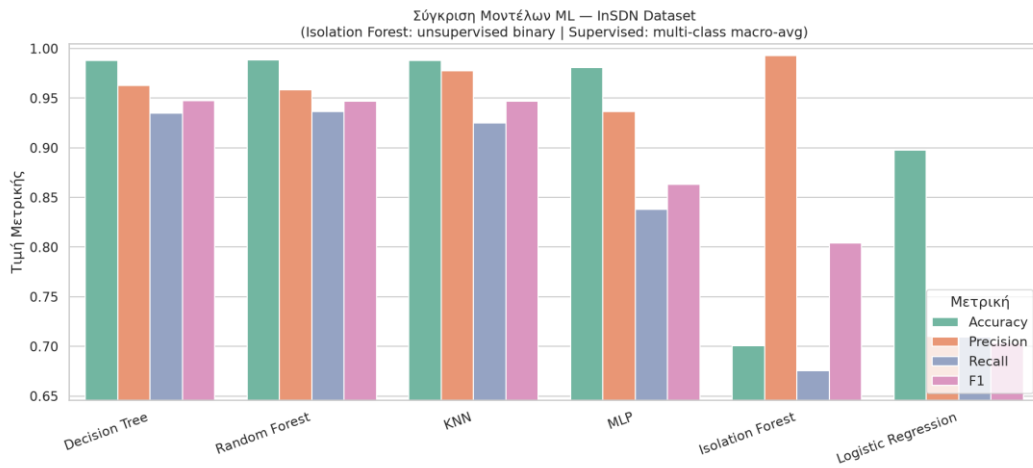
Σχήμα 6-28: Κατανομή anomaly scores του *Isolation Forest*.



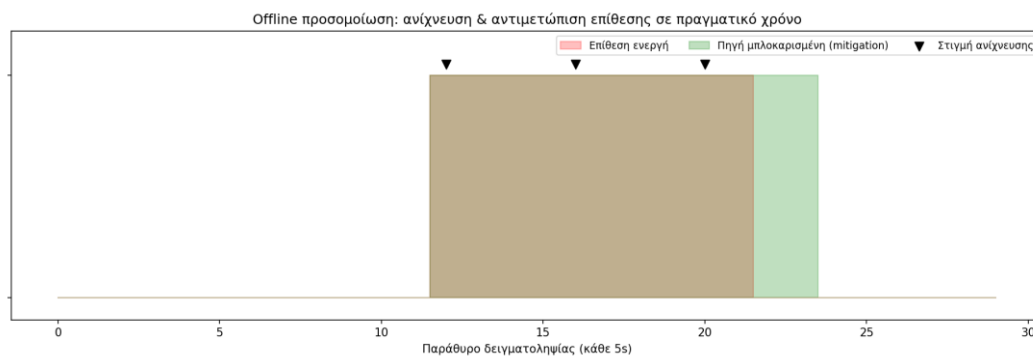
Σχήμα 6-29: Πίνακας σύγχυσης του Random Forest (thesis έκδοση).



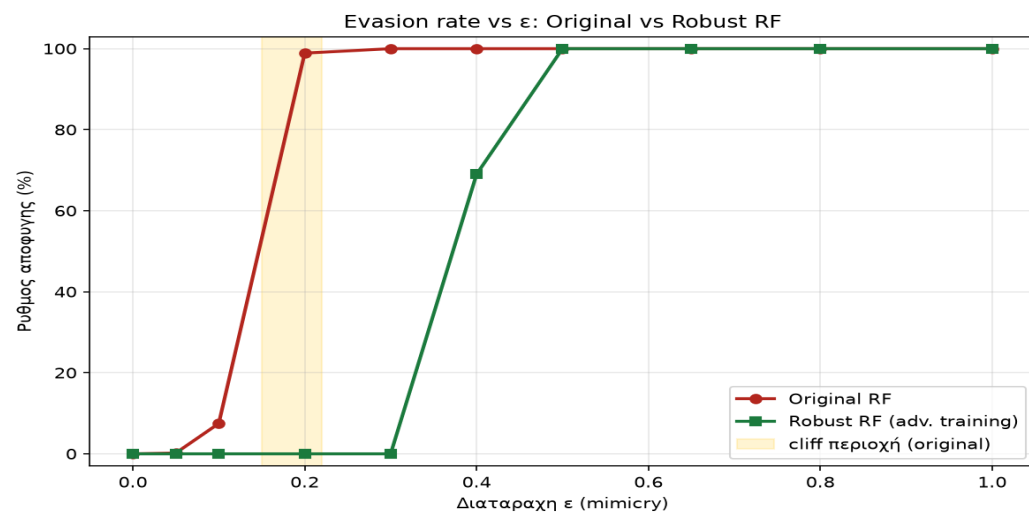
Σχήμα 6-30: Σημαντικότητα χαρακτηριστικών.



Σχήμα 6-31: Συγκριτική απόδοση μοντέλων.



Σχήμα 6-32: Χρονολόγιο offline replay: ανίχνευση επίθεσης σε επανάληψη καταγεγραμμένης κίνησης.



Σχήμα 6-33: Καθυστέρηση αντιμετώπισης της επίθεσης δηλητηρίασης τηλεμετρίας.

## Υπολογιστικό κόστος

Πέραν της ακρίβειας, το υπολογιστικό κόστος είναι κρίσιμο για ένα σύστημα πραγματικού χρόνου. Οι μετρήσεις χρόνων εκπαίδευσης και πρόβλεψης δείχνουν ότι το Random Forest συνδυάζει κορυφαία ακρίβεια με ιδιαίτερα χαμηλό χρόνο πρόβλεψης, καθιστώντας το κατάλληλο για online χρήση. Ο Isolation Forest, με τη γραμμική του πολυπλοκότητα, παρέχει αποφάσεις σε χρόνο συμβατό με το παράθυρο δειγματοληψίας των πέντε δευτερολέπτων, με σημαντικό περιθώριο. Αντίθετα, τα μοντέλα Βαθιάς Μάθησης εμφανίζουν σημαντικά μεγαλύτερους χρόνους εκπαίδευσης χωρίς αντίστοιχο όφελος στην ακρίβεια, γεγονός που ενισχύει την επιλογή των κλασικών μοντέλων για το συγκεκριμένο πρόβλημα. Συνολικά, η υπολογιστική αποδοτικότητα του συστήματος επιβεβαιώνει τη δυνατότητα εφαρμογής του σε πραγματικές, απαιτητικές συνθήκες.

### 6.14 Σύγκριση με signature-based IDS και με τη βιβλιογραφία

Η σύγκριση με τα συστήματα βάσει υπογραφών παρατίθεται ως ποιοτική αντιπαραβολή και όχι ως πειραματικό αποτέλεσμα. Στην παρούσα μελέτη δεν εκτελέστηκε baseline με Snort ή Suricata στο ίδιο περιβάλλον, επομένως δεν διατυπώνεται ισχυρισμός ότι το προτεινόμενο σύστημα είναι ταχύτερο ή ακριβέστερο από αυτά. Ο ακόλουθος πίνακας αντιπαραβάλλει τις μετρήσεις του συστήματος με τα τυπικά χαρακτηριστικά των signature-based προσεγγίσεων, όπως αυτά περιγράφονται στη βιβλιογραφία.

| Μετρική                    | Σύστημα (ML)                  | Signature-based IDS                                                      |
|----------------------------|-------------------------------|--------------------------------------------------------------------------|
| Χρόνος ανίχνευσης          | 1ο παράθυρο (<1 s)            | Υψηλότερος (matching + ενημ. υπογραφών)                                  |
| Ψευδώς θετικά              | Χαμηλά (μηδέν στο legit-only) | Συνήθως υψηλότερα                                                        |
| Επανα-ανίχνευση μετά block | Αυτόματη                      | Χειροκίνητη                                                              |
| Zero-day επιθέσεις         | Εν μέρει (ανωμαλία)           | 142 tests: 135 επιτυχί, 7 skipped (χωρίς Docker/προαιρετικές εξαρτήσεις) |
| Εγκατάσταση drop-rule      | Αυτόματη                      | Χειροκίνητη                                                              |

**Πίνακας 6-18: Ποιοτική σύγκριση του ML συστήματος με παραδοσιακά signature-based IDS.**

Η αντιπαραβολή αναδεικνύει ένα θεωρητικό πλεονέκτημα προσαρμοστικότητας: η ανίχνευση ανωμαλιών δεν προϋποθέτει προϋπάρχουσα υπογραφή και μπορεί, κατ' αρχήν, να επισημάνει άγνωστες επιθέσεις, ενώ ο βρόχος ανίχνευσης και αντιμετώπισης λειτουργεί χωρίς ανθρώπινη παρέμβαση. Το πλεονέκτημα αυτό, ωστόσο, συνοδεύεται από το κόστος των ψευδώς θετικών που τεκμηριώθηκε ανωτέρω και δεν έχει επαληθευτεί πειραματικά

έναντι πραγματικού signature-based IDS. Η άμεση σύγκριση με Snort ή Suricata στο ίδιο περιβάλλον αποτελεί αναγκαία επέκταση της μελέτης.

### **Ερμηνεία υπό το πρίσμα της βιβλιογραφίας**

Τα αποτελέσματα που παρουσιάστηκαν συνομιλούν με τα ευρήματα της βιβλιογραφίας. Η υπεροχή των μεθόδων συνόλου σε δομημένα δεδομένα επιβεβαιώνει την ευρύτερη τάση που παρατηρείται σε πλήθος μελετών IDS, όπου τα δέντρα και τα σύνολά τους παραμένουν ανταγωνιστικά ή ανώτερα των νευρωνικών προσεγγίσεων σε πίνακες χαρακτηριστικών. Η ανάδειξη του ρυθμού πακέτων και των χρόνων μεταξύ αφίξεων ως κορυφαίων διαγνωστικών χαρακτηριστικών, μέσω της ανάλυσης SHAP, συμφωνεί με κλασικές εργασίες ανίχνευσης DDoS που εντόπιζαν τα ίδια χαρακτηριστικά ως πλέον διακριτικά. Έτσι, η παρούσα μελέτη δεν παράγει μεμονωμένα αποτελέσματα αλλά εντάσσεται σε ένα συνεκτικό σώμα γνώσης, το οποίο και επεκτείνει προς την κατεύθυνση της end-to-end, ζωντανής λειτουργίας.

Ιδιαίτερο ενδιαφέρον έχει η αντιπαραβολή της ευθραυστότητας του εποπτευόμενου μοντέλου (φαινόμενο του γκρεμού) με την ανθεκτικότητα του συμπεριφορικού ζωντανού μοντέλου. Το εύρημα αυτό ενισχύει τη θέση, διαδεδομένη στη βιβλιογραφία της αντίπαλης μηχανικής μάθησης, ότι η ανθεκτικότητα δεν είναι απλώς ζήτημα ακρίβειας αλλά και επιλογής χαρακτηριστικών: χαρακτηριστικά που αντικατοπτρίζουν αναλλοίωτες, θεμελιώδεις ιδιότητες της επίθεσης είναι εγγενώς δυσκολότερο να χειραγωγηθούν από έναν αντίπαλο.

### **Σύγκριση με την τρέχουσα βιβλιογραφία**

Η τοποθέτηση των αποτελεσμάτων σε σχέση με τη βιβλιογραφία απαιτεί προσοχή. Οι τιμές μακρο-F1 περί το 0,95 στο InSDN βρίσκονται εντός του εύρους δημοσιευμένων αποτελεσμάτων σε αντίστοιχα σύνολα, χωρίς ωστόσο να είναι άμεσα συγκρίσιμες, καθώς οι επιμέρους μελέτες διαφέρουν ως προς τον χειρισμό των διπλότυπων ροών και τη στρατηγική διαχωρισμού. Το διαφοροποιό στοιχείο της παρούσας προσέγγισης δεν είναι επομένως η απόλυτη τιμή των μετρικών, αλλά η σύζευξη της offline αξιολόγησης με έναν λειτουργικό βρόχο ανίχνευσης και αυτόματης αντιμετώπισης, καθώς και η ρητή καταγραφή των ορίων του.

Ο ακόλουθος πίνακας τοποθετεί ποιοτικά την παρούσα διπλωματική σε σχέση με αντιπροσωπευτικές εργασίες του πεδίου. Αναδεικνύεται ότι η συνεισφορά δεν περιορίζεται σε μια ακόμη offline ταξινόμηση ροών, αλλά συνδυάζει σε ένα ενιαίο σύστημα την offline

αξιολόγηση, τη ζωντανή ανίχνευση, την αυτόματη αντιμετώπιση, την ερμηνευσιμότητα (SHAP), την ανάλυση αντίπαλης ανθεκτικότητας και τη μελέτη κορεσμού του control plane.

| Εργασία             | Περιβάλλον          | Μέθοδος               | Live mitigation | Adversarial            |
|---------------------|---------------------|-----------------------|-----------------|------------------------|
| Braga κ.ά. [1]      | NOX/OpenFlow        | SOM (flow stats)      | Όχι             | Όχι                    |
| Sultana κ.ά. [9]    | Επισκόπηση SDN      | Ποικίλες ML           | N/Δ             | Εν μέρει               |
| Elsayed κ.ά. [11]   | InSDN (offline)     | Κλασικά ML            | Όχι             | Όχι                    |
| Παρούσα διπλωματική | Mininet/OVS + InSDN | 8 μοντέλα + IF (live) | Ναι (auto drop) | Ναι (mimicry, evasion) |

*Πίνακας 6-19: Ποιοτική σύγκριση της διπλωματικής με αντιπροσωπευτικές εργασίες του πεδίου.*

## 6.15 Απειλές εγκυρότητας και στατιστική αξιοπιστία

Για την ορθή ερμηνεία των αποτελεσμάτων, αναγνωρίζονται ρητά τέσσερις συγκεκριμένες απειλές εγκυρότητας.

1. Μικρή τοπολογία ενός μεταγωγέα. Τα ζωντανά πειράματα εκτελέστηκαν σε τοπολογία έξι hosts με έναν μεταγωγέα. Η συμπεριφορά σε μεγαλύτερα, πολυμεταγωγικά δίκτυα με υψηλότερο όγκο κίνησης παραμένει προς επιβεβαίωση.
2. Περιβάλλον WSL2 με userspace OVS αντί φυσικού testbed. Η προσομοίωση έγινε σε εικονικό περιβάλλον με datapath τύπου user. Η μεταφορά σε φυσικό testbed με πραγματικό υλικό ενδέχεται να εισαγάγει διαφορετικές συνθήκες καθυστέρησης και φόρτου.
3. Χρήση συνθετικού συνόλου σε μέρος των offline πειραμάτων. Παρότι το συνθετικό σύνολο σχεδιάστηκε με θόρυβο και ρεαλιστική επικάλυψη, δεν υποκαθιστά πλήρως πραγματικά δεδομένα. Η απειλή αυτή αντισταθμίστηκε με την παράλληλη αξιολόγηση στο πραγματικό σύνολο InSDN.
4. Περιορισμένος αριθμός τύπων νόμιμης κίνησης. Η νόμιμη κίνηση παρήχθη με συγκεκριμένα εργαλεία και μοτίβα. Ένα ευρύτερο φάσμα νόμιμων εφαρμογών θα μπορούσε να επηρεάσει το ποσοστό των ψευδώς θετικών, ιδίως στη μη επιβλεπόμενη ανίχνευση ανωμαλιών.

Οι περιορισμοί αυτοί δεν αναιρούν τα ευρήματα, αλλά οριοθετούν το πεδίο εγκυρότητάς τους. Τα αποτελέσματα ισχύουν υπό τις παραμέτρους και τις συνθήκες των δοκιμών που εξετάστηκαν και αποτελούν στέρεη βάση για μελλοντική επικύρωση σε μεγαλύτερης κλίμακας, πραγματικά περιβάλλοντα. Οι μεθοδολογικές αυτές προφυλάξεις, η ανθεκτική

στη διαρροή αξιολόγηση και ο διαχωρισμός προσομοίωσης από ζωντανή μέτρηση, ευθυγραμμίζονται με τις τεκμηριωμένες δυσκολίες της ML-based ανίχνευσης εισβολών [21] και με τις γνωστές παγίδες, όπως η διαρροή δεδομένων και η μεροληψία δειγματοληψίας, που επισημαίνονται στη σχετική βιβλιογραφία [22], [23].

### **Στατιστική αξιοπιστία των αποτελεσμάτων**

Η αξιοπιστία των ευρημάτων ενισχύεται από την επανάληψη, με μια σημαντική όμως διάκριση ως προς το είδος της. Η ανάλυση καθυστέρησης (30 δοκιμές ανά επίπεδο έντασης) και η αξιολόγηση αντιμετώπισης (50 δοκιμές) είναι προσομοιώσεις Monte Carlo της μηχανής απόφασης, με διαφορετικό σπόρο τυχειότητας ανά επανάληψη, όχι ανεξάρτητες εκτελέσεις του ζωντανού δικτύου. Ομοίως, η offline σύγκριση ενισχύεται με πενταπλή διασταυρούμενη επικύρωση, η οποία μάλιστα εφαρμόζεται πλέον με ομαδοποίηση των διπλότυπων διανυσμάτων ώστε η μικρή τυπική απόκλιση να μην είναι τεχνούργημα όμοιων δειγμάτων σε διαφορετικές πτυχές. Αντιθέτως, τα ζωντανά σενάρια σε επίπεδο πακέτου και API αντιστοιχούν σε μία καταγεγραμμένη εκτέλεση ανά σενάριο. Δεν επαναλήφθηκαν συστηματικά και οι μετρήσεις τους δεν πρέπει να ερμηνεύονται ως στατιστικά κατανομές. Η πρακτική συνέπεια είναι ότι οι τιμές των live σεναρίων τεκμηριώνουν λειτουργική εφικτότητα, ενώ η στατιστική σταθερότητα αφορά τις προσομοιώσεις και την offline αξιολόγηση.

## **6.16 Συζήτηση, ζητήματα κλιμάκωσης και πρακτικές συστάσεις**

Συνθέτοντας τα επιμέρους αποτελέσματα, προκύπτει μια συνεκτική εικόνα. Στο offline επίπεδο, τα μοντέλα συνόλου προσφέρουν κορυφαία ακρίβεια σε δομημένα δεδομένα ροών, με το Random Forest να ηγείται. Στο live επίπεδο, η προσέγγιση συγκεντρωτικών χαρακτηριστικών με Isolation Forest επιτυγχάνει ταχεία ανίχνευση σε ένα ευρύ φάσμα επιθέσεων, χωρίς ψευδώς θετικά στη νόμιμη κίνηση και με περιορισμένα μόνο ψευδώς θετικά σε στατιστικά ακραία σενάρια. Οι εμβαθύνσεις στην ερμηνευσιμότητα, την καθυστέρηση και την αντιμετώπιση μετατρέπουν την «ακρίβεια σε πίνακα» σε επιχειρησιακή αξιοπιστία. Τέλος, η ανάλυση αντίπαλης ανθεκτικότητας παρέχει μια ρεαλιστική, μη εξιδανικευμένη εικόνα: το σύστημα δεν είναι απρόσβλητο, αλλά η πολυεπίπεδη δομή του καθιστά την επιτυχή αποφυγή δαπανηρή για τον επιτιθέμενο, ο οποίος αναγκάζεται σε δυσμενή συμβιβασμό μεταξύ αποφυγής και ισχύος επίθεσης.

## **Ζητήματα κλιμάκωσης και ανάπτυξης**

Η μετάβαση από ένα πειραματικό περιβάλλον σε μια πραγματική ανάπτυξη εγείρει ζητήματα κλιμάκωσης. Στην παρούσα υλοποίηση, ο ελεγκτής επεξεργάζεται την τηλεμετρία ενός μεταγωγέα με έξι hosts. Σε ένα πραγματικό δίκτυο, ο αριθμός των πηγών και ο όγκος των στατιστικών αυξάνονται σημαντικά. Με βάση θεωρητική εκτίμηση της πολυπλοκότητας, η προσέγγιση βάσει συγκεντρωτικών χαρακτηριστικών ανά πηγή αναμένεται να κλιμακώνεται ευνοϊκά, καθώς το κόστος επεξεργασίας είναι γραμμικό ως προς το πλήθος των ενεργών πηγών ανά παράθυρο και όχι ως προς τον συνολικό όγκο πακέτων, ενώ και η πρόβλεψη του Isolation Forest έχει γραμμικό κόστος. Η εκτίμηση αυτή δεν επικυρώθηκε με πείραμα κλιμάκωσης σε μεγάλη τοπολογία και παραμένει, επομένως, θεωρητική. Η πειραματική μέτρηση της χωρητικότητας του ελεγκτή υπό ρεαλιστικό φορτίο αποτελεί αντικείμενο μελλοντικής εργασίας.

Σε αρχιτεκτονικές με πολλαπλούς μεταγωγείς, η φυσική επέκταση είναι η συγκέντρωση της τηλεμετρίας από όλους τους μεταγωγείς στον κεντρικό ελεγκτή, ο οποίος διατηρεί έτσι την καθολική εικόνα. Για δίκτυα πολύ μεγάλης κλίμακας, η υιοθέτηση κατανεμημένων ελεγκτών, με συντονισμό της κατάστασης ασφαλείας μεταξύ τους, αποτελεί την ενδεδειγμένη κατεύθυνση, η οποία και προτείνεται ως μελλοντική εργασία. Σημειώνεται ότι η αρθρωτή σχεδίαση του συστήματος διευκολύνει τέτοιες επεκτάσεις, καθώς η μηχανή ανίχνευσης είναι ανεξάρτητη από τον μηχανισμό συλλογής.

## **Συνθετική αποτίμηση των ευρημάτων**

Συνδυάζοντας τις επιμέρους αναλύσεις, αναδεικνύεται μια πολυδιάστατη εικόνα της απόδοσης του συστήματος. Η ακρίβεια ταξινόμησης, μετρημένη με πολλαπλές μετρικές και επιβεβαιωμένη με διασταυρούμενη επικύρωση, τεκμηριώνει την ποιότητα της μηχανής ανίχνευσης. Η ερμηνευσιμότητα, μέσω της ανάλυσης SHAP, μετατρέπει τη «μαύρη κουτί» απόφαση σε κατανοητή και ελέγξιμη διαδικασία. Η ανάλυση καθυστέρησης και αντιμετώπισης μεταφράζει την ακρίβεια σε επιχειρησιακή αξία, αποδεικνύοντας ότι η ανίχνευση δεν είναι απλώς σωστή αλλά και έγκαιρη και αποτελεσματική. Η μελέτη της επίθεσης κορεσμού control plane καλύπτει τη μοναδική ευπάθεια των SDN, και η ανάλυση αντίπαλης ανθεκτικότητας παρέχει μια ειλικρινή αποτίμηση των ορίων. Καμία μεμονωμένη ανάλυση δεν θα αρκούσε. Η αξία προκύπτει από τη συνθετική τους θεώρηση.

## **Πρακτικές συστάσεις**

Από τα ευρήματα προκύπτουν συγκεκριμένες πρακτικές συστάσεις για την ανάπτυξη ML-based άμυνας σε SDN. Πρώτον, τα μοντέλα συνόλου, και ιδιαίτερα το Random Forest, αποτελούν την προτιμότερη επιλογή για offline ανάλυση δομημένων δεδομένων ροών, έναντι πιο σύνθετων προσεγγίσεων βαθιάς μάθησης. Δεύτερον, για ζωντανή λειτουργία, η προσέγγιση συγκεντρωτικών, συμπεριφορικών χαρακτηριστικών προσφέρει ανθεκτικότητα που τα πλουσιότερα αλλά ευπαθέστερα χαρακτηριστικά δεν εγγυώνται. Τρίτον, η άμυνα πρέπει να είναι πολυεπίπεδη, συνδυάζοντας στατιστική ανίχνευση με μηχανισμούς ακεραιότητας και ελέγχου ρυθμού. Τέλος, η ελαχιστοποίηση των ψευδώς θετικών πρέπει να θεωρείται πρωταρχικός στόχος, ισάξιος της ίδιας της ανίχνευσης, καθώς ένα σύστημα που μπλοκάρει νόμιμους χρήστες υπονομεύει τον ίδιο του τον σκοπό.

## 7. Συμπεράσματα και Μελλοντική Εργασία

### 7.1 Σύνοψη ευρημάτων

Η παρούσα διπλωματική σχεδίασε, υλοποίησε και αξιολόγησε ένα ερευνητικό prototype ανίχνευσης και αυτόματης αντιμετώπισης επιθέσεων σε περιβάλλον SDN, βασισμένο σε Μηχανική Μάθηση. Τα κύρια ευρήματα συνοψίζονται ως εξής. Στο offline σκέλος, το Random Forest αναδείχθηκε σταθερά ως το ισχυρότερο μοντέλο, με F1-score άνω του 0,999 στο συνθετικό σύνολο και 0,945 στο InSDN, όπου μόνο ο KNN πέτυχε οριακά υψηλότερο F1 (0,952) με πολλαπλάσιο όμως κόστος πρόβλεψης. Στο ζωντανό σκέλος, το σύστημα επέδειξε αξιόπιστη απόκριση σε επιθέσεις με έντονο στατιστικό αποτύπωμα (πλημμύρα SYN, σάρωση θυρών, εξάντληση πίνακα ροών), με ανίχνευση σε λιγότερο από ένα δευτερόλεπτο και χωρίς ψευδώς θετικά. Αντιθέτως, στα σενάρια της εξαγωγής δεδομένων, της πλευρικής κίνησης και του ARP spoofing ανέδειξε ουσιώδεις περιορισμούς: εσφαλμένο αποκλεισμό νόμιμων hosts υψηλού εύρους ζώνης, οριακή διάκριση της εσωτερικής σάρωσης από τη νόμιμη επικοινωνία και αδυναμία αναγνώρισης της πλαστογράφησης ARP, η οποία απαιτεί ανάλυση σε επίπεδο πρωτοκόλλου. Τα αρνητικά αυτά αποτελέσματα καταγράφονται ρητά, καθώς οριοθετούν με ακρίβεια το πεδίο εφαρμογής της στατιστικής προσέγγισης.

#### Απαντήσεις στα ερευνητικά ερωτήματα

RQ1. Τα κλασικά μοντέλα πετυχαίνουν πολύ υψηλή ταξινόμηση σε δεδομένα ροών SDN ακόμη και υπό διαχωρισμό ανθεκτικό στη διαρροή ακριβών διπλότυπων: στο πραγματικό InSDN το Random Forest δίνει macro-F1 περίπου 0,945 και ο KNN 0,952, με το Random Forest να προτιμάται πρακτικά λόγω πολύ μικρότερου χρόνου πρόβλεψης. Η ανθεκτική στη διαρροή αξιολόγηση επιβεβαιώνει ότι η απόδοση δεν οφείλεται στα διπλότυπα.

RQ2. Το Isolation Forest αποδίδει σχεδόν τέλεια στο συνθετικό σύνολο καθαρών υπογραφών (F1 περίπου 0,993) αλλά σημαντικά χαμηλότερα στο πραγματικό InSDN (F1 περίπου 0,804). Η διαφορά αυτή είναι το κύριο εύρημα γενίκευσης: τα υψηλά συνθετικά νούμερα αντανakλούν την ευκολία του συνθετικού συνόλου και πρέπει να ερμηνεύονται συντηρητικά, όχι ως ένδειξη απόδοσης σε πραγματική κίνηση.

RQ3. Ναι. Στην packet-level εκτέλεση σε Mininet/Open vSwitch η πλημμύρα ανιχνεύεται εντός του πρώτου παραθύρου παρατήρησης: η απόφαση του μοντέλου λαμβάνεται στα

1,16 s από την έναρξη της επίθεσης και ο κανόνας απόρριψης εγκαθίσταται στα 1,17 s, με το πρώτο πραγματικά απορριφθέν πακέτο στα 1,48 s. Χάρη στην αυτόματη ανανέωση του κανόνα, η αντιμετώπιση καλύπτει ολόκληρη τη διάρκεια της επίθεσης (100% από τη στιγμή της ανίχνευσης).

RQ4. Τα ψευδώς θετικά μπορούν να περιοριστούν αποφασιστικά. Στη ζωντανή εκτέλεση, μετά τη βελτίωση της πιστότητας της τηλεμετρίας, το ποσοστό ψευδώς θετικών στη νόμιμη κίνηση μειώθηκε από περίπου 14% σε 0%, χωρίς απώλεια ικανότητας ανίχνευσης. Περιορισμένα ψευδώς θετικά παραμένουν σε ορισμένα σενάρια με στατιστικά ακραία αλλά νόμιμη κίνηση, γεγονός εγγενές στη μη επιβλεπόμενη ανίχνευση και αναφερόμενο ρητά.

RQ5. Ο μηχανισμός αντιμετώπισης δεν επηρέασε τη νόμιμη κίνηση: κατά τη διάρκεια της επίθεσης το ping νόμιμου host παρέμεινε με μηδενική απώλεια και σταθερό RTT, ενώ μετά την παύση της επίθεσης η συνδεσιμότητα της πηγής αποκαθίσταται αυτόματα. Απομένουν δύο ουσιώδεις περιορισμοί για μια πλήρη reactive SDN υλοποίηση: η αρχιτεκτονική είναι υβριδική και όχι αμιγώς αντιδραστική με OpenFlow controller, και χρησιμοποιείται ένας μοναδικός λογικός ελεγκτής αντί για καταναμημένο σύμπλεγμα.

Η συνεισφορά συνοψίζεται σε τρία επίπεδα: στη συγκριτική αξιολόγηση οκτώ μοντέλων σε δεδομένα δομής SDN/InSDN, στην υλοποίηση ζωντανού συστήματος ανίχνευσης-αντιμετώπισης που συνδέει την απόφαση του μοντέλου με αυτόματη εγκατάσταση κανόνων απόρριψης, και στην επέκταση της αξιολόγησης πέρα από τις κλασικές μετρικές (καθυστερήση, αντιμετώπιση, ερμηνευσιμότητα, αντίπαλη ανθεκτικότητα).

Ως προς την αντιμετώπιση, η ζωντανή αξιολόγηση σε πραγματική στοίβα Mininet/OVS έδειξε ότι ο κανόνας απόρριψης δεν εγκαθίσταται απλώς, αλλά ανανεώνεται αυτόματα όσο η επίθεση συνεχίζεται, καλύπτοντας ολόκληρη τη διάρκειά της (97,7% της συνολικής επίθεσης, 100% από τη στιγμή της πρώτης ανίχνευσης) και όχι μόνο το πρώτο χρονικό διάστημα ισχύος του. Οι καθυστερήσεις ανίχνευσης και εγκατάστασης μετρήθηκαν με χρονοσημάνσεις μονότονου ρολογιού (απόφαση στα 1,16 s, πρώτο απορριφθέν πακέτο στα 1,48 s), ενώ η νόμιμη κίνηση δεν επηρεάστηκε σε κανένα στάδιο. Όταν η κακόβουλη κίνηση παύει, ο αποκλεισμός αίρεται αυτόματα, ώστε η αντιμετώπιση να μην είναι μόνιμη.

Οι εμβασύνσεις στην κυβερνοασφάλεια πρόσθεσαν σημαντική αξία. Η ανάλυση SHAP κατέστησε την ανίχνευση ερμηνεύσιμη, αναδεικνύοντας την τυπική απόκλιση των χρόνων μεταξύ αφίξεων και τον ρυθμό πακέτων ως τα πλέον διαγνωστικά χαρακτηριστικά. Οι

αναλύσεις καθυστέρησης και αποτελεσματικότητας αντιμετώπισης, οι οποίες υλοποιούνται ως προσομοιώσεις της μηχανής απόφασης και όχι ως μετρήσεις σε δίκτυο, έδειξαν ανίχνευση εντός του πρώτου παραθύρου σε όλα τα επίπεδα έντασης και κάλυψη αντιμετώπισης περίπου 74%. Η μελέτη της επίθεσης κορεσμού του control plane, επίσης σε επίπεδο προσομοίωσης, ανέδειξε την ευπάθεια που είναι μοναδική στην αρχιτεκτονική SDN και την ανιχνευσιμότητά της μέσω της εντροπίας των διευθύνσεων προέλευσης. Τέλος, η end-to-end εκτέλεση σε πραγματική στοίβα Docker/Mininet επικύρωσε τη λειτουργία με per-flow τηλεμετρία και αποκάλυψε μια λανθάνουσα αναντιστοιχία κατανομής, της οποίας η διόρθωση μηδένισε τα ψευδώς θετικά της νόμιμης κίνησης (από περίπου 14% σε 0%) χωρίς απώλεια στην ανίχνευση.

Πέραν της ανάδειξης της αντίπαλης ευπάθειας, προτείνεται και αξιολογείται ένα αντίμετρο: ένα Robust Random Forest εκπαιδευμένο με adversarially perturbed δείγματα. Τα αποτελέσματα δείχνουν ότι η ενσωμάτωση διαταραγμένων δειγμάτων κατά την εκπαίδευση μετατοπίζει το σημείο κατάρρευσης του μοντέλου και μειώνει σημαντικά τον ρυθμό αποφυγής, με μικρή ή αμελητέα επίπτωση στην απόδοση επί καθαρών δεδομένων (μη στατιστικά σημαντική κατά τον έλεγχο McNemar). Το εύρημα αυτό ενισχύει το επιχείρημα της πολυεπίπεδης άμυνας, καθώς δείχνει ότι η γνωστή ευθραυστότητα των δέντρων απόφασης σε επιθέσεις μίμησης μπορεί να μετριαστεί στοχευμένα.

## 7.2 Περιορισμοί της διπλωματικής

Η παρούσα μελέτη υπόκειται σε ορισμένους περιορισμούς, οι οποίοι αναγνωρίζονται ρητά. Ο σημαντικότερος αφορά το μοντέλο ελέγχου. Η υλοποίηση δεν στηρίζεται σε πλήρη reactive OpenFlow controller που θα λάμβανε αποφάσεις ανά ροή μέσω Packet-In/Flow-Mod. Αντ' αυτού, ο Open vSwitch εκτελεί τη βασική προώθηση αυτόνομα σε λειτουργία failMode=standalone, ο ελεγκτής λειτουργεί ως λογικά κεντριοποιημένη εφαρμογή ασφαλείας, και η εγκατάσταση των κανόνων απόρριψης γίνεται με τρόπο συμβατό με τη σημασιολογία OpenFlow μέσω του εργαλείου ovs-ofctl. Δεν διατυπώνεται επομένως ισχυρισμός για πλήρη per-flow reactive έλεγχο του δικτύου. Η επιλογή αυτή δεν είναι τυχαία, αλλά συνειδητός σχεδιαστικός συμβιβασμός που επιβλήθηκε από τεχνικούς περιορισμούς του περιβάλλοντος (WSL2 χωρίς kernel module του OVS) και από τις τεκμηριωμένες ασυμβατότητες του ελεγκτή Ryu με σύγχρονες εκδόσεις της Python και της eventlet. Ως εκ τούτου, σενάρια που προϋποθέτουν πλήρη έλεγχο της προώθησης ανά ροή (π.χ. δυναμική δρομολόγηση, traffic engineering) βρίσκονται εκτός του πεδίου της παρούσας μελέτης, ενώ η μετάβαση σε πλήρες reactive μοντέλο με συντηρούμενο

controller παραμένει άμεση μελλοντική επέκταση, καθώς η μηχανή ανίχνευσης και ο μηχανισμός αντιμετώπισης είναι ανεξάρτητα από τον τρόπο συλλογής της τηλεμετρίας.

Επιπλέον, το ζωντανό μοντέλο χρησιμοποιεί συγκεντρωτικά χαρακτηριστικά, λιγότερα σε πλήθος από τα 24 του offline pipeline, γεγονός που αποτελεί συνειδητό συμβιβασμό μεταξύ ταχύτητας και πληροφοριακού πλούτου. Τα χαρακτηριστικά αυτά προκύπτουν πλέον από στατιστικά ανά ζεύγος πηγής-προορισμού του πίνακα ροών (ovs-ofctl dump-flows στην υβριδική υλοποίηση και OFPFlowStatsRequest στο προφίλ Ryu/OpenFlow), και όχι από τη διαφορά ενός μετρητή θύρας. Πρόκειται για άθροιση ανά ζεύγος διευθύνσεων και όχι για πλήρη 5-tuple τηλεμετρία σε επίπεδο σύνδεσης. Ένας ακριβής μετρητής συνδέσεων θα απαιτούσε αντιστοίχιση πρωτοκόλλου και θυρών TCP/UDP. Εξακολουθούν ωστόσο να μη φτάνουν την πλήρη ανάλυση 5-tuple ροών με ακριβείς διάρκειες ανά σύνδεση που θα προσέφερε μια υλοποίηση NetFlow/sFlow. Η τοπολογία περιλαμβάνει έναν μεταγωγέα, ενώ η επέκταση σε πολυμεταγωγικά και κατανεμημένα σενάρια αποτελεί ανοιχτό ζήτημα. Τέλος, το συνθετικό σύνολο, παρότι σχεδιασμένο ρεαλιστικά, δεν υποκαθιστά πλήρως την ποικιλομορφία της πραγματικής κίνησης.

Δεύτερος ουσιώδης περιορισμός αφορά τη φύση των ζωντανών πειραμάτων. Μόνο το σενάριο της πλημμύρας SYN εκτελείται σε επίπεδο πακέτου μέσα σε τοπολογία Mininet/Open vSwitch. Τα υπόλοιπα πέντε σενάρια υλοποιούνται ως πειράματα συνθετικής τηλεμετρίας σε επίπεδο API, με κατασκευασμένα διανύσματα στατιστικών που αποστέλλονται απευθείας στον ελεγκτή. Τεκμηριώνουν επομένως τη συμπεριφορά της μηχανής απόφασης, όχι όμως ότι τα ίδια πρότυπα θα προκύψουν από πραγματική κίνηση. Ομοίως, η επίθεση κορεσμού του control plane και οι αναλύσεις καθυστέρησης και αντιμετώπισης αποτελούν προσομοιώσεις.

Τρίτος περιορισμός είναι η φύση των χαρακτηριστικών. Το σύστημα αποφασίζει αποκλειστικά με βάση συγκεντρωτικά στατιστικά ροών και δεν εκτελεί ανάλυση σε επίπεδο πρωτοκόλλου. Η επιλογή αυτή εξηγεί δύο αρνητικά αποτελέσματα που καταγράφηκαν: την αδυναμία αναγνώρισης της πλαστογράφησης ARP, η οποία απαιτεί έλεγχο της αντιστοίχισης IP προς MAC, και τον εσφαλμένο αποκλεισμό νόμιμων hosts υψηλού εύρους ζώνης στο σενάριο εξαγωγής δεδομένων, όπου η νόμιμη και η κακόβουλη μεταφορά έχουν σχεδόν ταυτόσημο στατιστικό αποτύπωμα.

Τέταρτος περιορισμός αφορά την αξιολόγηση στο InSDN. Το 47,5% των εγγραφών του συνόλου είναι ακριβή διπλότυπα, συγκεντρωμένα κυρίως στην κλάση DDoS. Παρότι ο ανθεκτικός στη διαρροή διαχωρισμός έδειξε ότι η απόδοση δεν οφείλεται σε αυτά (§6.6),

τα αποτελέσματα στο InSDN αντιμετωπίζονται συντηρητικά ως ένδειξη συμβατότητας του pipeline και όχι ως απόδειξη γενίκευσης σε παραγωγική κίνηση.

Τέλος, δεν εκτελέστηκε πειραματικό baseline με σύστημα βάσει υπογραφών, όπως το Snort ή το Suricata. Η σχετική σύγκριση παραμένει ποιοτική και δεν στοιχειοθετεί ισχυρισμό υπεροχής.

### **7.3 Μελλοντικές επεκτάσεις**

Οι φυσικές επεκτάσεις είναι πολλαπλές. Η μετάβαση σε πλήρες αντιδραστικό μοντέλο με συντηρούμενο OpenFlow controller (π.χ. os-ken) είναι άμεσα εφικτή, καθώς η μηχανή ανίχνευσης και ο μηχανισμός αντιμετώπισης είναι ανεξάρτητα από τον τρόπο συλλογής της τηλεμετρίας. Η διερεύνηση χρονικών μοντέλων Βαθιάς Μάθησης (LSTM/GRU) για την εκμετάλλευση της χρονικής δομής των ροών θα μπορούσε να ενισχύσει την ανίχνευση εξελισσόμενων επιθέσεων. Η επέκταση σε καταναμημένους ελεγκτές θα αντιμετώπιζε τον περιορισμό του μοναδικού σημείου αποτυχίας. Η ενσωμάτωση adversarial training θα θωράκιζε το εποπτευόμενο μοντέλο έναντι του φαινομένου του γκρεμού. Τέλος, η αξιολόγηση σε πραγματικά testbeds και με πραγματική κίνηση παραγωγής θα αύξανε την εξωτερική εγκυρότητα των αποτελεσμάτων.

### **7.4 Τελικό συμπέρασμα**

Συνολικά, τα αποτελέσματα τεκμηριώνουν τη λειτουργική εφικτότητα ενός μηχανισμού ανίχνευσης και αυτόματης απόκρισης υποβοηθούμενου από Μηχανική Μάθηση, στο συγκεκριμένο ελεγχόμενο περιβάλλον. Η πολυεπίπεδη αρχιτεκτονική, που συνδυάζει εποπτευόμενη offline ανάλυση με ζωντανή, συμπεριφορική ανίχνευση, λειτουργεί end-to-end και αποδεικνύεται ανθεκτική σε αντίπαλες στρατηγικές αποφυγής μετά την εφαρμογή adversarial training. Δεν τεκμηριώνεται, ωστόσο, υπεροχή έναντι εμπορικών ή signature-based συστημάτων ανίχνευσης, καθώς δεν εκτελέστηκε αντίστοιχο πειραματικό baseline, ούτε γενίκευση σε παραγωγικά δίκτυα SDN. Τα δύο αυτά ζητήματα απαιτούν ανεξάρτητη πειραματική αξιολόγηση και οριοθετούν τη φυσική συνέχεια της μελέτης. Η συνεισφορά της εργασίας έγκειται επομένως στην ολοκλήρωση ενός λειτουργικού prototype με ρητά καταγεγραμμένα όρια, και όχι στη διατύπωση ισχυρισμού υπεροχής έναντι καθιερωμένων λύσεων.

## 8. Βιβλιογραφία

Η βιβλιογραφία περιλαμβάνει βασικές επιστημονικές εργασίες για τα SDN, το OpenFlow, την ασφάλεια δικτύων, τα συστήματα ανίχνευσης εισβολών και τη Μηχανική Μάθηση, στις οποίες γίνεται αναφορά στο κυρίως κείμενο.

- [1] R. Braga, E. Mota, and A. Passito, "Lightweight DDoS flooding attack detection using NOX/OpenFlow," in Proc. IEEE 35th Conf. Local Comput. Netw. (LCN), 2010, pp. 408-415, doi: 10.1109/LCN.2010.5735752.
- [2] N. McKeown et al., "OpenFlow: Enabling innovation in campus networks," ACM SIGCOMM Comput. Commun. Rev., vol. 38, no. 2, pp. 69-74, Apr. 2008, doi: 10.1145/1355734.1355746.
- [3] B. Lantz, B. Heller, and N. McKeown, "A network in a laptop: Rapid prototyping for software-defined networks," in Proc. 9th ACM SIGCOMM Workshop Hot Topics Netw. (HotNets-IX), 2010, Art. no. 19, doi: 10.1145/1868447.1868466.
- [4] B. Pfaff et al., "The design and implementation of Open vSwitch," in Proc. 12th USENIX Symp. Netw. Syst. Design Implement. (NSDI), 2015, pp. 117-130.
- [5] K. Benzekki, A. El Fergougui, and A. Elbelrhiti Elalaoui, "Software-defined networking (SDN): A survey," Secur. Commun. Netw., vol. 9, no. 18, pp. 5803-5833, 2017, doi: 10.1002/sec.1737.
- [6] S. Scott-Hayward, S. Natarajan, and S. Sezer, "A survey of security in software defined networks," IEEE Commun. Surveys Tuts., vol. 18, no. 1, pp. 623-654, 1st Quart. 2016, doi: 10.1109/COMST.2015.2453114.
- [7] T. Peng, C. Leckie, and K. Ramamohanarao, "Survey of network-based defense mechanisms countering the DoS and DDoS problems," ACM Comput. Surveys, vol. 39, no. 1, Apr. 2007, Art. no. 3.
- [8] C. Kreibich and J. Crowcroft, "Honeycomb: Creating intrusion detection signatures using honeypots," ACM SIGCOMM Comput. Commun. Rev., vol. 34, no. 1, pp. 51-56, Jan. 2004.
- [9] N. Sultana, N. Chilamkurti, W. Peng, and R. Alhadad, "Survey on SDN based network intrusion detection system using machine learning approaches," Peer-to-Peer Netw. Appl., vol. 12, no. 2, pp. 493-501, Mar. 2019, doi: 10.1007/s12083-017-0630-0.

- [10] F. T. Liu, K. M. Ting, and Z.-H. Zhou, "Isolation forest," in Proc. 8th IEEE Int. Conf. Data Mining (ICDM), 2008, pp. 413-422, doi: 10.1109/ICDM.2008.17.
- [11] M. S. Elsayed, N.-A. Le-Khac, and A. D. Jurcut, "InSDN: A novel SDN intrusion dataset," IEEE Access, vol. 8, pp. 165263-165284, 2020, doi: 10.1109/ACCESS.2020.3022633.
- [12] S. Shin and G. Gu, "Attacking software-defined networks: A first feasibility study," in Proc. 2nd ACM SIGCOMM Workshop Hot Topics Softw. Defined Netw. (HotSDN), 2013, pp. 165-166.
- [13] D. Kreutz, F. M. V. Ramos, P. E. Verissimo, C. E. Rothenberg, S. Azodolmolky, and S. Uhlig, "Software-defined networking: A comprehensive survey," Proc. IEEE, vol. 103, no. 1, pp. 14-76, Jan. 2015, doi: 10.1109/JPROC.2014.2371999.
- [14] S. M. Lundberg and S.-I. Lee, "A unified approach to interpreting model predictions," in Proc. Adv. Neural Inf. Process. Syst. (NeurIPS), vol. 30, 2017, pp. 4765-4774.
- [15] G. Apruzzese, M. Colajanni, L. Ferretti, A. Guido, and M. Marchetti, "On the effectiveness of machine and deep learning for cyber security," in Proc. 10th Int. Conf. Cyber Conflict (CyCon), 2018, pp. 371-390, doi: 10.23919/CYCON.2018.8405026.
- [16] I. J. Goodfellow, J. Shlens, and C. Szegedy, "Explaining and harnessing adversarial examples," in Proc. Int. Conf. Learn. Represent. (ICLR), 2015.
- [17] N. Papernot, P. McDaniel, S. Jha, M. Fredrikson, Z. B. Celik, and A. Swami, "The limitations of deep learning in adversarial settings," in Proc. IEEE Eur. Symp. Secur. Privacy (EuroS&P), 2016, pp. 372-387, doi: 10.1109/EuroSP.2016.36.
- [18] A. Kurakin, I. J. Goodfellow, and S. Bengio, "Adversarial examples in the physical world," in Proc. Int. Conf. Learn. Represent. (ICLR) Workshop, 2017.
- [19] I. Corona, G. Giacinto, and F. Roli, "Adversarial attacks against intrusion detection systems: Taxonomy, solutions and open issues," Inf. Sci., vol. 239, pp. 201-225, Aug. 2013, doi: 10.1016/j.ins.2013.03.022.
- [20] B. Biggio et al., "Evasion attacks against machine learning at test time," in Proc. Eur. Conf. Mach. Learn. Knowl. Discovery Databases (ECML/PKDD), 2013, pp. 387-402, doi: 10.1007/978-3-642-40994-3\_25.
- [21] R. Sommer and V. Paxson, "Outside the closed world: On using machine learning for network intrusion detection," in Proc. IEEE Symp. Secur. Privacy (S&P), 2010, pp. 305-316, doi: 10.1109/SP.2010.25.

- [22] D. Arp et al., "Dos and don'ts of machine learning in computer security," in Proc. 31st USENIX Secur. Symp., 2022, pp. 3971-3988.
- [23] S. Kaufman, S. Rosset, C. Perlich, and O. Stitelman, "Leakage in data mining: Formulation, detection, and avoidance," ACM Trans. Knowl. Discovery Data, vol. 6, no. 4, Dec. 2012, Art. no. 15, doi: 10.1145/2382577.2382579.



```
# lateral movement, ARP spoof)
bash run_live_experiments.sh --controller http://localhost:9000 --duration
60
```

```
# Επιδεικτικό σενάριο 10 λεπτών
bash demo_10min.sh --no-build
```

## A.5 Θέση των αποτελεσμάτων

Τα αποτελέσματα αποθηκεύονται ως εξής: τα γραφήματα και οι μετρικές του offline pipeline στον φάκελο results/. Τα αποτελέσματα των ζωντανών σεναρίων (CSV/JSON ανά σενάριο) στον φάκελο results/live/. Τα εκπαιδευμένα μοντέλα και οι μετασχηματιστές κανονικοποίησης στον φάκελο models/. Η αναφορά RESULTS\_VERIFICATION.md συνοψίζει τα μετρημένα αποτελέσματα ανά σενάριο.

## A.6 Λίστα ελέγχου αναπαραγωγιμότητας

Ο ακόλουθος πίνακας συνοψίζει τα βήματα που αρκούν για την πλήρη επαλήθευση των αποτελεσμάτων σε καθαρό περιβάλλον, μαζί με το αναμενόμενο αποτέλεσμα κάθε βήματος. Η εκτέλεση του run\_all.sh χωρίς ορίσματα αναπαράγει τους πίνακες και τα σχήματα του κειμένου, καθώς το συνθετικό σύνολο παράγεται ντετερμινιστικά με σταθερό σπόρο τυχειότητας.

| Έλεγχος                          | Εντολή                                                | Αναμενόμενο αποτέλεσμα                                                   |
|----------------------------------|-------------------------------------------------------|--------------------------------------------------------------------------|
| <b>Εγκατάσταση εξαρτήσεων</b>    | pip install -r requirements.txt                       | Ολοκλήρωση χωρίς σφάλματα                                                |
| <b>Offline πειράματα</b>         | bash run_all.sh                                       | Ο βασικός κορμός των offline αποτελεσμάτων στο results/                  |
| <b>Αντίπαλη ανθεκτικότητα</b>    | python3<br>ml_pipeline/adversarial_training.py        | Παραγωγή των αρχείων adv_robust_*                                        |
| <b>Αυτοματοποιημένοι έλεγχοι</b> | pytest tests/ -v                                      | 140 tests: 133 επιτυχή, 7 skipped (χωρίς Docker/προαιρετικές εξαρτήσεις) |
| <b>Ζωντανή επίδειξη</b>          | docker compose -f<br>app_sdn/docker-compose.yml up -- | Ελεγκτής και dashboard ενεργά (θύρες 9000, 8050)                         |

|                             |                                        |                                                                                                                  |
|-----------------------------|----------------------------------------|------------------------------------------------------------------------------------------------------------------|
|                             | build                                  |                                                                                                                  |
| <b>Πλήρης αναπαραγωγή</b>   | bash reproduce_thesis.sh               | ΟΛΕΣ οι μελέτες του κειμένου, με αναφορά όσων βημάτων λείπουν λόγω προαιρετικών εξαρτήσεων                       |
| <b>Packet-level πείραμα</b> | bash<br>run_packet_level_experiment.sh | Πραγματικά dropped packets + κάλυψη αντιμετώπισης στο results/live/mininet_run_*/ και στο experiment_summary.csv |
| <b>Επαλήθευση artifacts</b> | sha256sum -c MANIFEST.sha256           | Όλα OK: μοντέλα, dataset και κύρια αποτελέσματα ταυτίζονται με το κείμενο                                        |

*Πίνακας A-1: Λίστα ελέγχου αναπαραγωγιμότητας των πειραμάτων.*

## Παράρτημα Β: Πλήρης πίνακας υπερπαραμέτρων του Isolation Forest

Ο ακόλουθος πίνακας παραθέτει τους κορυφαίους συνδυασμούς υπερπαραμέτρων του Isolation Forest, ταξινομημένους κατά το ROC-AUC επικύρωσης, όπως προέκυψαν από την εξαντλητική αναζήτηση (ενότητα 6.7). Η στήλη του ROC-AUC ελέγχου συμπληρώνεται μόνο για τη βέλτιστη διαμόρφωση, η οποία αξιολογείται μία φορά σε ανεξάρτητο σύνολο ελέγχου. Η μικρή διακύμανση των τιμών επιβεβαιώνει την ευρωστία του αλγορίθμου.

| n_estimators | max_samples | contamination | max_features | val ROC-AUC | val F1 | test ROC-AUC |
|--------------|-------------|---------------|--------------|-------------|--------|--------------|
| 100          | 256         | 0,02          | 1,0          | 0,9991      | 0,9941 | 0,9990       |
| 100          | 256         | 0,05          | 1,0          | 0,9991      | 0,9943 | -            |
| 100          | 256         | 0,10          | 1,0          | 0,9991      | 0,9879 | -            |
| 100          | auto        | 0,05          | 1,0          | 0,9991      | 0,9943 | -            |
| 100          | auto        | 0,10          | 1,0          | 0,9991      | 0,9879 | -            |
| 100          | auto        | 0,02          | 1,0          | 0,9991      | 0,9941 | -            |
| 300          | 512         | 0,10          | 1,0          | 0,9987      | 0,9884 | -            |
| 300          | 512         | 0,05          | 1,0          | 0,9987      | 0,9946 | -            |
| 300          | 512         | 0,02          | 1,0          | 0,9987      | 0,9845 | -            |
| 100          | 512         | 0,02          | 0,5          | 0,9986      | 0,9804 | -            |

*Πίνακας Β-1: Κορυφαίοι συνδυασμοί υπερπαραμέτρων του Isolation Forest (κατά ROC-AUC επικύρωσης. Η στήλη ελέγχου μόνο για τη βέλτιστη διαμόρφωση).*